

LargoVerse

Bezpečnostní architektura a plán rozvoje

Současný stav aplikace · cílový bezpečnostní stav na úrovni banky a blockchainu
mezerová analýza · plán a očekávaná náročnost

Verze 1.0 | 16. srpna 2026

Zpracováno auditem repozitáře largoverse-beta, revize bcfaa50

Klasifikace: důvěrné. Určeno pouze pro uzavřený investorský okruh.
Dokument obsahuje neopravené bezpečnostní nálezy — nešířit.

Obsah

1. Shrnutí pro vedení	4
Co dokument říká ve čtyřech větách	4
Poznámka k rozsahu, terminologii a verzi	4
Rozložení nálezů podle závažnosti	5
2. Rozsah, metoda a omezení	6
Co bylo předmětem	6
Co předmětem nebylo	6
3. Současný stav	7
3.1 Architektura	7
3.2 Funkční rozsah	7
3.3 Doručení a ochrana ukázky	10
3.4 Peněžní logika	12
3.5 Dodavatelský řetězec	14
3.6 Souhrn nálezů podle oblasti	14
4. Cílový bezpečnostní stav	15
4.1 Klientská vrstva	15
4.2 Backend a platforma	16
4.3 Blockchainová vrstva	17
4.4 Regulace a compliance	18
4.5 Ochrana osobních údajů	19
4.6 Cílová architektura	21
5. Mezerová analýza	22
Rozložení náročnosti podle oblasti	22
5.1 Blokátory ostrého provozu (P0)	23
5.2 Ostatní mezery (P1–P3)	28
6. Plán a očekávaná náročnost	30
6.1 Fáze	30
6.2 Dva odhady a proč se liší	30
7. Nezávislá oponentura	31
8. Doporučený postup	34
Tento týden	34

Do dvou měsíců, dřív než se napíše první řádek backendu	34
Co naopak před licencí nedělat	34
9. Co se od auditu změnilo	35
Příloha A — úplný seznam nálezů	36
Příloha B — úplný seznam požadavků cílového stavu	47

1. Shrnutí pro vedení

LargoVerse je dnes **úplná klikací simulace** retailové bankovní aplikace, která běží celá v prohlížeči. Nemá backend, nemá databázi, nemá server. Všechny peníze, účty, karty i historie jsou hodnoty v paměti prohlížeče, uložené do *localStorage*. Jako nástroj na předvedení produktu investorům je hotová a plní účel. Jako základ regulované finanční služby to **není architektura** — je to uživatelské rozhraní bez jádra.

90 nálezů v současném stavu	10 z toho kritických	130 požadavků cílového stavu	85 z toho právních povinností
59 identifikovaných mezer	44 blokátorů ostrého provozu	3 152 člověkodní zdola nahoru	5 500–7 000 po oponentuře (MD)

Co dokument říká ve čtyřech větách

- **Ukázka je bezpečná jako ukázka, ne jako produkt.** Šifrování nasazovaného balíčku je kryptograficky provedené správně (AES-GCM-256, PBKDF2-SHA256, 310 000 iterací), ale chrání jediné sdílené heslo bez možnosti odvolání a audit našel tři kritické nálezy přímo v doručovacím řetězci.
- **Peněžní logika nemá vlastnosti, které bankovní jádro mít musí.** Zůstatky jsou JavaScriptové floaty v prohlížeči, neexistuje podvojný účetnictví, operace nejsou idempotentní a zdrojem pravdy je zařízení klienta.
- **Cílový stav není otázka programování, ale licence.** Ze 130 zjištěných požadavků je 85 přímo vymahatelná právní povinnost — MiCA, PSD2, DORA, AML balíček, GDPR. Bez autorizace se ostrý provoz spustit nesmí.
- **Náročnost je řádově vyšší než odpovídá dnešnímu rozsahu prací.** Odhad zdola nahoru vychází na 3 152 člověkodní; nezávislá oponentura ho zvedá na 5 500–7 000 MD 24–33 měsíců a tým 14–25 lidí.

Poznámka k rozsahu, terminologii a verzi

Audit v tomto dokumentu se vztahuje ke **konkrétní revizi** repozitáře. Beta aplikace se od té doby změnila — přehled změn je v závěru dokumentu. Tabulka níž mapuje pojmy, aby při čtení nevznikl dojem rozporu.

Pojem	Co znamená v tomto dokumentu
Safe Money	Název funkce v aplikaci. Dokument ho používá všude, kde jde o produkt. Safe Money je vedené vždy v XSGD — vklad z jiné měny je po cestě směna.
„trezor“ jinde v textu	Technický pojem pro oddělené úložiště (PII trezor, AML trezor, break-glass trezor, fyzický trezor pro zálohy klíčů). S produktem nesouvisí a záměrně se nepřejmenovává.
„úschova kryptoaktiv“	Právní pojem podle čl. 75 MiCA (úschova a správa kryptoaktiv jménem klientů). Také se nepřejmenovává — je to znění nařízení.

Pojem	Co znamená v tomto dokumentu
Fáze 1 / 2 / 3	Kdy se komponenta staví, ne pořadové číslo v seznamu. Fáze 1 = přežije každé budoucí rozhodnutí, staví se hned. Fáze 2 = až po rozhodnutí o licenci. Fáze 3 = až před ostrým provozem.
Částky v příkladech	Ilustrativní. Neodpovídají zůstatkům v beta aplikaci a nejsou požadavkem na ni — popisují cílový systém.
Karty	V cílovém systému se PAN, CVV ani PIN neukládají vůbec — drží se jen token vydavatele a údaje karty se zobrazují komponentou vydavatele. Beta aplikace je ukazuje simulačně a čísla v ní jsou záměrně neplatná.

Nejdůležitější jednotlivý nález

Nasazovací heslo se dostává v čitelné podobě do sestaveného souboru na disku, a to i u šifrovaného buildu. Heslo, které chrání celou ukázkou, tedy leží v otevřené podobě ve složce synchronizované do cloudového úložiště. Náprava je otázka hodin a nemá na co čekat — detail v kapitole 3.3.

Rozložení nálezů podle závažnosti

Závažnost	Počet	Co to znamená
Kritická	10	Ohrožuje důvěrnost ukázky nebo by v ostrém provozu znamenalo ztrátu peněz.
Vysoká	32	Bez nápravy nelze systém provozovat s cizími prostředky.
Střední	31	Nutné před spuštěním, ale nebrání dalšímu vývoji.
Nízká	9	Technický dluh s omezeným dopadem.
Informativní	8	Pozorování bez přímého bezpečnostního dopadu.

2. Rozsah, metoda a omezení

Dokument vznikl statickým auditem repozitáře a rešerší platné evropské regulace. Auditovaný stav odpovídá revizi *bcfaa50* na větvi *main* ke dni 16. srpna 2026, tedy včetně sazebníku podle stavu ekonomiky a úschovy po měnách.

Co bylo předmětem

- Úplný zdrojový kód aplikace — doménová vrstva, stavová vrstva, obrazovky, sdílené komponenty, lokalizace a sestavovací skripty.
- Doručovací řetězec — šifrovaný jednosouborový build, zaváděcí stránka, přístupová brána, správa tajemství, rozdělení veřejného a privátního repozitáře, hosting.
- Integrita peněžní logiky — zůstatky, zaokrouhlování, perzistence, souběh, auditovatelnost.
- Dodavatelský řetězec — přímé závislosti, absence CI a testů, reprodukovatelnost buildu.
- Cílový stav podle OWASP MASVS a ASVS, PSD2 a RTS 2018/389, DORA, ISO/IEC 27001:2022, MiCA, AML balíčku, nařízení 2023/1113 (Travel Rule) a GDPR.

Co předmětem nebylo

- Penetrační test běžící aplikace. Audit je statický — nebyl prováděn žádný útok na živou adresu.
- Právní posouzení. Regulatorní část je podklad pro právníky, nikoli právní stanovisko. Klient si formulace nechává kontrolovat vlastními zástupci a tento dokument to nenahrazuje.
- Posouzení obchodního modelu, jeho ekonomiky a životaschopnosti cílového trhu.
- Ověřování třetích stran — údaje o emitentech stablecoinů pocházejí z veřejných zdrojů a před použitím v obchodních materiálech je nutné je znovu ověřit.

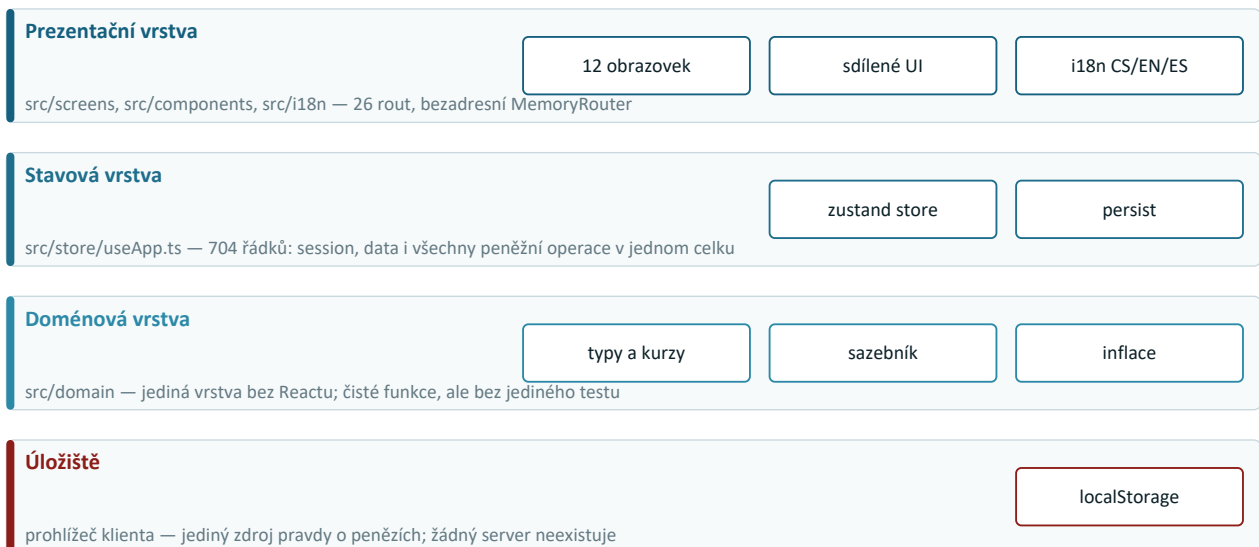
Jak číst nálezy

Nález o závažnosti „kritická“ nebo „vysoká“ **neznamená, že je dnes něco rozbité**. Znamená, že vlastnost, kterou by regulovaná finanční aplikace mít musela, v současném řešení chybí — a že by se to v ostrém provozu projevilo. Ukázka je ukázka; problém nastane ve chvíli, kdy se z ní má stát produkt bez toho, aby se jádro postavilo znovu.

3. Současný stav

3.1 Architektura

LargoVerse je jednostránková React aplikace bez jakéhokoli backendu: 50 verzovaných souborů, ~5 500 řádků TSX/TS, pět runtime závislostí (react, react-dom, react-router-dom 6.30.4, zustand 5.0.14, lucide-react). Vrstvení je čitelné a poctivě komentované — src/domain drží čisté typy, kurzy, sazebník a inflační snímek, src/lib formátování a překlad, src/components sdílené prvky, src/screens jedenáct souborů s obrazovkami — ale veškerý stav i všechna peněžní logika sedí v jediném zustand store (src/store/useApp.ts, 704 řádků) s persist do localStorage, takže mezi UI a daty neexistuje žádná servisní vrstva. Routing běží na MemoryRouteru uvnitř simulovaného rámu telefonu, takže aplikace nemá URL, deep-linky ani prohlížečové zpět a cesty pod /app nejsou nijak chráněné; lokalizace je vlastní plochá mapa se třemi slovníky v ověřené paritě (284 klíčů, typ Dict odvozený z češtiny), byť část textů i18n obchází. Build je záměrně minimální (vite.config.ts má 8 řádků) a jeho podstata je v scripts/build-secure.mjs, který celý bundle zašifruje do jediného 1,4 MB index.html chráněného heslem. Typecheck prochází bez chyby, ale v repozitáři nejsou žádné testy, lint ani CI. Jako investorská ukázka je to konzistentně postavené a dobře zdokumentované dílo; produkční slabiny jsou v tom, že peníze jsou floaty s ručním zaokrouhlením, historie transakcí není dvojité účetnictví, tajemství karet se persistují a nasazovací skript má tichou podmínku (jediný JS chunk), na které stojí funkčnost celého nasazeného buildu.



Vrstvy současné aplikace. Červená vrstva je jádro problému: pod stavovou vrstvou už nic není.

3.2 Funkční rozsah

Aplikace je úplná klikací simulace retailového bankovníctví: brána na kód, registrace/přihlášení, KYC, tři účty (CZK/USD/EUR), tři karty, platby (tuzemské, zahraniční, P2P, na vlastní účet, QR), směna mezi pěti měnami, Safe Money po měnách, peněženka s VES/XSGD, historie s filtry, notifikace, tři jazyky a režim prezentace s ručními spouštěči. Všechno běží výhradně v prohlížeči — jediným zdrojem pravdy je objekt v zustand storu, který se celý ukládá do localStorage pod klíčem largoverse-beta-3, včetně PINů, CVV a čísel karet; kdo otevře devtools, přepíše si zůstatek. Peněžní logika je promyšlenější, než bývá u atrap: spread se opravdu odečítá na obě strany, směna tam a zpět je ztrátová, sazebník rozlišuje hyperinflační a standardní pár a srovnání kupní síly je počítané z doložených inflačních čísel a nikde se nevydává za výnos. Zásadní rozdíly proti skutečné bance nejsou v matematice, ale v tom, co chybí: nic neověřuje totožnost ani heslo, session nikdy nevyprší, platba nemá potvrzení ani druhý faktor, limity a

zámek karty se nikde nevynucují a zůstatek se vede odděleně od historie, takže se nedají navzájem odsouhlasit. Sazebník z pricing.ts se navíc uplatňuje jen v jedné ze čtyř cest, kterými se v aplikaci hýbe penězi — převod mezi vlastními účty konvertuje středovým kurzem bez spreadu a Safe Money obchází pevný poplatek.

Funkční celek	Co dnes umí
Přístupová brána a distribuce buildu	Před spuštěním aplikace se ptá na přístupový kód. unlock(code) normalizuje vstup (velká písmena, jen A-Z0-9) a porovná se seznamem z VITE_ACCESS_CODES; při shodě nastaví unlocked: true. unlocked se záměrně NEukládá do persistence, takže po zavření okna se brána zavře znovu. Při VITE_GATE=off se brána vypne úplně — to používá šifrovaný build, kde heslo padne už v zaváděcí stránce (AES-GCM 256, PBKDF2-SHA256, 310 000 iterací). Nad tím stojí Cloudflare Access se seznamem pozvaných e-mailů.
Jazyk, onboarding, registrace a přihlášení (session)	Devět obrazovek: výběr jazyka (setLang, confirmLanguage), čtyřsnímkový onboarding (finishOnboarding), registrace a přihlášení e-mailem i telefonem, zapomenuté heslo a potvrzení odeslání. Sociální tlačítka Google/Apple/Facebook. Všechny cesty končí voláním signIn(), které nastaví authed: true — žádné údaje se neukládají ani neporovnávají. signOut() shodí jen authed, ne jazyk, onboarding ani KYC, aby se ověřenému klientovi po odhlášení nabídlo přihlášení místo registrace. Rozcestník Entry v App.tsx řídí, kam se po st
KYC / ověření identity	Seznam kroků: výběr typu dokladu (setDocType: idCard passport driverLicense), nahrání přední a zadní strany, selfie s vlastní záběrovou obrazovkou, doplňkové dokumenty (faktura + výpis), stav zpracování a nabídka Face ID. Každý „upload“ je boolean přepínač přes setKycFlag; obrazovka k němu dokreslí vymyšlený název souboru a velikost. submitKyc() přepne stav na pending, approveKyc() na approved. Bez approved stavu rozcestník do /app nepustí.
Účty	Seznam tří účtů (CZK 37 129,64 / USD 3 129,64 / EUR 3 129,64) s filtrem podle měny. U každého: detail s číslem účtu, IBAN, BIC a majitelem (kopírování jen zobrazí toast), zkratka na nový platební příkaz, výpis transakcí a vygenerování dekorativního QR kódu. Účty se v aplikaci nedají zakládat ani rušit — pole accounts vzniká výhradně ze seedu.
Karty	Přehled nezrušených karet s filtrem podle měny a detail karty. Akce: setCardState (zamknout/odemknout), setCardPin (nový PIN přes numpad), setCardLimit pro tři limity (obchodník, hotovost, internet), cancelCard (nastaví cancelled + locked, karta zmizí ze seznamu) a generateCard (nová VISA na daný účet, náhodné číslo, CVV a PIN, limity přepočtené kurzem do měny účtu). Zobrazení PINu i čísla karty s CVV má odpočet 17 s. Zůstatek na kartě = zůstatek účtu, ke kterému patří.
Platby	Spodní panel s pěti cestami. (1) pay() — odepíše částku ze zvoleného účtu a zapíše řádek historie; kontroluje jen amount > 0 a dostatek zůstatku, žádný poplatek. Formulář umí tuzemskou variantu (číslo účtu + VS/KS/SS pod rozbalovátkem) i zahraniční (IBAN + SWIFT). (2) P2P na e-mail s předvyplněním ze čtyř kontaktů. (3) transferOwn() — mezi vlastními účty: připiše convert(amount) v cílové měně, odepíše částku plus poplatek 50 CZK přepočtený do měny zdroje, zapíše dva řádky. (4) Tři šablony (nájem 14 500, doprava
Směna měn a sazebník	Obousměrná směna mezi pěti drženými měnami (EXCHANGEABLE = CZK, EUR, USD, VES, XSGD). exchangeAny(from, to, amount) najde, kde je která měna vedená (účet podle měny, nebo wallet.ves / wallet.xsgd), odmítne směnu, když jedna strana nikde není, zaokrouhlí vstup podle desetinných míst zdrojové měny, spočítá sazbu přes tariffFor (hyper = spread 1,5 % bez poplatku, standard = spread 1,5 % + 50 CZK), ověří krytí částky včetně poplatku, odepíše, připiše convert × (1 – spread) a zapíše dva až tři řádky historie (odpis, při
Safe Money a srovnání kupní síly	Oddělená část zůstatku vedená po měnách (wallet.vaults, seed VES 12 000 a CZK 8 500). vaultMove(currency, amount, direction, source) přesune peníze mezi volným zůstatkem a Safe Money; když se měna zadání liší od měny Safe Money, je to zároveň směna se stejným spreadem jako na obrazovce směny — při vkladu se částka násobí (1 – spread), při výběru dělí, aby klient dostal na účet přesně to, co si zadal. Nad tím je srovnání kupní síly: purchasingPowerGap počítá (1 + inflace kotvy) / (1 + inflace měny) – 1 proti XSGD/SG
Peněženka, přehled aktiv a crypto	Celková hodnota všeho přepočtená do CZK, přetahovatelný seznam aktiv (tři účty + VES + XSGD + řádek pro každou měnu Safe Money, pořadí drží assetOrder a mění reorderAssets přes pointer events) a výpis pohybů peněženky (transakce s accountId 'wallet'). K tomu obrazovka nákupu XSGD (volá exchangeAny) a příjmu XSGD s adresou peněženky, QR a sítí „XSGD · Polygon“. Komponenta Amount umí kteroukoli částku přepočítat do jiné měny — volba displayCurrency je globální a persistovaná, drženou hodnotu nemění.
Historie transakcí a vyhledávání	Výpis jednoho účtu seskupený po měsících a fulltextové hledání s filtry: částka (přesná shoda absolutní hodnoty), rozsah dat přes vlastní kalendář, směr příchozí/odchozí a sedm rychlých návrhů (včera, tento/minulý týden, měsíc, rok). Prázdný stav. Řádek transakce má ikonu podle druhu (12 druhů), titulke, poznámku nebo přeložený podtitulek, znaménkovanou částku v původní měně a datum.

Funkční celek	Co dnes umí
Profil a notifikace	Profil s jménem majitele, odznakem „ověřeno“ podle KYC, přepínačem jazyka za běhu (cykluje cs → en → es) a šesti položkami menu, z nichž funguje jen jazyk a notifikace — osobní údaje, bezpečnost, dokumenty a podpora jsou slepé. Notifikace: seznam čtyř seedovaných zpráv s nepřechteným stavem, hromadné označení jako přečtené (markNotificationsRead) a nepřechtený puntík v hlavičce přehledu.
Režim prezentace a reset	Tři ruční spouštěče, které nikdy neběží samy: simulateIncoming (připíše 2 450 CZK na běžný účet, přidá transakci i notifikaci), simulateCardCharge (odepíše 1 890 CZK přes první aktivní korunovou kartu, pokud je krytí) a simulateCryptoIn (připíše 250 XSGD do peněženky). resetDemo() vrátí účty, karty, transakce, notifikace, kontakty, šablony a peněženku na seed a shodí session, KYC, Face ID, zvolenou zobrazovací měnu i pořadí aktiv.

3.3 Doručení a ochrana ukázky

Samotná kryptografie v ``scripts/build-secure.mjs`` je provedená správně: náhodná 16bajtová sůl a 12bajtový IV na každý build, AES-GCM-256, klíč z PBKDF2-SHA256 se 310 000 iteracemi, klíč se nikde neukládá. Ciphertext v ``deploy/index.html`` neobsahuje heslo a git historie je čistá — tajemství nebylo nikdy commitnuté a repozitář je privátní. Tím ale pochvala končí. Nasazovací heslo ``LARGO-HETN-BD7M-B9TY`` je doslova vloženo do sestaveného JS (``dist/assets/index-hmPcZoc-.js``) i při běhu ``build:secure``, protože skript vypíná bránu přes ``VITE_GATE=off``, ale nechává Vite načíst ``VITE_ACCESS_CODES`` z ``.env.local`` — a ``.env.example`` s README tuhle shodu obou tajemství přímo nařizují. Ochrana stojí a padá na jednom sdíleném hesle, které nejde odvolat, nejde auditovat a jehož normalizace (``toUpperCase().replace(/[^\A-Z0-9]/g, "")``) mlčky zahazuje entropii — povolené minimum 8 znaků odpovídá jen ~41 bitům a útočník má soubor u sebe, takže hádá offline bez jakéhokoli omezení. Zamčená stránka navíc bez hesla vyzrazuje klienta: značku, investorský kontext a logo v čitelném base64 (2× 152 kB). Doručení dnes fakticky nestojí nikde — GitHub Pages není u repozitáře nakonfigurované, wrangler není nainstalovaný ani přihlášený, takže pro žádné nasazení šifrovaného buildu neexistuje lokální doklad; a kdyby někdo Pages zapnul z ``main``, zveřejnil by zdrojový kód, protože ``deploy/`` se neverzuje a v kořeni leží vývojový ``index.html``.

Kritické nálezy v doručovacím řetězci

Nasazovací heslo je vloženo v čitelné podobě do sestaveného JS — i při šifrovaném buildu

``scripts/build-secure.mjs`` (ř. 57–62) spouští Vite s ``env: { ...process.env, VITE_GATE: 'off' }``. Vypíná tím vnitřní bránu, ale nijak neruší ``VITE_ACCESS_CODES`` — a Vite si ho stejně načte přímo z ``.env.local`` na disku. Vite všechny ``VITE_*`` proměnné nahrazuje literálem už při buildu, takže se do bundlu vypeče ostré nasazovací heslo. Není to teorie: ``dist/assets/index-hmPcZoc-.js`` (mtime 17:03:05.665) a ``deploy/index.html`` (mtime 17:03:05.823) vznikly 0,16 s po sobě, tedy jedním během ``build:secure`` — a ten dist s heslem uvnitř zůstává na disku, protože skript maže jen ``deploy/``, nikoli ``dist/``.

Důkaz: `dist/assets/index-hmPcZoc-.js: 'A-Z0-9]/g, ""), Am="LARGO-HETN-BD7M-B9TY".split("").map(Fd).filter(Boo`` — obsahuje doslovné heslo z ``.deploy-passphrase.txt``. Zdroj: `src/store/useApp.ts:148 `const ACCESS_CODES = (import.meta.env.VITE_ACCESS_CODES ?? 'DEMO')``. Vypí

Šifrovací klíč je z rozhodnutí projektu totožný s vývojovým přístupovým kódem

README (ř. 56–58) i ``.env.example`` výslovně instruují, aby se ``VITE_ACCESS_CODES`` drželo shodné s heslem, kterým se šifruje nasazený build — s odůvodněním, že jinak „localhost chce jiný kód než živá adresa“. Na disku to tak skutečně je: ``.env.local`` obsahuje ``LARGO-HETN-BD7M-B9TY`` a ``.deploy-passphrase.txt`` obsahuje přesně tentýž řetězec. Tím se z pohodlnosti při vývoji stává jediné tajemství sdílené mezi vrstvou, o které se samo README píše, že „nechrání před nikým“, a vrstvou, která má být jediná skutečná ochrana.

Důkaz: ``.env.local: `VITE_ACCESS_CODES=LARGO-HETN-BD7M-B9TY`; .deploy-passphrase.txt: `LARGO-HETN-BD7M-B9TY`.env.example: „Držte ho STEJNÝ jako heslo, kterým šifrujete nasazený build“. README.md:56-58.`

Jedno sdílené heslo bez odvolatelnosti — stažená kopie platí navždy

Celý model je „jeden soubor + jedno heslo pro všechny“. Neexistuje přístup per osoba, neexistuje expirace, neexistuje seznam pro zneplatnění a neexistuje záznam, kdo odemkl. Zásadní je, že `deploy/index.html` je statický soubor — kdokoli si ho uloží (Ctrl+S, curl, cache prohlížeče) a má offline kopii, kterou stejné heslo otevře napořád. Změna hesla znamená přešifrovat a znovu nahrát, což nijak neovlivní kopie, které si lidé už stáhli. README tenhle problém částečně přiznává u přeposlání odkazu a nabízí Cloudflare Access, ale Access chrání jen cestu k souboru, ne už rozdané kopie.

Důkaz: scripts/build-secure.mjs:252-259 zapisuje jediný statický `deploy/index.html`. Neexistuje žádný server, žádná validace tokenů ani kontrola vypršení — loader v ř. 186-231 pouze lokálně dešifruje. Heslo je jedna hodnota bez struktury (`arg('pass') ?? process.env`)

3.4 Peněžní logika

Zůstatky jsou vedené jako obyčejná čísla s plovoucí desetinnou čárkou přímo ve stavu prohlížeče (`accounts[].balance`, `wallet.ves`, `wallet.xsgd`, `wallet.vaults`) a jsou jediným zdrojem pravdy; pole `transactions` je jen zápis vedle, který se s nimi nikde neporovnává. Podvojný účetnictví ani audit trail neexistují — poplatky se strhávají a nikam se nepřipisují, převod mezi vlastními účty nemá spárované strany, a nic nebrání tomu, aby zůstatek a součet pohybů rozešly. Celý stav je uložený v localStorage pod klíčem `largoverse-beta-3` a dá se z konzole prohlížeče přepsat na libovolnou hodnotu, včetně `kyc.status` a `authed`. Našel jsem tři cesty, kterými hodnota reálně vzniká nebo se ztrácí: platba pod jeden halíř neodepíše nic, ale zapíše se, `NaN` projde všemi kontrolami a natrvalo znehodnotí zůstatek, a stejná konverze CZK→USD stojí přes „převod na vlastní účet“ o 15 000 CZK méně než přes obrazovku Směna (na 1 milionu CZK). Operace nejsou idempotentní, nemají žádný identifikátor požadavku a dvě otevřené karty prohlížeče si stav navzájem přepisují bez varování. V repozitáři nejsou žádné testy.

Kritické nálezy v peněžní logice

Žádné podvojný účetnictví — zůstatek a historie jsou dvě nezávislé pravdy

Zůstatek je vlastní pole (`accounts[].balance`, `wallet.ves`, `wallet.xsgd`, `wallet.vaults[c]`), které se mění přímo. Pole `transactions` se plní vedle něj a nikde se nepoužije k odvození ani ke kontrole zůstatku. Neexistuje invariant „součet pohybů = zůstatek“, žádná rekonsiliace, žádný uzávěrkový bod. Že to spolu nesouvisí, dokazují už seed data: `seedAccounts[0].balance = 37129.64` je ručně zapsané číslo, které nijak neodpovídá součtu `seedTransactions`. Transakce navíc nemají mezi sebou vazbu — `transferOwn` zapíše dva řádky bez společného identifikátoru, `exchangeAny` dva až tři, a nic je nespojuje. Nic není nikdy jen připsáno k nějakému protiúčtu: peníze při platbě prostě zmizí ze systému.

V ostrém provozu: Ledger v bance není záznam o penězích — ledger JE ty peníze. Tady je opačně: číslo v `balance` je pravda a historie je popis. Jakákoli chyba v jednom ze čtyř míst, kde se `balance` mění, tiše vytvoří nebo zničí hodnotu a nikdo to nezjistí, protože není proti čemu porovnávat. Klient nemůže reklamovat

Zdroj pravdy o penězích je localStorage prohlížeče, přepsatelný jedním řádkem v konzoli

Celý stav včetně zůstatků, historie, KYC statusu a příznaku přihlášení se serializuje do localStorage pod klíčem `largoverse-beta-3`. `partialize` vyřazuje jen `toast` a `unlocked` — všechno ostatní se uloží. Kdokoli může v devtools spustit `JSON.parse(localStorage['largoverse-beta-3'])`, změnit `state.accounts[0].balance` na libovolné číslo, přidat si transakce, nastavit `state.kyc.status = 'approved'` a `state.authed = true`, uložit zpět a načíst stránku. Server neexistuje, ověření neexistuje. Přístupový kód `unlock()` porovnává řetězec, který je součástí staženého balíčku — což komentář v kódu poctivě přiznává.

V ostrém provozu: Klient si nastaví libovolný zůstatek a odešle ho pryč. Obejde KYC nastavením jednoho pole, čímž padá celý AML režim — a s ním licenční podmínka provozu. Zároveň jde o klasický scénář, kdy poškozený není banka, ale klient: kdokoli s krátkodobým přístupem k odemčenému zařízení mu může stav přepsat a o

Platba pod jeden halíř neodepíše nic, ale odešla se — hodnota vzniká z ničeho

``pay()`` svůj vstup nezaokrouhluje. Kontrola je jen ``amount <= 0``. Zůstatek se pak nastaví na ``round(a.balance - amount)`` se dvěma desetinnými místy, takže při částce pod 0,005 se výsledek zaokrouhlí zpět na původní hodnotu. Ověřeno výpočtem: 1 000 plateb po 0,004 CZK z 37 129,64 CZK nechá zůstatek na přesně 37 129,64 CZK, přičemž každá platba zapíše řádek (s částkou ``-0``) a vrátí ``true``. Totéž na dolarovém účtu s 0,0049 USD. Z UI je to dosažitelné — ``Payments.tsx`` kontroluje jen ``value > 0``, žádné omezení na počet desetinných míst. Pro srovnání: ``exchangeAny`` tuhle díru má zavřenou (zaokrouhlí vstup a znovu zkontroluje proti nule, řádky 353-357), takže autor si problém uvědomil na jednom místě a nepřenesl ho na ostatní.

V ostrém provozu: Doslova tiskárna peněz, provozovatelná z běžného rozhraní bez jakéhokoli nástroje. Ve skutečné bance by odchozí příkaz šel do zúčtování v plné zadané hodnotě, zatímco odesílatelův účet by se nepohnul — rozdíl by šel z prostředků banky, tedy z peněz ostatních klientů. Objem je omezený jen počtem opak

NaN a Infinity projdou všemi kontrolami a natrvalo znehodnotí zůstatek

Všechny peněžní funkce se brání pouze porovnáním typu ``amount <= 0`` a ``balance < amount``. Obě porovnání jsou s ``NaN`` vždy ``false``, takže ``NaN`` projde jako platná částka. Ověřeno: ``NaN <= 0`` → `false`, ``37129.64 < NaN`` → `false`, ``round(NaN, 2)`` → `NaN`. Zůstatek se tím nastaví na ``NaN``, uloží se do `localStorage` jako ``null`` a po načtení se z něj stane trvale nepoužitelný stav — každý další výpočet, součet aktiv i ``convert()`` vrátí ``NaN``. Stejně projde ``Infinity`` (``Infinity <= 0`` je `false`). Dnes to z UI nespustíte, protože obrazovky mají vlastní pojistky (``Number(...) || 0`` v `Exchange` a `Crypto`, ``value > 0`` v `Payments`, kde ``NaN > 0`` je `false`) — ale to znamená, že jediná ochrana peněz je v prezentační vrstvě a store se nechrání sám.

V ostrém provozu: Jeden nekontrolovaný vstup — vadné pole ve formuláři, chyba v parsování odpovědi z API, poškozený řádek v dávkovém importu — a zůstatek klienta se stane nečíslem. Účet přestane fungovat celý: neprojde platba, neprojde příchozí, nejde spočítat úrok ani poplatek, a hodnota už nejde odvodit, protože hi

Operace nejsou idempotentní a nemají identifikátor požadavku

Každá peněžní funkce provede pohyb bezpodmínečně a vygeneruje si nové náhodné id (``uid()``). Neexistuje klientem zadaný idempotency key, žádná deduplikace, žádný stav operace (zahájeno/potvrzeno/zamítnuto), žádná evidence už provedených požadavků. Funkce vrátí pouze ``boolean``, takže volající nemá jak zjistit, jestli operace, kterou opakuje, už proběhla. Tlačítka se během odesílání nedeaktivují — ``Payments.tsx`` volá ``pay()`` a teprve pak ``onClose()``, ``Exchange.tsx`` volá ``exchangeAny()`` v ``onClick`` bez jakékoli pojistky proti opakovanému stisku.

V ostrém provozu: Dvojitě odepsání při každém dvojklíku, každém opakovaném odeslání po výpadku sítě, každém retry na straně klienta i infrastruktury. V síťovém provozu je opakování normální stav, ne výjimka — klient nikdy neví, jestli neodpovídající požadavek proběhl, takže ho zopakuje. Bez idempotence to znamená dru

3.5 Dodavatelský řetězec

LargoVerse je jednorepozitářová Vite/React SPA (5 přímých runtime závislostí, 5 dev) bez backendu, verzovaná v privátním GitHub repu MajkPowa/largoverse-beta, nasazovaná na Cloudflare Pages jako jediný AES-GCM šifrovaný soubor. Hygiena tajemství v gitu je nadprůměrná: .gitignore byl kompletní už od prvního commitu, sken celé historie neodhalil žádnou commitnutou hodnotu hesla, e-mailu investora ani API tokenu. Slabinou není to, co je v repu, ale to, co kolem něj chybí — neexistuje jediný test, jediný CI workflow ani jakákoli automatická brána mezi změnou kódu a nasazením; jediná kontrola je `tsc`, kterou musí někdo spustit ručně. Reprodukovatelnost buildu je částečná: lockfile je úplný a integritní, ale README učí `npm install` místo `npm ci`, verze Node není nikde připnutá a nasazuje se s `--commit-dirty=true`, takže k nasazenému artefaktu neexistuje ověřitelný commit. Bezpečnostní model stojí na jednom sdíleném hesle, které je zároveň vývojovým přístupovým kódem, leží v cleartextu ve složce synchronizované do OneDrive a jehož minimální délku skript vynucuje jen na 8 znaků, přestože útočník má šifrovaný soubor u sebe a může ho lámat offline.

3.6 Souhrn nálezů podle oblasti

Oblast	Kritická	Vysoká	Střední	Ostatní	Celkem
Architektura	—	5	7	3	15
Funkční rozsah	2	8	8	6	24
Doručení a ochrana	3	6	4	3	16
Peněžní logika	5	8	8	2	23
Dodavatelský řetězec	—	5	4	3	12
Celkem	10	32	31	17	90

Úplný seznam všech 90 nálezů včetně důkazů je v příloze A.

4. Cílový bezpečnostní stav

Cílový stav není jedna norma, ale průnik pěti vrstev požadavků, které se překrývají a nelze je splnit jedním opatřením ani jednou licencí. Rešerše zjistila celkem 130 konkrétních požadavků; 85 z nich je přímo vymahatelná právní povinnost, 41 de facto standard, který dohled i protistrany očekávají.

Vrstva	Právní povinnost	De facto standard	Doporučení	Celkem
Klientská vrstva	18	15	0	33
Backend a platforma	19	4	0	23
Blockchainová vrstva	5	20	2	27
Regulace a compliance	25	1	1	27
Ochrana osobních údajů	18	1	1	20

4.1 Klientská vrstva

Klientská část platební aplikace stojí na třech vrstvách požadavků. (1) Právní vrstva: v EU je nejtvrdším a přímo vymahatelným pramenem Nařízení Komise v přenesené pravomoci (EU) 2018/389 (RTS k PSD2) — dva nezávislé faktory, dynamic linking, max. 5 minut nečinnosti, max. 5 neúspěšných pokusů, a čl. 9(3), který přímo vyžaduje oddělené bezpečné prostředí, kontrolu integrity aplikace a mitigaci při kompromitaci víceúčelového zařízení; to je právní opora pro root/jailbreak detekci a anti-tampering. K tomu DORA (od 1/2025) plus zúžené EBA/GL/2025/02 (od 5/2025), PCI DSS 4.0.1 pro webové platební stránky (req. 6.4.3 a 11.6.1 povinné od 31. 3. 2025) a nově Cyber Resilience Act, jehož ohlašovací povinnosti platí od 11. 9. 2026 (hlavní povinnosti od 11. 12. 2027) a mobilní bankovní aplikace do jeho působnosti spadá. (2) De facto standardní vrstva: OWASP MASVS v2.1.0 (8 kategorií, 24 kontrol; poslední vydání 18. 1. 2024, stále aktuální) a k němu OWASP MASTG v2.0.0 (první stabilní vydání nové modulární struktury, 30. 6. 2026) s testovacími profily MAS-L1 / MAS-L2 / MAS-R — pro banku je referenční MAS-L2 + MAS-R. Pro web OWASP ASVS 5.0.0 (30. 5. 2025, 17 kapitol, ~350 požadavků), kde je autentizace kap. 6, správa relací kap. 7, self-contained tokeny kap. 9, frontend kap. 3. (3) Doporučení: platformové novinky (StrongBox, Play Integrity, App Attest, detekce nahrávání obrazovky od API 35), které regulace nepředepisuje jmenovitě, ale bez kterých se výše uvedené právní požadavky prakticky n

Klíčové právní povinnosti

Požadavek	Co znamená implementačně	Zdroj
Silné ověření klienta: dva prvky ze tří nezávislých kategorií	Přihlášení k účtu i iniciace platby musí vyžadovat dva prvky z různých kategorií — znalost (PIN/heslo), vlastnictví (vázaná instance aplikace, SIM, hardwarový klíč) a inherence (biometrie). Implementačně: klient nikdy nesmí sám rozhodovat o úspěchu SCA. Klientská část jen shromáždí důkazy a nechá autentizační kód vygenerovat kryptograficky (podpis klíčem v Keystore/Secure Enclave) — samotný boolean 'biometrie OK' vrácený z kli	Commission Delegated Regulation (EU) 2018/389, čl. 4(1) a čl. 9(1) (nezávislost prvků); PSD2 (EU) 2015/2366 čl
Dynamic linking — autentizační kód vázaný na částku a příjemce	Autentizační kód musí být kryptograficky specifický pro konkrétní částku a konkrétního příjemce; jakákoli změna kteréhokoli z nich kód zneplatní. Implementačně: potvrzovací obrazovka musí zobrazit částku a příjemce (nebo jejich zkrácený tvar) tak, jak je do podpisu vstupují — tedy z dat přijatých ze serveru pro tuto transakci, ne z lokálního stavu formuláře. Do podpisu (challenge) vstupuje transaction ID + částka + měna + iden	Commission Delegated Regulation (EU) 2018/389, čl. 5(1) a 5(2)

Požadavek	Co znamená implementačně	Zdroj
Ochrana při běhu na víceúčelovém zařízení: oddělené prostředí, kontrola integrity, mitigace	Právně nejdůležitější a nejčastěji přehlížené ustanovení pro klienta. Pokud se prvky SCA používají na víceúčelovém zařízení (běžný mobil), poskytovatel MUSÍ přijmout: (a) oddělená bezpečná prováděcí prostředí — v praxi TEE/StrongBox na Androidu, Secure Enclave a Keychain s ACL na iOS; (b) mechanismy, které ověří, že software nebo zařízení nebyly pozmeněny — ověření podpisu APK/IPA za běhu, kontrola instalačního zdroje, vzdálen	Commission Delegated Regulation (EU) 2018/389, čl. 9(3)(a)–(c)
Timeout relace: max. 5 minut nečinnosti pro přístup k účtu	Maximální doba bez aktivity plátce po autentizaci pro online přístup k platebnímu účtu nesmí překročit 5 minut. Implementačně: timeout musí být vynucen SERVEREM (invalidace session tokenu), klientský odpočet je pouze UX doplněk. Klient posílá keep-alive jen na skutečnou uživatelskou interakci, ne na pollování zůstatku na pozadí. Po přechodu aplikace do pozadí je vhodné relaci zamknout okamžitě. Na webu totéž — expire session	Commission Delegated Regulation (EU) 2018/389, čl. 4(3)(d)
Limit neúspěšných pokusů o autentizaci: max. 5	Nejvýše pět po sobě jdoucích neúspěšných pokusů, pak dočasné nebo trvalé zablokování. Implementačně: čítač je autoritativně na serveru a je vázaný na uživatele/zařízení, ne na instanci aplikace (jinak stačí reinstalace nebo smazání app dat). Pokud aplikace umožňuje offline ověření lokálního PINu proti klíči v Keystore, musí čítač držet i tento klíč (Android: setUserAuthenticationRequired + invalidate; nebo vlastní čítač uložen	Commission Delegated Regulation (EU) 2018/389, čl. 4(3)(b) a čl. 4(3)(c); PSD2 čl. 97(1)
Device binding — vázání instance aplikace na zařízení jako důkaz vlastnictví	Mobilní aplikace je platným prvkem 'vlastnictví' pouze tehdy, je-li chráněna mechanismem device bindingu, který jednoznačně váže instanci aplikace na konkrétní zařízení. Implementačně: při onboardingu vygenerovat asymetrický klíčový pár uvnitř hardwarového úložiště, non-exportable (Android: KeyGenParameterSpec se setIsStrongBoxBacked(true) kde je k dispozici, jinak TEE; iOS: kSecAttrTokenIDSecureEnclave). Veřejný klíč zaregist	EBA Opinion on the elements of strong customer authentication under PSD2 (EBA-Op-2019-06, 21. 6. 2019), odst.

4.2 Backend a platforma

Pro backend finanční instituce v EU je od 17. 1. 2025 plně účinné nařízení DORA (EU) 2022/2554 spolu se svými RTS — zejména delegovaným nařízením (EU) 2024/1774, které převádí obecné principy na konkrétní technické kontroly (šifrování, správa klíčů, logování, segmentace sítě, IAM, patch management, change management). DORA je vůči NIS2 lex specialis, takže pro licencované finanční entity má přednost. Nad rámec regulace existuje vrstva de facto standardů, které regulátor sice explicitně nevyžaduje, ale bez nichž se compliance prakticky neprokáže: ISO/IEC 27001:2022 jako důkaz řízeného ISMS, FIPS 140-3 / PCI PTS HSM pro hardware klíčů, NIST SP 800-207 pro zero trust, NIST SP 800-57 pro kryptoperiody a rotaci, a v oblasti peněžní logiky podvojný append-only ledger plus idempotentní platební API — to jsou inženýrské požadavky vycházející z povinnosti integrity dat a rekonstruovatelného audit trailu, nikoli z konkrétního článku zákona. Sankční rámec je reálný: až 2 % celosvětového ročního obrátu podle čl. 50 DORA a osobní odpovědnost členů vedení. Klíčové upozornění: většina níže uvedených povinností se vztahuje na licencovanou finanční entitu podle čl. 2 DORA — pokud je LargoVerse zatím jen investorské beta demo bez licence, jde o cílový stav architektury, ne o okamžitě vymahatelnou povinnost.

Klíčové právní povinnosti

Požadavek	Co znamená implementačně	Zdroj
Dokumentovaný rámec řízení ICT rizik s ročním přezkumem	Backend nesmí existovat bez písemného rámce: strategie, politiky, procedury, protokoly a nástroje pro ICT riziko. Implementačně to znamená verzovaný soubor politik v repozitáři (security policy, crypto policy, logging policy, BCP/DR plán, incident response playbooky), roční revize (a mimořádná po každém závažném incidentu), interní audit prováděný nezávislou osobou se znalostí ICT, a organizační oddělení tří linií obrany — výv	Nařízení (EU) 2022/2554 (DORA), čl. 6 odst. 1–5 a 8
Odpovědnost statutárního orgánu za ICT riziko	Vedení nese konečnou odpovědnost — nelze ji delegovat na CTO. Implementačně: schválené a datované rozhodnutí orgánu o ICT strategii a rizikovém apetitu, jmená odpovědnost za role, pravidelné školení členů vedení k ICT riziku, a reporting ICT rizik na úroveň představenstva s doložitelnou frekvencí.	Nařízení (EU) 2022/2554 (DORA), čl. 5

Požadavek	Co znamená implementačně	Zdroj
Šifrování dat v klidu, při přenosu a v použití + kryptografická politika	Povinná dokumentovaná kryptografická politika s klasifikací dat, seznamem schválených algoritmů a délek klíčů a s procesem jejich revize (včetně sledování post-kvantového vývoje). Implementačně: TLS 1.3 na všech externích i interních hranicích, šifrování databází a záloh, šifrování zůstatků a osobních údajů, žádné plaintextové PAN/IBAN v logách. RTS explicitně požaduje i posouzení ochrany dat 'in use' tam, kde je to relevantní	Delegované nařízení (EU) 2024/1774, čl. 6 (Encryption and cryptographic controls)
Správa kryptografických klíčů v HSM nebo cloud KMS s certifikací FIPS 140-3	Klíče musí mít definovaný celý životní cyklus — generování, distribuce, uložení, obnova, zálohování, archivace, revokace, zničení — a nesmí být uloženy vedle šifrovaných dat. Implementačně: root a KEK klíče v HSM nebo managed KMS (AWS KMS/CloudHSM, Azure Managed HSM, GCP Cloud KMS) s validací FIPS 140-3 Level 3, envelope encryption pro datové klíče, dual control a split knowledge pro operace s root klíči, key ceremony s protokol	Delegované nařízení (EU) 2024/1774, čl. 7 (Cryptographic key management)
Rotace klíčů a tajemství s definovanou kryptoperiodou	Každý typ klíče a tajemství musí mít písemně stanovenou kryptoperiodu a automatizovanou rotaci. Praktické hodnoty podle NIST SP 800-57 Part 1 Rev. 5: symetrické datové klíče ≤ 2 roky, KEK ≤ 2 roky originator-usage, TLS certifikáty krátkodobé (ideálně automatizované ACME), aplikační tajemství (DB hesla, API klíče, webhook secrecy) 30–90 dní. Implementačně: centrální secret manager (HashiCorp Vault, AWS Secrets Manager, Azure Ke	Delegované nařízení (EU) 2024/1774, čl. 7 odst. 2 a 4
Zero trust: silná autentizace, least privilege a per-request autorizace	Žádný request není důvěryhodný jen proto, že přišel z vnitřní sítě. Implementačně: mTLS mezi službami, krátkodobé tokeny s úzkým scope, autorizace na úrovni každého volání (ne jen na gateway), MFA povinně pro všechny administrativní a vzdálené přístupy, privileged access management s just-in-time eskalací a nahráváním relací, čtvrtletní recertifikace přístupových práv, oddělené účty pro běžnou a administrátorskou práci. RTS 20	Delegované nařízení (EU) 2024/1774, čl. 20 (Identity management) a čl. 21 (Access control)

4.3 Blockchainová vrstva

Statistika roku 2025 posunula prioritu jednoznačně od chyb ve smart kontraktech ke kompromitaci klíčů a podpisových procesů: podle Chainalysis bylo v roce 2025 odcizeno přes 3,4 mld. USD, z toho 2,2 mld. USD (76 %) připadá na „infrastructure attacks“ — kompromitace privátních klíčů, wallet infrastruktury, privilegovaných přístupů a front-endů. Tři největší incidenty poslední doby (Bybit 1,5 mld. USD / únor 2025, WazirX 230 mil. USD / 2024, Radiant Capital 53 mil. USD / 2024) mají stejný vzorec: multisig nebo cold wallet byl formálně v pořádku, ale podepisující lidé viděli podvrženou transakci a podepsali ji naslepo. Z toho plyne, že samotná volba MPC/TSS vs. multisig vs. HSM je až druhotná — rozhodující je nezávislé ověření obsahu transakce (clear signing, out-of-band verifikace, policy engine mimo podpisový UI) a segregace hot/warm/cold. Druhá vrstva rizik je specifická pro stablecoiny jako tokeny: XSGD i USDT jsou centrálně kontrolované ERC-20 kontrakty s freeze/blacklist funkcí a upgradovatelným proxy. Emitent může kdykoli zmrazit adresu (Tether v roce 2025 zablokoval 4 163 adres a 1,26 mld. USD) nebo změnit implementaci kontraktu — aplikace na to musí být architektonicky připravena (detekce blacklistu, reakce na pozastavení, riziko emitenta a depeg). USDT navíc není striktně ERC-20 kompatibilní (transfer nevrací bool, approve vyžaduje reset na nulu), což je konkrétní implementační past. Třetí vrstva je právní: pro EU subjekt je závazné MiCA (zejména čl. 75 — custody pool

Klíčové právní povinnosti

Požadavek	Co znamená implementačně	Zdroj
On-chain screening protistran a sankční kontrola (Chainalysis / Elliptic / TRM)	Integrace blockchain analytics do transakčního toku, nikoli jen do reportingu: (1) pre-transaction screening každé cílové adresy před odesláním a každé zdrojové adresy před připsáním (real-time API), s automatickým zablokováním při sankčním zásahu a s eskalací při vysokém risk skóre; (2) průběžný re-screening historicky použitých adres (adresa čistá dnes může být sankcionována zítra); (3) transaction monitoring s pravidly na t	Chainalysis, What Is the Travel Rule / compliance glossary

Požadavek	Co znamená implementačně	Zdroj
Travel rule podle TFR (EU) 2023/1113 a ověřování self-hosted adres	Od 30. 12. 2024 musí u převodů krypto-aktiv doprovázet transakci údaje o původci a příjemci — v EU bez jakéhokoli minimálního prahu (nejpřísnější implementace na světě). Implementačně: (1) napojení na travel rule protokol (TRP, Notabene, Sygna, Openpayd apod.) pro výměnu dat mezi CASPy; (2) rozlišení, zda protistrana je CASP nebo self-hosted adresa (identifikace VASPu z adresy — counterparty discovery); (3) u převodů z/na self	Nařízení (EU) 2023/1113 (recast TFR), použitelné od 30. 12. 2024
MiCA čl. 75: custody policy, segregace a odpovědnost za ztrátu	Pokud aplikace drží krypto-aktiva klientů (byť jen dočasně), jde o službu úschovy a správy podle MiCA. Povinné prvky: písemná custody policy s interními pravidly a postupy zajišťujícími bezpečné uložení a kontrolu aktiv; smlouva s klientem; registr pozic vedený pro každého klienta; postup pro vrácení aktiv nebo prostředků přístupu klientovi; operační oddělení klientských aktiv od vlastních aktiv poskytovatele na úrovni distrib	Nařízení (EU) 2023/1114 (MiCA), čl. 75
DORA: ICT risk management, testování a hlášení incidentů	DORA je účinná od 17. 1. 2025 a vztahuje se i na poskytovatele služeb krypto-aktiv. Implementačně: (1) formální rámec řízení ICT rizik s odpovědností vedení; (2) klasifikace a hlášení závažných ICT incidentů příslušnému orgánu v předepsaných lhůtách (initial / intermediate / final report) — což zahrnuje i on-chain incidenty typu odcizení klíčů; (3) rizikově orientovaný program testování digitální odolnosti: skenování zraniteln	Nařízení (EU) 2022/2554 (DORA), zejména čl. 24–27 (testování) a čl. 26 (TLPT); přehled požadavků
Právní přípustnost XSGD a USDT v EU (blokátor nad technickou vrstvou)	Nezávisle na kvalitě blockchainové bezpečnosti platí, že XSGD ani USDT nejsou v EU autorizované e-money tokeny podle MiCA — autorizace mají v EU zejména USDC a EURC. Podle MiCA smí být EMT v EU veřejně nabízen nebo přijat k obchodování jen tehdy, je-li jeho emitent autorizovanou úvěrovou nebo elektronickopeněžní institucí a je-li publikován whitepaper. Implementačně to znamená rozhodnutí na úrovni architektury: buď (a) změna p	Nařízení (EU) 2023/1114 (MiCA), Hlava IV (e-money tokeny), čl. 48–50 a Hlava V; přehled povinností CASP

4.4 Regulace a compliance

K srpnu 2026 je regulační rámec pro kombinovaný model "kryptopeněženka + stablecoin + platby" v EU tvořen čtyřmi vrstvami, které se navzájem překrývají a NELZE je splnit jednou licenci. (1) MiCA (nařízení 2023/1114) je plně účinné; přechodné období pro staré národní VASP registrace podle čl. 143(3) skončilo — v Litvě již 1. 1. 2026, celoevropský strop byl 1. 7. 2026. Kdo nemá autorizaci CASP, musí činnost ukončit podle wind-down plánu. (2) Kritický bod pro jakýkoli produkt se stablecoiny: podle stanoviska EBA (EBA/Op/2025/08, tzv. No Action Letter) představuje úschova EMT a převody EMT jménem klienta platební službu podle PSD2 — vedle licence CASP je tedy nutná i licence platební instituce nebo EMI, případně partnerství s licencovaným PSP. Přechodná tolerance skončila 2. 3. 2026; kapitálové požadavky MiCA a PSD2/EMD2 se počítají, nekompenzují. (3) MiCA čl. 50 absolutně zakazuje jakékoli úročení EMT, a to jak vydavateli, tak CASP — včetně cashbacku, slev a jakékoli odměny vázané na dobu držení; toto je nejčastější "product-killer" u peněženkových produktů. (4) AML vrstva: Travel Rule (nařízení 2023/1113) je účinná od 30. 12. 2024 bez prahové hodnoty; balíček AMLR 2024/1624 + AMLD6 2024/1640 nabývá účinnosti 10. 7. 2027 a přinese mj. zákaz anonymních účtů a anonymity-enhancing coins (čl. 79); AMLA zahájí přímý dohled nad vybranými subjekty (včetně CASP) v roce 2028, výběr proběhne v roce 2027. Nad tím vším leží DORA (nařízení 2022/2554), účinná od 17. 1. 2025, která se na CASP

Klíčové právní povinnosti

Požadavek	Co znamená implementačně	Zdroj
Autorizace CASP podle MiCA a passportování	Bez autorizace jako CASP nelze v EU poskytovat žádnou z regulovaných služeb (úschova a správa kryptoaktiv, směna kryptoaktiv za peněžní prostředky nebo jiná kryptoaktiva, provoz obchodní platformy, přijímání a předávání pokynů, provádění pokynů, poradenství, správa portfolia, převodní služby). Implementačně: právnická osoba se sídlem v EU (v LT typicky UAB), skutečné vedení v EU, žádost podle čl. 62 obsahující program činnosti	Nařízení (EU) 2023/1114 (MiCA), čl. 59, 60, 61, 62, 65

Požadavek	Co znamená implementačně	Zdroj
Kapitálové požadavky CASP (obezřetnostní záruky)	CASP musí trvale držet obezřetnostní záruky ve výši vyšší z: (a) fixní minimální částky podle Přílohy IV — třída 1: 50 000 EUR (poradenství, správa portfolia, přijímání a předávání pokynů, převodní služby), třída 2: 125 000 EUR (úschova a správa, směna, provádění pokynů, umisťování), třída 3: 150 000 EUR (provoz obchodní platformy); nebo (b) jedné čtvrtiny fixních režijních nákladů předchozího roku, přepočítávané ročně. Při ví	Nařízení (EU) 2023/1114 (MiCA), čl. 67 a Příloha IV
Ochrana klientských kryptoaktiv a peněžních prostředků (obecná povinnost)	CASP držící kryptoaktiva klientů musí učinit odpovídající opatření k ochraně vlastnických práv klientů, zejména pro případ vlastní insolvence. Peněžní prostředky klientů (jiné než EMT) musí být uloženy u úvěrové instituce nebo centrální banky nejpozději do konce pracovního dne následujícího po dni přijetí, na účtu oddělitelně identifikovatelném od účtů vlastních prostředků CASP. CASP nesmí používat klientské prostředky na vlas	Nařízení (EU) 2023/1114 (MiCA), čl. 70
Úschova a správa kryptoaktiv jménem klientů — provozní režim podle čl. 75	Konkrétní implementační povinnosti: (1) uzavřít s klientem smlouvu vymezující povinnosti stran, (2) zavést a udržovat custody policy s vnitřními pravidly a postupy pro bezpečné uložení či kontrolu kryptoaktiv a prostředků přístupu (klíčů); na žádost klienta ji poskytnout, (3) vést registr pozic otevřených na jméno každého klienta, odpovídajících jeho právům ke kryptoaktivům, a bezodkladně do něj zapisovat pohyby na pokyn kien	Nařízení (EU) 2023/1114 (MiCA), čl. 75
Zákaz úročení e-money tokenů (MiCA čl. 50)	Vydavatelé EMT nesmějí poskytovat úrok ve vztahu k EMT. Stejný zákaz se vztahuje na CASP při poskytování služeb souvisejících s EMT. Za úrok se považuje jakákoli odměna nebo jiná výhoda vázaná na dobu, po kterou držitel EMT drží — včetně čisté kompenzace či slev s účinkem rovnocenným úroku, ať už přijaté přímo od vydavatele nebo od třetích stran, a ať už spojené přímo s EMT nebo plynoucí z odměňování či cenotvorby jiných produ	Nařízení (EU) 2023/1114 (MiCA), čl. 50
Marketingová sdělení k e-money tokenům (MiCA čl. 53)	Marketingová sdělení k nabídce EMT nebo jeho přijetí k obchodování musí: (a) být jasně identifikovatelná jako marketingové sdělení, (b) obsahovat informace, které jsou nestranné, jasné a nezavádějící, (c) být v souladu s obsahem white paperu, (d) jasně uvádět, že white paper byl zveřejněn, včetně adresy webových stránek, telefonního čísla a e-mailu vydavatele, (e) obsahovat jasné a jednoznačné prohlášení, že držitelé EMT mají	Nařízení (EU) 2023/1114 (MiCA), čl. 53 (a čl. 66(4) pro CASP)

4.5 Ochrana osobních údajů

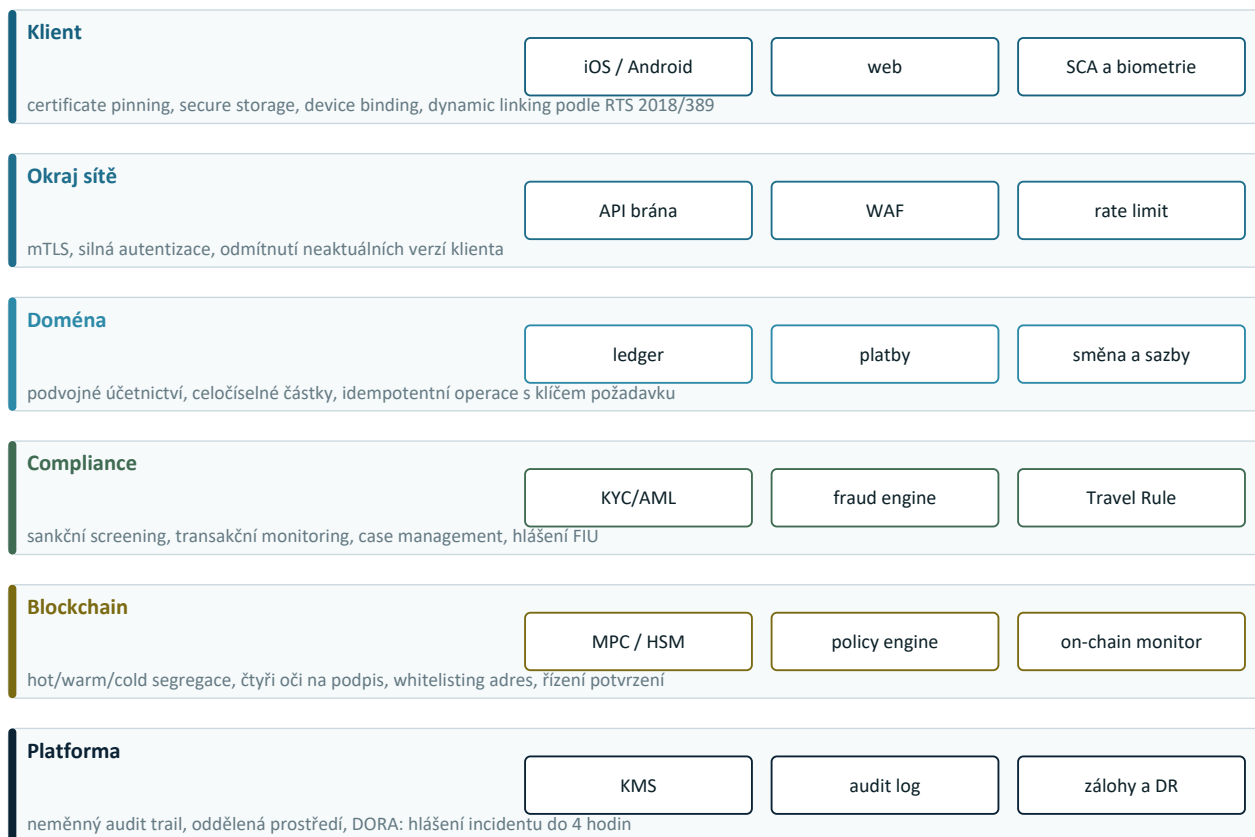
KYC data jsou v EU regulována souběžně čtyřmi vrstvami, které si částečně odporují: GDPR (minimalizace, výmaz, omezení uchování), AML/CFT (povinnost uchovat kompletní neredigované doklady 5–10 let), DORA (šifrování, řízení dodavatelů, hlášení incidentů do 4 hodin) a od 2. 8. 2026 též AI Act u biometrické identifikace. Právním titulem pro KYC je splnění právní povinnosti (čl. 6 odst. 1 písm. c GDPR), nikdy souhlas — souhlas je použitelný jen pro biometrii jako zvláštní kategorii a pro nadstavbové účely. Klíčové konflikty se řeší nikoli výjimkou z GDPR, ale architekturou: oddělený „AML trezor“ s vlastní retencí a přísným řízením přístupu, mimo něj běžná retence a výmaz. Pro blockchainovou část platí zásadní stanovisko EDPB — Guidelines 02/2025, verze 2.0 přijatá 7. 7. 2026 — které říká, že hash ani šifrovaný údaj nepřestává být osobním údajem, technická nemožnost výmazu není omluvou, a jediné bezpečné řešení je nezapisovat osobní údaje on-chain vůbec. Předávání mimo EU je nadále legální přes EU-US Data Privacy Framework (potvrzen Tribunálem 3. 9. 2025, kasační opravný prostředek C-703/25 P u SDEU zatím nerozhodnut) nebo SCC + posouzení dopadu předání, ale s ohledem na riziko zrušení je u KYC dat vhodné držet primární úložiště v EU. DPIA je u této kombinace (rozsáhlé finanční údaje + doklady totožnosti + biometrie + blockchain) prakticky povinná, ne volitelná.

Klíčové právní povinnosti

Požadavek	Co znamená implementačně	Zdroj
Právní titul KYC: právní povinnost, nikoli souhlas	Zpracování identifikačních údajů, dokladů totožnosti a údajů o původu prostředků při KYC/CDD se opírá o čl. 6 odst. 1 písm. c) GDPR (splnění právní povinnosti podle AML předpisů), doplňkově o čl. 6 odst. 1 písm. b) (plnění smlouvy) u údajů nutných k vedení účtu. Implementačně to znamená: žádné checkboxy typu 'souhlasím se zpracováním osobních údajů' u onboardingu — jsou zavádějící a v rozporu s realitou, protože klient KYC odm	Nařízení (EU) 2016/679 (GDPR), čl. 6 odst. 1 písm. b) a c), čl. 7
Minimalizace a účelové omezení KYC dat	Sbírat jen údaje, které AML předpis skutečně vyžaduje pro daný rizikový profil (jméno, datum narození, adresa, číslo a typ dokladu, státní příslušnost, účel obchodního vztahu, zdroj prostředků u vyššího rizika). Praktické dopady: neukládat celé skeny dokladu, pokud stačí ověřené atributy + doklad o provedení ověření; potlačit strojově čitelnou zónu a nepotřebná pole (např. rodné číslo tam, kde není vyžadováno); nepoužívat KYC	GDPR čl. 5 odst. 1 písm. b) a c)
Doby uchování: AML retence vs. omezení uložení	AML vyžaduje uchovat kopie dokladů a záznamy o transakcích 5 let od skončení obchodního vztahu nebo od provedení příležitostné transakce; členské státy mohou prodloužit až na 10 let. AMLR čl. 77 (přímo použitelný od 10. 7. 2027) navíc zakazuje záznamy redigovat — musí zůstat úplné a nezměněné. V ČR platí do té doby zákon č. 253/2008 Sb. s desetiletou lhůtou. Implementačně: (1) každá kategorie údajů má definovanou retenční lhůtu	AMLR (EU) 2024/1624 čl. 77
Omezení práv subjektu údajů kvůli zákazu tipování (tipping-off)	Pokud klient podal žádost o přístup nebo výmaz a zároveň je předmětem oznámení podezřelého obchodu, nesmí být z odpovědi patrné, že takové oznámení existuje. Prakticky: odpovědní workflow na DSAR musí mít krok kontroly proti AML case managementu, exporty pro klienta nesmí obsahovat interní risk skóre, SAR/STR příznaky, poznámky compliance ani audit stopy AML šetření. Omezení musí být opřeno o konkrétní ustanovení unijního nebo	GDPR čl. 23 a čl. 15
Šifrování při přenosu (TLS 1.3, mTLS pro integrace)	Veškerá komunikace klient–aplikace, aplikace–API, aplikace–databáze i mezi mikroslužbami musí být šifrována. Konkrétně: TLS 1.3 (minimálně 1.2 s omezenou sadou šifer), HSTS s preload, zákaz downgrade, certificate pinning u mobilní aplikace, mTLS nebo podepsané payloady u integrací s KYC providerem, bankou a travel-rule sítí. DORA to nepodmiňuje rizikem — vyžaduje mít písemnou politiku šifrování a kryptografických kontrol, včet	Nařízení Komise (EU) 2024/1774, RTS k rámci řízení ICT rizik, čl. 6–7 (šifrování a kryptografické kontroly)
Šifrování v klidu a správa klíčů	Databáze, objektové úložiště se skeny dokladů, zálohy, logy i dočasné soubory musí být šifrovány. Doporučený standard je AES-256 (nebo ekvivalent), přičemž samotné šifrování disku (FDE) nestačí jako opatření proti aplikačnímu úniku — u nejcitlivějších polí (číslo dokladu, biometrická šablona, adresa) je namístě šifrování na úrovni sloupce/pole s klíči mimo aplikační databázi. Klíče spravovat v KMS/HSM, s rotací, oddělením rolí	RTS (EU) 2024/1774 čl. 6–9 (šifrování dat v klidu, správa kryptografických klíčů)

4.6 Cílová architektura

Cílový tvar má tři vlastnosti, které dnešní řešení nemá: zdroj pravdy je na serveru, peníze vede podvojný ledger v celočíselné aritmetice, a podpisové klíče nikdy neopustí hardwarovou nebo prahovou ochranu. Klientská aplikace se z „místa, kde peníze žijí“ mění na „tenký ověřený pohled“.



Cílová architektura. Každá vrstva má vlastní důvod existence v regulaci — není to technická preference.

Úplný seznam všech 130 požadavků včetně zdrojů je v příloze B.

5. Mezerová analýza

Porovnáním současného a cílového stavu vzniklo 59 mezer. Priorita P0 znamená, že bez uzavření té mezery **nelze spustit ostrý provoz s cizími prostředky** — jde o 44 položek. P1 jsou věci nutné krátce po spuštění, P2 a P3 zbytek.

Priorita	Počet mezer	Člověkodny	Význam
P0	44	2 604	Blokátor ostrého provozu — bez toho se spustit nesmí.
P1	11	475	Nutné bezprostředně po spuštění nebo pro první dohledovou kontrolu.
P2	3	73	Důležité, ale snese odklad o jedno vydání.
P3	1	—	Podmíněné — vzniká až tehdy, když bude subjekt označen za významný.

Jediná mezeru v P3 je Threat-Led Penetration Testing podle DORA. Nemá odhad, protože povinnost vzniká až tehdy, pokud dohled subjekt označí za významný — do té doby je to nulová práce, potom několikaměsíční projekt.

Rozložení náročnosti podle oblastí

Backend a platforma		928 MD
Regulace a licence		600 MD
Procesy a lidé		566 MD
Klientská aplikace		483 MD
Blockchain		390 MD
Data a soukromí		185 MD

Součet odhadu zdola nahoru je **3 152 člověkodní**. Kapitola 7 vysvětluje, proč je toto číslo považováno za podstřelené a jaká je oponovaná hodnota.

5.1 Blokátory ostrého provozu (P0)

Seřazeno podle náročnosti sestupně. Sloupec „MD“ je odhad zdola nahoru před oponenturou.

Mezera	Oblast	Cílový stav (zkráceně)	MD
Chybí licence CASP podle MiCA a souběžná platební licence (EMI/PI)	Regulace a licence	Plná autorizace CASP podle MiCA čl. 59–63 (úschova a správa + směna = třída 2, obezřetnostní záruky min. 125 000 EUR nebo 1/4 fixních režijních nákladů), souběžně licence platební instituce nebo EMI, protože podle EBA/Op/2025/08 je úschova a převod EMT platební službou podle PSD2 — kapitál se kumulu	220
Klientská platforma: dnešní webová SPA nemůže být produkčním klientem	Klientská aplikace	Rozhodnutí a realizace produkčního klienta: nativní iOS a Android aplikace (nebo React Native s nativními bezpečnostními moduly), protože Keystore/Secure Enclave, device binding, Play Integrity/App Attest, FLAG_SECURE a ochrana proti overlay na webu splnit nelze. Webová část zůstane nanejvýš jako in	190
Neexistuje backend — klient je jediným zdrojem pravdy o penězích	Backend a platforma	Serverová aplikace jako jediná autorita nad penězi: doménové služby pro platby, převody, směnu a Safe Money, transakční databáze, autorizace na úrovni každého volání, validace vstupů zopakovaná na serveru, definované API kontrakty, stavy operací a chybové kódy. Klient se stane tenkým rozhraním bez j	160
Neexistuje AML/CFT program, compliance funkce ani MLRO	Regulace a licence	Kompletní AML/CFT program: dokumentované interní politiky a postupy, rizikové hodnocení klienta i produktu, CDD při navázání vztahu a u příležitostných transakcí od 1 000 EUR, EDD u PEP a rizikových jurisdikcí, identifikace skutečných majitelů, průběžné monitorování, uchování 5 let bez možnosti reda	130
Neexistuje podvojný účetnictví — zůstatek a historie jsou dvě nezávislé pravdy	Backend a platforma	Append-only podvojný ledger jako jediný zdroj pravdy: tabulka postings, každá operace generuje minimálně dvě strany se součtem přesně nula (v každé měně zvlášť), vynuceno databázovým constraintem; žádné UPDATE ani DELETE na zaúčtovaných řádcích, jen storno zápisy; zůstatek jako materializovaný agreg	85
Chybí detekce anomálií, SIEM a fraud engine	Backend a platforma	Centrální SIEM sbírající logy z aplikace, databáze, KMS, cloud audit logu, WAF a identity provideru; detekční pravidla na neúspěšné přihlášení, eskalaci oprávnění, přístup ke klíčům, neobvyklý objem nebo směr plateb, nesouhlas součtu ledgeru, hromadné stahování KYC složek; 24/7 on-call s definovanou	80
Chybí custody architektura klíčů (hot / warm / cold)	Blockchain	Tři oddělené domény klíčů s odlišnými bezpečnostními modely: hot (automatické podepisování, provozní minimum pod 1–2 % aktiv, tvrdý denní i per-transakční limit), warm (MPC/HSM s policy enginem a lidským schválením), cold (air-gapped, většina rezerv, podpisové zařízení bez konektivity). Samostatné k	80
KYC je klikací atrapa schvalovaná časovačem	Procesy a lidé	Integrace ověřovacího poskytovatele (OCR dokladu, kontrola pravosti, liveness, porovnání obličeje), serverové rozhodnutí o schválení, fronta ruční revize pro hraniční případy, evidence důkazů o provedeném ověření v auditovatelné formě, rizikové skórování, znovuoověření při změně údajů. Povinná rovnoc	75
Chybí silné ověření klienta (SCA) podle RTS 2018/389	Backend a platforma	SCA u přihlášení k účtu i u iniciace platby: dva prvky ze tří nezávislých kategorií, kde klient nikdy nerozhoduje o úspěchu — shromáždí důkazy a nechá autentizační kód vygenerovat kryptograficky podpisem klíčem v Keystore/Secure Enclave; server ověří kód a vydá relaci. Výjimky z SCA (nízké částky, d	75
Nulové pokrytí testy — peněžní logika není ověřená ničím	Procesy a lidé	Testovací pyramida se zaměřením na peníze: jednotkové testy doménové vrstvy, property a invariantní testy ledgeru (součet postingů = 0 v každé měně, zůstatek = přepočet z nuly, žádná cesta neobchází tarif), fuzz testy na aritmetiku a zaokrouhlení, integrační testy API včetně idempotence a souběhu, k	70

Mezera	Oblast	Cílový stav (zkráceně)	MD
Chybí on-chain provozní vrstva: nonce, gas, potvrzení, reorg, redundance RPC	Blockchain	Centralizovaný nonce serializer s perzistentní tabulkou nonce ↔ tx hash ↔ stav (nikdy nespolehat jen na eth_getTransactionCount), watchdog na mezery s replace-by-fee, pool více odesílacích adres pro paralelní propustnost, reconciliace při přepnutí RPC. Gas management podle EIP-1559 s rezervou nad ba	70
Chybí rámec řízení ICT rizik podle DORA a odpovědnost vedení	Procesy a lidé	Verzovaný soubor politik (security, crypto, logging, BCP/DR, incident response playbooky), roční revize a mimořádná po každém závažném incidentu, interní audit nezávislou osobou se znalostí ICT, organizační oddělení tří linií obrany, schválené a datované rozhodnutí statutárního orgánu o ICT strategii	65
Chybí kontrola integrity platformy: root/jailbreak, atestace, anti-tampering	Klientská aplikace	Vrstvené, nezávislé signály vyhodnocované na serveru: Android — cesty su/busybox/Magisk, ro.debuggable, zápis do /system, Zygisk artefakty, SELinux, plus serverem ověřený verdikt Play Integrity (MEETS_DEVICE_INTEGRITY / MEETS_STRONG_INTEGRITY, appRecognitionVerdict PLAY_RECOGNIZED); iOS — Cydia, /pr	60
GDPR: právní tituly, informační povinnost, záznamy o zpracování, DPIA a DPO	Data a soukromí	Právní titul evidovaný u každé kategorie údajů (KYC z čl. 6 odst. 1 písm. c, vedení účtu z písm. b, marketing a volitelná analytika ze souhlasu, biometrie z výslovného souhlasu podle čl. 9) — bez zavádějících checkboxů „souhlasím se zpracováním“ u onboarding, protože KYC klient odmítnout nemůže. Úp	60
Ochrana klientských prostředků a aktiv (safeguarding a segregace)	Regulace a licence	Safeguarding podle EMD2 čl. 7 ve spojení s PSD2 čl. 10 — oddělený účet u úvěrové instituce s doloženým trust/segregation ujednáním, ochrana před nároky věřitelů v insolenci, ochrana prostředků nejpozději do 5 pracovních dnů, denní reconciliace safeguarding účtu proti závazkům. U kryptoaktiv MICA čl	55
Travel rule (TFR 2023/1113) a ověřování self-hosted adres	Regulace a licence	U každého převodu kryptoaktiv bez jakéhokoli minimálního prahu shromažďovat, ověřovat, předávat a uchovávat údaje o plátcích a příjemcích (IVMS101), napojení na travel-rule protokol (TRP, Notabene, Sygna), rozlišení CASP vs. self-hosted protistrany, u převodů z/na self-hosted adresu nad 1 000 EUR doložit	55
Chybí zero trust, řízení identit a segmentace sítě	Backend a platforma	mTLS mezi službami, krátkodobé tokeny s úzkým scope, autorizace na úrovni každého volání (ne jen na gateway), MFA povinně pro všechny administrativní a vzdálené přístupy, PAM s just-in-time eskalací a nahráváním relací, čtvrtletní recertifikace práv, oddělené účty pro běžnou a administrátorskou práci	55
Chybí provozní dokumentace CASP: custody policy, wind-down, stížnosti, střety zájmů, outsourcing	Regulace a licence	Sada verzovaných a schválených dokumentů: custody policy (čl. 75), registr pozic klientů, plán řádného ukončení činnosti (čl. 74), postup bezplatného vyřizování stížností se lhůtami a evidencí (čl. 71), politika střetů zájmů včetně odměňování a skupinových vztahů (čl. 72), outsourcingová politika s	50
Přihlášení neověřuje nic a session nikdy nevyprší	Backend a platforma	Serverová identita: registrace s ověřením e-mailu/telefonu, hesla s Argon2id a politikou podle ASVS, session token z CSPRNG min. 128 bitů v cookie s HttpOnly/Secure/SameSite a prefixem __Host- (web) resp. krátkodobý access token vázaný na device-binding klíč (mobil), regenerace ID po každé změně úro	50
Chybí device binding a hardwarově vázané klíče	Klientská aplikace	Při onboarding vygenerovat asymetrický pár uvnitř hardwarového úložiště, neexportovatelný (Android KeyGenParameterSpec se setIsStrongBoxBacked(true) s fallbackem na TEE a ošetřením StrongBoxUnavailableException; iOS kSecAttrTokenIDSecureEnclave, ECC P-256, SecAccessControl). Veřejný klíč zaregistrovat	50
Chybí program testování digitální provozní odolnosti a penetrační testy	Procesy a lidé	Rizikově orientovaný program podle DORA čl. 24–25: SAST/DAST a SCA v pipeline, pravidelný vulnerability scanning s SLA na patchování podle závažnosti, penetrační testy před každým velkým vydáním a minimálně ročně (backend, mobilní klient podle MASVS profilu MAS-L2 + MAS-R, web podle ASVS L2), scénář	50

Mezera	Oblast	Cílový stav (zkráceně)	MD
Chybí on-chain monitoring, circuit breaker a reconciliace proti ledgeru	Blockchain	Real-time sledování všech vlastních adres a kontraktů s automatizovanou reakcí: detekce neočekávaného odchozího transferu, nového Approval eventu, změny vlastnictví nebo implementace kontraktu, transakcí mimo pracovní dobu, objemu nad rolling limit. Napojení komerčního detekčního nástroje (Hypernati	50
Operace nejsou idempotentní a nemají identifikátor požadavku	Backend a platforma	Povinná hlavička Idempotency-Key (UUIDv4) na každé mutující platební operaci, uložení dvojice klíč → hash požadavku → odpověď s unique constraintem, návrat původní odpovědi při opakování a 409 při stejném klíči s odlišným tělem, retence klíčů 24 h – 7 dní. Transactional outbox pro asynchronní kroky	45
Chybí dynamic linking — kryptografická vazba autentizace na částku a příjemce	Klientská aplikace	Autentizační kód kryptograficky specifický pro částku a příjemce; jakákoli změna kteréhokoli z nich kód zneplatní. Potvrzovací obrazovka zobrazuje částku a příjemce z dat přijatých ze serveru pro tuto transakci, ne z lokálního stavu formuláře. Do podpisu vstupuje transaction ID + částka + měna + ide	45
Chybí správa kryptografických klíčů a tajemství (HSM/KMS, rotate)	Backend a platforma	Dokumentovaná kryptografická politika s klasifikací dat, schválenými algoritmy a plánem kryptoagility. Root a KEK klíče v HSM nebo managed KMS s validací FIPS 140-3 Level 3 (pozor: FIPS 140-2 certifikáty se přesouvají na historický seznam), envelope encryption, dual control a split knowledge pro roo	45
Šifrování dat v klidu, pseudonymizace a oddělení KYC úložiště	Data a soukromí	Šifrování databází, objektového úložiště se skeny dokladů, záloh, logů i dočasných souborů (AES-256); u nejcitlivějších polí (číslo dokladu, biometrická šablona, adresa) šifrování na úrovni sloupce s klíči mimo aplikační databázi — samotné FDE nestačí proti aplikačnímu úniku. Kryptografické mazání j	45
Chybí signing policy, whitelist adres s časovým zámekem a Key Compromise Protocol	Blockchain	Formalizovaná signing policy s prahovými pásmy (pod X automaticky policy engine, X–Y dva nezávislé schvalovatelé s tvrdě vynuceným pravidlem iniciátor ≠ schvalovatel, nad Y tři a více plus schválení mimo IT). Prahy multisigu úměrné hodnotě — 3-z-11 je pro velké objemy neobhajitelné. Každý signer na	45
Chybí lidé — tým nemá obsazené role, které regulace vyžaduje odděleně	Procesy a lidé	Obsazené role, které regulace vyžaduje jako navzájem nezávislé: compliance manager na úrovni vedení a MLRO (litevský daňový rezident), nezávislý DPO (nesmí to být CTO ani vedoucí compliance), CISO/bezpečnostní odpovědnost oddělená od vývoje, interní audit jako třetí linie (lze outsourcovat), nejméně	45
Sazebník se uplatňuje jen v jedné ze čtyř peněžních cest — cenová nekonzistence	Backend a platforma	Jediná cenová služba na serveru volaná všemi peněžními cestami bez výjimky; kurzy z externího feedu s časovým razítkem a zdrojem; objekt kotace (quote) s expirací, který klient dostane, zobrazí a odklepne, a proti kterému se transakce provede — nikoli přepočít z konstanty v okamžiku provedení; sazeb	40
Chybí neměnitelný audit trail a logování	Backend a platforma	Append-only audit trail zachycující kdo, kdy, co, odkud a s jakým výsledkem, u peněžních operací včetně předchozího a nového stavu. WORM/object-lock retence, oddělený účet nebo tenant pro logy (kompromitace aplikace nesmí umožnit jejich smazání), hash chain nebo podepisování dávek, synchronizovaný č	40
Chybí zálohy, plán obnovy a definované RTO/RPO	Backend a platforma	Politika záloh podle kritičnosti a důvěrnosti dat, RTO a RPO pro každou kritickou funkci odvozené z business impact analýzy (u ledgeru prakticky nulová ztráta potvrzených transakcí, Pitr), zálohy v jiné failure doméně a jiném účtu s object-lock proti ransomware, šifrované vlastními klíči, a — nejčas	40
Neexistuje CI/CD ani žádná automatická brána mezi změnou kódu a nasazením	Procesy a lidé	CI pipeline s blokujícími branami: typecheck včetně build skriptů, lint, testy, SAST, SCA sken závislostí s policy na kritické CVE, sken tajemství, generování a uchování SBOM (CycloneDX/SPDX) pro každé vydání. Reprodukovatelný build: npm ci, připnutá verze Node, podepsané artefakty a ověření podpisu	40

Mezera	Oblast	Cílový stav (zkráceně)	MD
Chybí registr ICT dodavatelů, smluvní doložky a exit strategie	Procesy a lidé	Registr informací ve formátu prováděcího nařízení (EU) 2024/2956 se všemi smluvními ujednáními, kritičností, lokalitami zpracování a uložení dat a subdodavatelskými řetězci. Předmluvní due diligence a posouzení koncentračního rizika u každého nového dodavatele (cloud, KYC provider, RPC provider, an	40
Chybí on-chain screening protistran a sankční kontrola	Blockchain	Blockchain analytics (Chainalysis / TRM / Elliptic) v transakčním toku, ne jen v reportingu: pre-transaction screening každé cílové adresy před odesláním a každé zdrojové adresy před připsáním v reálném čase, automatické zablokování při sankčním zásahu a eskalace při vysokém risk skóre; průběžný re-	40
Chybí oddělení prostředí dev/test/prod a řízený change management	Procesy a lidé	Samostatné cloud účty pro dev, test a produkci, žádné sdílené credentials napříč prostředím, žádná produkční data v testu (jen syntetická nebo ireverzibilně anonymizovaná), oddělení rolí mezi tím, kdo kód píše, a kdo nasazuje (PCI DSS 6.4.2), schvalovací brána pro produkční release. Change manage	35
Chybí incident management, klasifikace a hlášení ve dvou paralelních režimech	Procesy a lidé	Jediný incident response proces s krokem souběžné klasifikace: je to porušení osobních údajů? je to závažný ICT incident? DORA: prvotní hlášení do 4 hodin od klasifikace, nejpozději do 24 hodin od zjištění, průběžná zpráva do 72 hodin, závěrečná s root cause do 1 měsíce; klasifikační kritéria podle	35
Integrace tokenu: SafeERC20, freeze/blacklist emitenta, monitoring depegu	Blockchain	Veškeré token interakce přes OpenZeppelin SafeERC20 (safeTransfer, safeTransferFrom, forceApprove) — USDT na Ethereum nevrací bool a přímé volání IERC20.transfer() revertne; USDT navíc má poplatkový mechanismus, takže přijatá částka nemusí odpovídat odeslané a je nutné měřit skutečnou změnu zůstatku.	35
Peníze jsou JavaScriptové floaty s ad-hoc zaokrouhlením	Backend a platforma	Peněžní částky jako celočíselné minor units (nebo decimal s pevnou přesností), měna jako součást typu, žádné implicitní konverze mezi měnami, jediná dokumentovaná zaokrouhlovací politika (half-even nebo pravidlo ve prospěch klienta) aplikovaná na jednom místě, zaokrouhlení jako explicitní krok s vla	30
Limity a zámek karty se nikde nevynucují; limit lze bez omezení eskalovat	Backend a platforma	Limity (denní, měsíční, per-transakční, per-kanál), zámek karty a KYC status jako tvrdé, serverem vynucené podmínky každé peněžní operace. Absolutní strop limitu stanovený produktovou a rizikovou politikou; zvýšení nad definovanou hranici vyžaduje SCA a případně manuální schválení. Zablokování plate	28
XSGD a USDT nejsou v EU autorizované EMT — produktový blokátor nad celou technickou vrstvou	Regulace a licence	Explicitní architektonické rozhodnutí a jeho promítnutí do domény, UI, textů a on-chain vrstvy: buď (a) přechod na autorizovaný EMT (USDC/EURC), nebo (b) omezení produktu na jurisdikce mimo EU, nebo (c) trvalé označení jako simulace bez skutečné držby a bez nabízení klientům v EU. Souběžně trvalý zá	25
Bezpečnost dodavatelského řetězce podepisovacího prostředí	Blockchain	Oddělené, hardened stroje pro podepisování — bez e-mailu, bez prohlížení webu, bez otevírání příloh (Radiant: infikovaný ZIP z Telegramu vydávaný za report od kontraktora). Pinning a integritní kontrola všech závislostí, zákaz načítání JS z CDN třetích stran ve všech rozhraních dotýkajících se trans	25
Tajemství karet (PIN, CVV, číslo) se ukládají na klientovi v otevřené podobě	Klientská aplikace	Klient nikdy nedrží PIN, CVV ani plné číslo karty. Citlivé údaje se zobrazují jen po SCA, přes krátkodobý serverový token, na obrazovce s FLAG_SECURE, a po vypršení se skutečně skryjí. Změna PINu vyžaduje ověření současného PINu nebo SCA a probíhá u vydavatele karty. Tokeny a klíče relace do Keychain	22
Certificate pinning a TLS konfigurace klienta	Klientská aplikace	Pinning SPKI hashe (SHA-256 veřejného klíče) na všechny endpointy pod vlastní kontrolou, vždy se záložním pinem a rozumnou expirací, s možností vzdálené obnovy podepsanou konfigurací nebo vynuceným updatem. TLS 1.3 (min. 1.2), pouze AEAD s forward secrecy, cleartextTrafficPermitted=false a nedůvěřov	18

Mezera	Oblast	Cílový stav (zkráceně)	MD
Okamžitá náprava dnešního nakládání s tajemstvími dema	Procesy a lidé	Přesun repozitáře i tajemství mimo synchronizovanou složku; oddělení šifrovacího hesla od vývojového přístupového kódu; odstranění VITE_ACCESS_CODES z prostředí šifrovaného buildu a mazání dist/ po build:secure; tvrdé selhání buildu při chybějícím VITE_ACCESS_CODES místo fallbacku na „DEMO“; zvýšení	6

5.2 Ostatní mezery (P1–P3)

Pri.	Mezera	Oblast	Cílový stav (zkráceně)	MD
P1	Chybí karetní vrstva a vydavatelský partner	Backend a platforma	Rozhodnutí a smlouva s vydavatelským partnerem (BaaS/issuer processor), integrace autorizačního toku (blokace → zúčtování → storno), 3-D Secure 2.x s SCA, správa životního cyklu karty (vydání, aktivace, blokace, obnova, náhrada), reklamační a chargeback proces	95
P1	Chybí ISMS a certifikace ISO/IEC 27001:2022	Procesy a lidé	Definovaný rozsah ISMS, analýza rizik s metodikou, Prohlášení o aplikovatelnosti pokrývající 93 kontrol Annexu A, interní audit, přezkoumání vedením, certifikační audit Stage 1 + Stage 2 proti verzi 2022 (verze 2013 pozbyla platnosti 31. 10. 2025, certifikát n	95
P1	PCI DSS v4.0.1 — vymezení rozsahu a soulad (podmíněno karetní vrstvou)	Regulace a licence	Formální vymezení CDE a jeho minimalizace tokenizací a hosted fields; pokud rozsah vznikne: maskování PAN, šifrování v klidu, MFA pro veškerý přístup do CDE, automatizovaná revize logů přes SIEM, oddělení dev/test/prod (6.4.1) a rolí (6.4.2), inventář a autori	65
P1	Chybí celý životní cyklus bankovní transakce	Backend a platforma	Modelovaný stavový automat transakce (iniciováno → autorizováno → zúčtováno → zamítnuto/stornováno/reklamováno), oddělení dostupného a blokováného zůstatku, protistrana u každého pohybu, storno a reklamační proces s lhůtami podle PSD2, trvalé příkazy a inkasa,	60
P1	GDPR: retence, práva subjektů, výmaz a omezení kvůli zákazu tipování	Data a soukromí	Každá kategorie údajů má retenční lhůtu a spouštěč jejího běhu (konec vztahu, datum transakce), po uplynutí automatizovaný job data skutečně maže nebo anonymizuje — ne jen nastaví deleted=true. Odděleně KYC složka a transakční záznamy. Mechanismus legal hold p	40
P1	Chybí ochrana uživatelského rozhraní: screenshoty, overlay, klávesnice, clipboard, notifikace	Klientská aplikace	Android: FLAG_SECURE na obrazovky s citlivým obsahem, detekce nahrávání (Activity.registerScreenCaptureCallback od API 35), setFilterTouchesWhenObscured(true) na potvrzovací tlačítka, kontrola FLAG_WINDOW_IS_OBSCURED, Window.setHideOverlayWindows(true), detekc	30
P1	Lokalita dat, předávání mimo EU a hodnocení dodavatelů z pohledu ochrany údajů	Data a soukromí	U každé služby a subdodavatele evidovaný region zpracování a uložení; regionální uzamčení cloudových zdrojů na EU včetně záloh, replik, CDN, logovacích a monitorovacích služeb a nástrojů podpory; vzdálený přístup podpory z třetích zemí ošetřen jako předání. Pr	25
P1	Komunikace s klientem o bezpečnosti a blokace platebního prostředku	Klientská aplikace	Bezpečný kanál pro upozornění na rizikové události (přihlášení z nového zařízení, změna limitu, neúspěšné pokusy, změna kontaktních údajů, přidání nové výběrové adresy), možnost okamžitě zablokovat platební prostředek přímo v aplikaci s okamžitým účinkem na se	22
P1	Bezpečnostní hlavičky a webová vrstva (podmíněno zachováním webového klienta)	Klientská aplikace	Content-Security-Policy s nonce nebo hashi, bez unsafe-inline a unsafe-eval, s frame-ancestors 'none', explicitním connect-src a form-action; HSTS s preload a includeSubDomains; X-Content-Type-Options: nosniff; Referrer-Policy; Permissions-Policy; COOP a COEP;	18
P1	Osobní údaje a nezměnitelnost blockchainu	Data a soukromí	Návrhové pravidlo podle EDPB Guidelines 02/2025 (v2.0 ze 7. 7. 2026): osobní údaje nikdy on-chain — ani jména, ani identifikátory klientů, ani travel-rule údaje v transakčních metadatech, memo polích či smart kontraktech. On-chain zůstává jen pseudonymní adres	15
P1	Doručení dema investorům — krátkodobá náprava do doby produkčního nasazení	Procesy a lidé	Jedna zvolená a skutečně nasazená cesta doručení (Cloudflare Pages + Access s pokrytím preview adres, per-osoba odvolatelný přístup, záznam kdo a kdy otevřel), GitHub Pages trvale vypnuté, odstranění klientských identifikátorů a loga ze zamčené stránky, odstra	10

Pri.	Mezera	Oblast	Cílový stav (zkráceně)	MD
P2	Vlastní smart kontrakty a jejich audit (podmíněné)	Blockchain	Pokud se v budoucnu nasadí jakýkoli vlastní kontrakt (byť „jen“ forwarder, paymaster, vault nebo timelock): Slither/Semgrep/Mythril v CI jako gate, manuální audit nejméně jedné renomované firmy, u vysoké hodnoty formální verifikace kritických invariantů, invar	45
P2	Lokalizace: české řetězce mimo i18n a marketingová compliance ve všech jazycích	Klientská aplikace	Veškerý uživatelsky viditelný text přes i18n včetně notifikací, aria-labelů a formátování dat; částky vždy formátované, nikdy psané ručně; lint pravidlo zakazující literálový český text v TSX. Souběžně marketingová compliance ve všech jazycích: sdělení jasně i	18
P2	Vynucení aktualizace klienta a minimální podporované verze OS	Klientská aplikace	Server vrací minimální podporovanou verzi klienta; při nižší verzi aplikace zablokuje platební funkce a nabídne update (Android In-App Updates v režimu IMMEDIATE, iOS kontrola proti App Store API s blokující obrazovkou). minSdkVersion a iOS deployment target n	10
P3	Threat-Led Penetration Testing (TLPT) — podmíněné, pro významné subjekty	Procesy a lidé	Pokud a až orgán subjekt označí za významný: red team test na produkčním prostředí jednou za tři roky podle rámce TIBER-EU, threat intelligence od nezávislého poskytovatele, oddělení red/blue/white týmů, externí kvalifikovaní testéři, attestation pro dohled. D	0

6. Plán a očekávaná náročnost

Plán je postavený tak, aby se nejdřív dělalo to, co přežije každé budoucí rozhodnutí o rozsahu a licenci, a teprve potom to, co na tom rozhodnutí závisí. Pořadí není podle technické zajímavosti, ale podle toho, co blokuje co.

6.1 Fáze

Fáze	Název	Doba	Rozsah	Obsah
Fáze 0	Hygiena a rozhodnutí	6–8 týdnů	~70 MD	Okamžitá náprava kritických nálezů v doručení ukázky. Rozhodovací sprint o jurisdikci, licenční třídě a rozsahu. Předběžná konzultace s regulátorem a první jednání s bankou o safeguarding účtu. Výstupem je memo se šesti rozhodnutími, ne kód.
Fáze 1	Jádro, které přežije každé rozhodnutí	3–4 měsíce	~150–200 MD	Podvojný ledger, celočíselný peněžní datový typ, jedna cenová služba jako malý server pod stávajícím rozhraním. Testy jako součást práce, ne jako položka. Druhý seniorní vývojář kvůli čtyřem očím a bus faktoru.
Fáze 2	Licenční spis a jádro platformy	6–9 měsíců	~1 200–1 600 MD	Backend, identita a SCA, KYC dodavatel, AML procesy, zero trust infrastruktura, správa klíčů. Souběžně kompletace žádosti — regulátoři dnes chtějí vidět funkční systémy, ne popis. Nábor licenčně relevantních rolí je na kritické cestě.
Fáze 3	Řízení, klient a integrace	8–12 měsíců	~2 000–2 800 MD	Licenční řízení s koly dotazů. Souběžně nativní klient, custody nebo jeho nákup, karetní vrstva, back-office, fraud engine, penetrační testy a audit. Otevírání bankovního účtu a certifikace u vydavatele karet.
Fáze 4	Pilot a zastropované spuštění	4–6 měsíců	~400–600 MD	Pilot s vlastními prostředky, uzavřená beta se zastropovanými zůstatky, postupné zvyšování limitů. Provozní kontinuita, podpora, reklamace, dohledový reporting.

6.2 Dva odhady a proč se liší

Dokument uvádí záměrně **dvě čísla**. Odhad zdola nahoru sečte práci na jednotlivých mezerách a vychází na 3 152 MD. Nezávislá oponentura zkušeným CTO ho zvedá na 5 500–7 000 MD. Rozdíl není chyba v součtu — je to systematický rozdíl mezi tím co znamená „napsat to“ a co znamená „provozovat to“.

Ukazatel	Odhad zdola nahoru	Po oponentuře
Rozsah prací	3 152 MD (~14 FTE-roků)	5 500–7 000 MD (~25–32 FTE-roků)
Doba do ostrého provozu	12–18 měsíců	24–33 měsíců
Velikost týmu	neuvedeno	minimum 14 FTE, špička 18–25
Náklad do spuštění	neuvedeno	8–14 mil. EUR včetně kapitálu, práva, auditů a minim dodavatelů
Měsíční burn ve špičce	neuvedeno	250–400 tis. EUR

Doporučení k prezentaci čísel

Investorovi se předkládá oponovaný odhad, ne ten nižší. Podstřelený rozpočet, který se v průběhu roku ztrojnásobí, poškodí důvěru víc než vysoké číslo na začátku. Nižší číslo v dokumentu zůstává proto, aby bylo vidět, z čeho se počítalo.

7. Nezávislá oponentura

Mezerová analýza i odhady byly předloženy nezávislé oponentuře z pozice zkušeného CTO fintechu se zadáním být tvrdý. Text níže je její výstup bez úprav. Obsahuje věci, které se čtou nepříjemně — proto tu je.

1. Podstřelené odhady

Celý plán vychází na ~3 150 člověkodní $\approx$ 14 FTERoků. Realistická hodnota je 5 500–7 000 MD. Systematická chyba není v jednotlivých číslech, ale ve třech vzorcích: (a) odhaduje se čas na *napsání* věci, ne na její *doladění*, *otestování* a *udržení v provozu*; (b) položky závislé na protistranách (banka, vydavatel, KYC, custody, auditor) mají malé MD, ale obrovský průběžný čas — a ten v plánu vůbec není; (c) chybí veškerý „run“ — provoz není nula.

Konkrétně bych zvedl:

- **Backend 160 → 400–500.** 160 MD je jeden platební engine bez backoffice, bez admin nástrojů, bez chybové taxonomie, bez provozních runbooků, bez migrací s penězi v letu. Osm člověkoměsíců na jádro regulované instituce je odhad na demo, ne na produkt.
- **Nativní klient 190 → 350–450.** Dva vývojáři, dvě platformy, 11 obrazovek proti API, plus bezpečnostní moduly, plus obnova ztraceného zařízení, plus store review cykly, plus QA na matici zařízení. Vaše vlastní poznámka („tři až šest měsíců dvou vývojářů“) dává 260–520 MD — číslo 190 si s ní odporuje.
- **Ledger 85 → 140–170.** Chybí uzávěrkové procesy, generování výpisů, nástroje pro ruční opravné zápisy se čtyřma očima, backfill a rekonciliační reporty. Ledger bez provozních nástrojů je polotovár.
- **SCA + dynamic linking + device binding 170 → 280–320.** Největší skrytá položka je **obnova a reenrollment po ztrátě zařízení** — v seznamu není vůbec, přitom je to nejčastější podvodný vektor a nejsložitější flow celé autentizace.
- **Karetní vrstva 95 → 180–250** a dodací lhůta partnera spíš 6–12 měsíců než 3–6. Chybí zpracování clearingových souborů, settlement rekonciliace vůči vydavateli, disputes/chargeback workflow jako samostatný produkt a správa PINu.
- **Custody 80 → 200+, pokud stavíte sami.** Za 80 MD nepostavíte hot/warm/cold s MPC, policy enginem a key ceremony. Buď to kupte (integrace 60–80 MD + vendor náklad), nebo přiznejte 200+.
- **AML 130 → 250+ a fraud engine odděleně 150** (dnes schovaný v položce SIEM za 80). Transakční monitoring s pravidly, case managementem, analytickým UI a ladění false positives je samostatný produkt, ne integrace.
- **KYC 75 → 110–140.** Integrace dodavatele je pětina práce; zbytek je fronta ruční revize, odvolání, perpetual KYC, rescreening, nebiometrická větev jako plnohodnotný druhý kanál.
- **Onchain provozní vrstva 70 → 120–150** (chybí indexer a atribuce příchozích depozitů).
- **Testy 70** — tohle nemá být položka. Testy jsou 25–35 % každé inženýrské řádky. Jako samostatné číslo je to první věc, kterou pod tlakem někdo škrtne. Rozpusťte do ostatních odhadů.
- **Infrastruktura.** Součet zero trust + zálohy + prostředí + CI/CD + KMS = 215 MD, ale nikde není položka „postavit cloudovou platformu“ (sítě, IaC, runtime, observabilita, databáze, FinOps). Reálně 250–350 MD navíc.
- **Licence 220 MD interního času** je možná správně na dokumentaci, ale zakrývá 2–4 kola dotazů regulátora a povinnost demonstrovat funkční systémy. Přidejte 80–120 MD na RFI a externí náklad 150–400 tis. EUR, který v MD odhadu nefiguruje.

Naopak realistické nebo velkorysé: okamžitá náprava tajemství (6), doručení dema (10), i18n (18), pinning (18), forced update (10). To jsou položky, které umí jeden člověk a nikdo na nic nečeká.

2. Co v seznamu chybí úplně

Řazeno podle toho, co nejpravděpodobněji projekt zabije:

1. **Bankovní vztah a safeguarding účet jako samostatný projekt s vlastním rizikem selhání.** Je zmíněn jako důsledek licence. Ve skutečnosti je to nejtvrdší blokátor: fintech s krypto vrstvou a klientelou z Venezuely shání banku 6–18 měsíců a často ji neseže vůbec. Tohle není položka plánu, tohle je otázka, jestli plán vůbec existuje.
2. **Sankční expozice na fiat straně a OFAC nexus.** Onchain screening tam je, jméno/IBAN/adresa screening ne. Venezuela + USD/USDC = riziko sekundárních sankcí a Circle jako single point of freeze. Nikde není posouzení, jestli je cílový trh vůbec obsluhovatelný.
3. **Napojení na platební schémata.** SEPA SCT/SCT Inst/SDD, přímý vs. nepřímý přístup, BIC, IBAN discrimination — a hlavně **Verification of Payee a povinná okamžitá platba podle nařízení 2024/886, pro platební instituce a EMI od 9. 4. 2027.** Datovaná právní povinnost s netriviální implementací, v seznamu není ani slovo.
4. **Backoffice a provozní nástroje.** Nula položek. Bez interní aplikace (vyhledání klienta, případ, ruční zápis, refundace, zmrazení, revize KYC, makerchecker a audit administrátorských akcí) skončí provoz u SQL konzole nad produkcí. 150–250 MD.
5. **Zákaznická podpora a reklamace jako provoz.** Helpdesk, tři jazyky, SLA, lhůty PSD2 na stížnosti, členství v mimosoudním řešení sporů, chargeback ops. 24/7 znamená minimálně 5 lidí nebo outsourcing. Kompletně chybí i v nákladech.
6. **Treasury a řízení likvidity.** Předfinancování nostro účtů, intraday likvidita, cutoff časy, FX pozice a kdo nese kurzové riziko spreadu, likvidita pro konverze stablecoinů, OTC protistrana, sledování vlastního kapitálu proti regulatornímu minimu, provize na winddown. Produkt postavený na hyperinflační měně bez treasury funkce je otevřená pozice, kterou nikdo neřídí.
7. **Účetnictví, uzávěrka a statutární audit.** Povinný audit účetní závěrky licencovaného subjektu, IFRS zacházení s klientskými prostředky a kryptoaktivy, měsíční uzávěrka, výběr auditora. A **DAC8 — od 1. 1. 2026 povinné daňové hlášení transakcí klientů poskytovatelem služeb kryptoaktiv.** Chybí celé.
8. **Pojištění.** PI, D&O, crime/fidelity, kyber, pojištění custody. D&O pro krypto subjekt je drahé a část pojistitelů ho odmítá — to je vstupní podmínka pro seriózního investora i pro některé bankovní partnery.
9. **Průběžný dohledový reporting po licenci.** Pravidelná hlášení regulátorovi, pololetní statistika podvodů podle EBA, statistika FIU, notifikace podstatných změn, hlášení stížností. Vyžaduje nástroje a lidi, ne jen politiku.
10. **Smluvní dokumentace vůči klientovi.** Rámcová smlouva podle Hlavy III PSD2, předmluvní informace, sazebník jako smluvní příloha, uzavírání smlouvy na dálku, verzování podmínek a jejich změna se 2měsíční lhůtou. Nikde.
11. **Životní cyklus klienta.** Ukončení účtu, offboarding, úmrtí a dědictví, nesvéprávnost, dormantní účty a nevyzvednuté prostředky, zmrazené účty, spory o vlastnictví. Zdroj velkého množství reálné provozní práce.
12. **Obnova přístupu a zařízení.** Viz výše — chybí a je to fraud hotspot.
13. **Provozní kontinuita mimo IT.** Keyperson risk, náhradní pracoviště, krizová komunikace, BIA. Dnešní bus faktor je 1 a to je v plánu jen jako „chybí lidé“.
14. **Nábor jako kritická cesta, ne jako 45 MD.** MLRO s litevskou rezidencí je vzácné a drahé zboží, výpovědní lhůty jsou 2–3 měsíce a fitandproper posouzení regulátorem trvá týdny až měsíce a může skončit zamítnutím. To je 6–9 měsíců elapsed, ne 45 člověkodní.
15. **Přístupnost jako právní povinnost** — European Accessibility Act se od 28. 6. 2025 vztahuje na spotřebitelské bankovní služby. V seznamu je „přístupnost“ jako vedlejší zmínka u přepisu klienta.
16. **Ekonomika produktu.** Unit economics spreadu, CAC, breakeven objem. Nikdo nespočítal, kolik klientů a jaké objemy potřebujete, aby provoz s 20 lidmi a 500 tis. EUR kapitálu dával smysl. Bez toho je celý plán rozpočet bez protistrany.
17. **Fázový rollout.** Pilot s vlastními prostředky, uzavřená beta se zastropovanými zůstatky, postupné zvyšování limitů. Plán implicitně předpokládá big bang.

3. Realistický čas a tým

24–33 měsíců od dneška do ostrého provozu s cizími penězi, při dobrém vedení a bez velkých překvapení. Ne 12–18.

Hrubá osa: 0–3 měsíce rozhodnutí a nábor jádra; 3–12 stavba backendu, ledgeru a identity souběžně s kompletací licenčního spisu; podání žádosti realisticky v měsíci 9–12, protože dřív nebudete mít co ukázat (regulátoři dnes chtějí demonstraci systémů, ne popis); 12–22 licenční řízení s koly dotazů souběžně s klientem, custody, kartou, testy a pentestem; 20–28 otevírání bankovního účtu a certifikace u vydavatele; 26–32 pilot a zastropované spuštění.

Tým: minimum 14 FTE, špička 18–25. Inženýrsky 4–6 backend, 2–3 mobil, 2 platforma/SRE, 1 bezpečnost, 1–2 QA, 1 blockchain, produkt, designér. Nezávisle compliance manager, MLRO, 2 AML analytici, DPO (částečný úvazek), CISO, treasury/finance 1–2, rizikový analytik, podpora 3–5. Burn ve špičce 250–400 tis. EUR měsíčně; celkem do spuštění 8–14 mil. EUR včetně kapitálu, externího práva, auditů a vendor minim.

Kde se to protáhne, seřazeno:

1. Bankovní a vydavatelský partner. Externí, nekoupitelné rychleji za peníze, může skončit „ne“.
2. Lidé s licenčně relevantními rolemi a jejich schválení regulátorem.
3. Úplnost žádosti — lhůty běží od úplnosti a tým skoro jistě podcení, co „úplná“ znamená.
4. Custody a onchain vrstva, pokud padne rozhodnutí stavět vlastní.
5. Bus faktor 1. Dnes jakákoli dvouměsíční absence zakladatele znamená úplné zastavení.

A hlavní důvod trojnásobku oproti plánu: **rozsah**. EMI + CASP + custody + karty + FX + hyperinflační produkt současně. Každá z těch věcí je samostatná firma. Dokud se rozsah nezmenší na jednu licenční třídu a jeden peněžní tok, je plán nefinancovatelný v seed kole — čísla, která z něj vypadnou, žádný institucionální investor v prerevenue fázi nedá.

4. Nejlevnější rozumný první krok

Čtyři věci, dohromady ~6–8 týdnů a v řádu nižších stovek tisíc korun:

1. **Hygienická oprava dema (položka za 6 MD) tento týden.** Heslo je prokazatelně v sestaveném souboru na disku v OneDrive. Není o čem diskutovat.
2. **Rozhodovací sprint, 2–3 týdny, ~20 MD plus 5–10 tis. EUR specializovaného právníka.** Výstup je desetistránkové memo se šesti rozhodnutími: jurisdikce, licenční třída, EMT, držet vs. nedržet klientská kryptoaktiva, vlastní licence vs. provoz jako agent/distributor pod cizí licencí, cílový trh. Samotné rozhodnutí „nedržíme vlastní custody“ škrtne ~350 MD a jednu licenční třídu. Rozhodnutí „jdeme jako agent existujícího EMI“ škrtne 12–18 měsíců a půl milionu eur kapitálu.
3. **Předběžná konzultace s regulátorem a tři rozhovory s bankami o safeguarding účtu.** Stojí memo a pár cest. Odpověď — nebo mlčení — vám do dvou měsíců řekne o životaschopnosti víc než rok vývoje. Tohle udělejte **dřív, než napíšete první řádek backendu**.
4. **Jediná technická investice, kterou má smysl dělat před licencí: ledger, peněžní datový typ a jedna cenová služba jako malý server pod stávajícím UI, s testy.** 40–60 MD, jeden vývojář, tři měsíce. Je to jediný kód, který přežije každé z rozhodnutí v bodě 2, odstraňuje cenovou nekonzistenci, kterou dnes máte, a je to zároveň jediný artefakt, kterým se dá při due diligence doložit inženýrská zralost. Souběžně přijměte druhého seniorního vývojáře — ne kvůli kapacitě, kvůli čtyřem očím a bus faktoru.

Před licencí naopak nedělejte: ISO 27001, PCI, penetrační test dema, nativní přepis, vlastní kontrakty, TLPT, doladování i18n. To všechno jsou peníze utracené za práci, kterou rozhodnutí z bodu 2 může zahodit.

A jedna poznámka mimo technický plán: největší reputační riziko dnešního kola není bezpečnostní, ale prezentační. Pokud se demo investorovi ukazuje jako „beta banky“, je rozdíl mezi tím, co vidí, a tím, co existuje, tak velký, že jeho odhalení v DD zabije důvěru ve všechno ostatní. Přeznačte to jako simulaci produktu a k ní přiložte tenhle plán se škrtnutým rozsahem. Ten rozhovor probíhá mnohem líp než ten druhý.

8. Doporučený postup

Tento týden

- **Vyměnit nasazovací heslo a opravit jeho únik do sestaveného souboru.** Heslo je prokazatelně v otevřené podobě na disku ve složce synchronizované do cloudu. Není o čem rozhodovat, je to hodinová práce.
- **Přestat používat jedno heslo pro vývoj i pro nasazení.** Dnes je šifrovací klíč totožný s vývojovým přístupovým kódem, takže kompromitace jednoho znamená kompromitaci druhého.
- **Ověřit, že přístup k ukázce jde odvolat.** Stažená kopie dnes platí navždy; kdo jednou dostal heslo, má přístup i po ukončení jednání.

Do dvou měsíců, dřív než se napíše první řádek backendu

- **Rozhodovací sprint.** Šest rozhodnutí: jurisdikce, licenční třída, který stablecoin, držet či nedržet klientská kryptoaktiva, vlastní licence versus provoz pod cizí licencí, cílový trh. Samotné rozhodnutí nedržet vlastní custody škrtne stovky člověkodní a jednu licenční třídu.
- **Předběžná konzultace s regulátorem a tři rozhovory s bankami o safeguarding účtu.** Odpověď — nebo mlčení — řekne o životaschopnosti víc než rok vývoje. Fintech s krypto vrstvou shání banku měsíce a někdy ji nesežene vůbec.
- **Jediná technická investice před licencí:** podvojný ledger, celočíselný peněžní typ a jedna cenová služba jako malý server pod stávajícím rozhraním, s testy. Je to jediný kód, který přežije každé z rozhodnutí výše, odstraňuje dnešní cenovou arbitráž a je to zároveň jediný artefakt, kterým se dá při due diligence doložit inženýrská zralost.

Co naopak před licencí nedělat

ISO 27001, PCI DSS, penetrační test ukázky, nativní přepis klienta, vlastní smart kontrakty, TLPT ani doladování lokalizace. To všechno jsou peníze utracené za práci, kterou může rozhodnutí o rozsahu zahodit.

Poznámka k prezentaci ukázky

Největší riziko dnešního kola není bezpečnostní, ale prezentační. Pokud se ukázka představuje jako „beta banky“, je rozdíl mezi tím, co investor vidí, a tím, co existuje, tak velký, že jeho odhalení při due diligence poškodí důvěru ve všechno ostatní. Doporučení je jednoznačné: prezentovat ji jako **simulaci produktu** a přiložit k ní tento dokument. Ten rozhovor probíhá výrazně lépe.

9. Co se od auditu změnilo

Audit se vztahuje k revizi *bcfaa50* ze 16. srpna 2026. Beta aplikace se od té doby změnila. Nálezy zůstávají v dokumentu tak, jak byly pořízeny — přepisovat audit zpětně by znamenalo ztratit stopu o tom, co se skutečně našlo. Přehled níž říká, co je od té doby jinak.

Co bylo v době auditu	Co je dnes
Funkce se jmenovala „Úschova / Trezor“.	Jmenuje se Safe Money . Slova „úschova“ a „trezor“ jsou z aplikace odstraněná ve všech třech jazycích.
Safe Money bylo vedené po měnách — trezor VES, trezor CZK.	Safe Money je vedené vždy v XSGD . Vklad z jiné měny je po cestě směna se stejnou sazbou jako na obrazovce směny.
Srovnání kupní síly ukazovalo procentní rozdíl, který se dal číst jako výnos.	Ukazuje graf uchování hodnoty — dvě křivky indexu kupní síly od 100 — a pod ním rozdíl inflací v procentních bodech se zdrojem a obdobím.
Nabídka obsahovala čtyři stablecoiny (XSGD, USDT, USDC, EURC) jako rovnocenné.	Aktivní je jen XSGD . USDT, USDC a EURC jsou v seznamu průhledné a nevybratelné, s poznámkou, že se posuzují vůči AML a MiCA.
Sazebník se uplatňoval jen v jedné ze čtyř peněžních cest.	Sazba se řídí stavem ekonomiky obou stran (hyperinflace / standard) a uplatňuje se i u Safe Money. Cesta „převod na vlastní účet“ zůstává k dořešení v cílovém systému.
Nasazovací heslo se dostávalo v čitelné podobě do sestaveného souboru.	Zůstává jako neopravený nález — je to organizační krok na straně klienta, ne změna v kódu. Viz kapitola 3.3.

Co se nezměnilo

Nálezy o peněžní logice platí dál v tom smyslu, v jakém byly pořízeny: zdrojem pravdy o peněžích je pořád prohlížeč klienta, neexistuje podvojný účetnictví a operace nejsou idempotentní. To nejsou vady, které by šlo opravit v simulaci — mizí až se serverem, tedy ve fázi 1 cílové architektury.

Příloha A — úplný seznam nálezů

Všech 90 nálezů seřazených podle závažnosti. Sloupec „Důkaz“ odkazuje na konkrétní místo ve zdrojovém kódu k datu auditu.

Závažnost	Nález	Oblast	Důkaz
Kritická	Zdrojem pravdy o penězích je prohlížeč klienta Celý stav včetně zůstatků, karet, PINů, CVV, plných čísel karet a stavu KYC žije v jednom zustand objektu a ukládá se nešifrovaně do localStorage. Partialize odfiltruje jen toast a unlocked — všechno ostatní se serializuje. Kdo otevře devtools, přepíše si zůstatek na libovolné číslo, přeskočí KYC nebo si přečte PIN ke všem kartá	Funkční rozsah	C:\Users\Brann\OneDrive\Desktop\alvah Technologies\LargoVerse\src\store\useApp.ts:683-686 — name: 'largoverse-beta-3', partialize: ({ toast: _toast, u
Kritická	Přihlášení neověřuje vůbec nic signIn() jen nastaví authed: true. Registrace e-mailem projde při jakémkoli řetězci s @ a hesle delším než 3 znaky, telefonní varianta při jakémkoli čtyřznakovém „SMS kódu“, sociální tlačítka přihlásí okamžitě bez jediného pole. Nikde se neukládá žádný uživatel, takže při přihlášení není co porovnávat — heslo se zahodí. Zapomenu	Funkční rozsah	C:\Users\Brann\OneDrive\Desktop\alvah Technologies\LargoVerse\src\store\useApp.ts:212 signIn: () => set({ authed: true }); podmínky v Auth.tsx:380
Kritická	Nasazovací heslo je vloženo v čitelné podobě do sestaveného JS — i při šifrovaném buildu `scripts/build-secure.mjs` (ř. 57–62) spouští Vite s `env: { ...process.env, VITE_GATE: 'off' }`. Vypíná tím vnitřní bránu, ale nijak neruší `VITE_ACCESS_CODES` — a Vite si ho stejně načte přímo z `.env.local` na disku. Vite všechny `VITE_*` proměnné nahrazuje literálem už při buildu, takže se do bundlu vypeče ostré nasazovací h	Doručení a ochrana	dist/assets/index-hmPcZoc-js: `A-Z0-9[/g, ""], Am="LARGO-HETN-BD7M-B9TY".split(",") .map(Fd).filter(Boo` — obsahuje doslovné heslo z .deploy-passphrase.
Kritická	Šifrovací klíč je z rozhodnutí projektu totožný s vývojovým přístupovým kódem README (ř. 56–58) i `.env.example` výslovně instruuji, aby se `VITE_ACCESS_CODES` drželo shodné s heslem, kterým se šifruje nasazený build — s odůvodněním, že jinak „localhost chce jiný kód než živá adresa“. Na disku to tak skutečně je: `.env.local` obsahuje `LARGO-HETN-BD7M-B9TY` a `.deploy-passphrase.txt` obsahuje přesně tentý	Doručení a ochrana	.env.local: `VITE_ACCESS_CODES=LARGO-HETN-BD7M-B9TY`; .deploy-passphrase.txt: `LARGO-HETN-BD7M-B9TY`. .env.example: „Držte ho STEJNÝ jako heslo, který
Kritická	Jedno sdílené heslo bez odvolatelnosti — stažená kopie platí navždy Celý model je „jeden soubor + jedno heslo pro všechny“. Neexistuje přístup per osoba, neexistuje expirace, neexistuje seznam pro zneplatnění a neexistuje záznam, kdo odemkl. Zásadní je, že `deploy/index.html` je statický soubor — kdokoli si ho uloží (Ctrl+S, curl, cache prohlížeče) a má offline kopii, kterou stejné heslo otevře	Doručení a ochrana	scripts/build-secure.mjs:252-259 zapisuje jediný statický `deploy/index.html`. Neexistuje žádný server, žádná validace tokenu ani kontrola vypršení —
Kritická	Žádné podvojně účetnictví — zůstatek a historie jsou dvě nezávislé pravdy Zůstatek je vlastní pole (`accounts[.balance`, `wallet.ves`, `wallet.xsgd`, `wallet.vaults[c]`), které se mění přímo. Pole `transactions` se plní vedle něj a nikde se nepoužije k odvození ani ke kontrole zůstatku. Neexistuje invariant „součet pohybů = zůstatek“, žádná rekonciliace, žádný uzávěrkový bod. Že to spolu nesouvisí, d	Peněžní logika	src/store/useApp.ts:226-242 (`pay`: `balance: round(a.balance - amount)` a vedle toho nezávisle `transactions: [tx({...}), ...s.transactions]`); src/d
Kritická	Zdroj pravdy o penězích je localStorage prohlížeče, přepsatelný jedním řádkem v konzoli Celý stav včetně zůstatků, historie, KYC statusu a příznaku přihlášení se serializuje do localStorage pod klíčem `largoverse-beta-3`. `partialize` vyřazuje jen `toast` a `unlocked` — všechno ostatní se uloží. Kdokoli může v devtools spustit `JSON.parse(localStorage['largoverse-beta-3'])`, změnit `state.accounts[0].balance` na li	Peněžní logika	src/store/useApp.ts:680-687 (`name: 'largoverse-beta-3', `partialize: ({ toast: _toast, unlocked: _unlocked, ...rest }) => rest`); src/store/useAp
Kritická	Platba pod jeden halíř neodepíše nic, ale odešlo se — hodnota vzniká z ničeho `pay()` svůj vstup nezaokrouhluje. Kontrola je jen `amount <= 0`. Zůstatek se pak nastaví na `round(a.balance - amount)` se dvěma desetinnými místy, takže při částce pod 0,005 se výsledek zaokrouhlí zpět na původní hodnotu. Ověřeno výpočtem: 1 000 plateb po 0,004 CZK z 37 129,64 CZK nechá zůstatek na přesně 37 129,64 CZK, při	Peněžní logika	src/store/useApp.ts:223-244 (`if (!account    amount <= 0    account.balance < amount) return false` a `balance: round(a.balance - amount)`); sr

Závažnost	Nálež	Oblast	Důkaz
Kritická	NaN a Infinity projdou všemi kontrolami a natrvalo znehodnotí zůstatek Všechny peněžní funkce se brání pouze porovnáním typu `amount <= 0` a `balance < amount`. Obě porovnání jsou s `NaN` vždy `false`, takže `NaN` projde jako platná částka. Ověřeno: `NaN <= 0` → false, `37129.64 < NaN` → false, `round(NaN, 2)` → NaN. Zůstatek se tím nastaví na `NaN`, uloží se do localStorage jako `null`	Peněžní logika	src/store/useApp.ts:225 (`amount <= 0    account.balance < amount`), :288, :336, :366 (`get().balanceOf(from) < amount + fee`), :447; ověřeno
Kritická	Operace nejsou idempotentní a nemají identifikátor požadavku Každá peněžní funkce provede pohyb bezpodmínečně a vygeneruje si nové náhodné id (`uid()`). Neexistuje klientem zadaný idempotency key, žádná deduplikace, žádný stav operace (zahájeno/potvrzeno/zamítnuto), žádná evidence už provedených požadavků. Funkce vrací pouze `boolean`, takže volající nemá jak zjistit, jestli operace, kter	Peněžní logika	src/store/useApp.ts:170 (`const uid = () => 'tx-' + Math.random().toString(36).slice(2, 10)`), :223, :246, :335 (všechny vracejí boolean); src/scre
Vysoká	Store je zároveň UI kontejner i bankovní jádro — chybí seam pro backend src/store/useApp.ts (704 řádků) drží session, KYC, všechna data i všechny peněžní operace a screens do něj sahají přímo přes useApp(selector). Mezi UI a daty není žádná servisní ani repository vrstva, žádná async operace, žádný stav načítání ani chyby — každá operace je synchronní funkce vracející boolean (`pay`, `transferOwn`,	Architektura	src/store/useApp.ts:180-689 (celý create(persist(...)) blok); src/screens/Exchange.tsx:118 vs src/store/useApp.ts:366
Vysoká	Peníze jako JavaScriptové floaty s ad-hoc zaokrouhlením Všechny zůstatky a částky jsou `number` a po každé operaci se ručně zaokrouhlují funkcí `round(n, decimals) { const f = 10 ** decimals; return Math.round(n * f) / f }`. Počet desetinných míst se rozhoduje na místě podle měny a stejná pomocná funkce `dec`/`decOf` je v souboru definovaná třikrát (ř. 355, 370, 449). Řetězec konverz	Architektura	src/store/useApp.ts:691-694 (`round`), :355, :370, :449 (třikrát definované `dec`/`decOf`), :369 `convert(amount, from, to) * (1 - tariff.spread)`
Vysoká	Zápis do historie není dvojité účetnictví a je nekonzistentní mezi operacemi Každá operace si zapisuje do `transactions` jinak. `exchangeAny` запиše dvě nohy plus samostatný řádek poplatku (2-3 řádky). `transferOwn` запиše dvě nohy, ale poplatek zabalí do odepsané částky a vlastní řádek pro něj nevytvoří. `vaultMove` запиše jedinou nohu — pohyb na volném zůstatku — a stranu Safe Money ani spread při kříž	Architektura	src/store/useApp.ts:407-416 (exchangeAny, 2-3 řádky) vs :263-279 (transferOwn, poplatek jen uvnitř `round(debited)` vs :510-519 (vaultMove, jediný ř
Vysoká	Číslo karty, CVV a PIN se ukládají v otevřeném localStorage `persist` vynechává z ukládaného stavu jen `toast` a `unlocked`; všechno ostatní včetně pole `cards` jde do localStorage pod klíčem `largoverse-beta-3`. Každá karta nese `number`, `cvv` a `pin` jako čitelný text (seed.ts:60-107, generateCard v useApp.ts:541-568). V demu jsou to smyšlená a záměrně nevalidní data, takže se aktuáln	Architektura	src/store/useApp.ts:686 `partialize: ({ toast: _toast, unlocked: _unlocked, ...rest }) => rest`; src/domain/seed.ts:60-107 (`cvv: '123', `pin: '12
Vysoká	Šifrovaný build se rozbije při jakémkoli code-splittingu a po dešifrování volá cizí CDN build-secure.mjs vybere z dist/assets první soubor končící na .css a první na .js a zašifruje jen tyhle dva. Víte dnes vydává přesně jeden chunk, takže to funguje; jakmile ale kdokoli přidá dynamický import, manualChunks nebo web worker, skript beze slova zabalí jen část aplikace. Navíc zaváděcí stránka po úspěšném dešifrování p	Architektura	scripts/build-secure.mjs:77-82 (`assetFiles.find((f) => f.endsWith('.js'))`); scripts/build-secure.mjs:212-215 (`fonts.href = 'https://fonts.google
Vysoká	Session nikdy nevypřít a přežije restart prohlížeče authed je součástí persistovaného stavu, takže po zavření a otevření prohlížeče je uživatel dál přihlášený. Zavře se jen přístupová brána (unlocked se neukládá). Není tu žádný časový limit nečinnosti, žádné obnovení tokenu, žádné odhlášení na straně serveru — signOut jen přepne příznak zpět.	Funkční rozsah	C:\Users\Brann\OneDrive\Desktop\alvah Technologies\LargoVerse\src\store\useApp.ts:686 (authed není vyloučen z partialize) a 215 signOut: () => set(
Vysoká	Skenování QR ohlásí odeslanou platbu, aniž by se pohnula koruna Klepnutí na obrázek QR ve skeneru zavolá showToast(`paymentSent`) a odnaviguje na přehled. Žádná akce storu se nevolá, žádný zůstatek se nemění, žádná transakce nevzniká. Uživatel se přitom napíše totéž hlášení jako u skutečně provedené platby.	Funkční rozsah	C:\Users\Brann\OneDrive\Desktop\alvah Technologies\LargoVerse\src\screens\Payments.tsx:552-557 — onClick={() => { showToast(t(`paymentSent`)); navi

Závažnost	Nález	Oblast	Důkaz
Vysoká	Sazebník se uplatňuje jen v jedné ze čtyř peněžních cest pricing.ts se tváří jako jediné místo pravdy o cenách, ale volá ho jen exchangeAny (spread i pevný poplatek) a částečně vaultMove (pouze spread, poplatek ne). transferOwn si účtuje natvrdo TRANSFER_FEE_CZK a konvertuje středovým kurzem convert() zcela bez spreadu. pay() neúčtuje nic. Vzniká obcházení ceny: převod CZK → USD mezi	Funkční rozsah	C:\Users\Brann\OneDrive\Desktop\alvah Technologies\LargoVerse\src\store\useApp.ts:246-284 (transferOwn — convert bez spreadu, feelnFrom z konstanty),
Vysoká	Náhled odpisu u převodu na vlastní účet neodpovídá tomu, co se strhne Formulář počítá odpis jako převedená částka + TRANSFER_FEE_CZK, tedy přičte 50 jednotek měny zdrojového účtu, a takto to zobrazí jako „Z účtu se strhne“. Store ale poplatek přepočte kurzem: convert(50, 'CZK', from.currency). Při zdrojovém účtu v USD tedy náhled slibuje odpis o zhruba 47,7 USD ($\approx 1\,045$ CZK) vyšší, než se skutečně	Funkční rozsah	C:\Users\Brann\OneDrive\Desktop\alvah Technologies\LargoVerse\src\screens\Payments.ts:376 const debited = convert(value, to.currency, from.currency)
Vysoká	KYC je klikací atrapa a schvaluje se časovačem Nahrání dokladu je přepnutí booleanu — nevybírání se žádný soubor, název „IMG_2376 (1.8 MB)“ je dokreslený text. Selfie se pořídí klepnutím na kruh. Po odeslání se stav přepne na pending a obrazovka si sama po 2 600 ms zavolá approveKyc(). Nic se nikam neposílá a nic se neověřuje — ani jméno, které aplikace celou dobu ukazuje (Ond	Funkční rozsah	C:\Users\Brann\OneDrive\Desktop\alvah Technologies\LargoVerse\src\screens\Kyc.ts:282-286 — window.setTimeout(approve, 2600); fiktivní názvy souborů n
Vysoká	Zůstatek a historie jsou dvě nezávislé pravdy Každá peněžní akce zvlášť změní číslo zůstatku a zvlášť vloží řádek do transactions. Zaokrouhluje se přitom dvakrát a různě: round(balance + delta) proti round(delta) v řádku výpisu, takže se obě čísla mohou rozejít o haléře. Nic se nikdy nesesouhlasuje — výpis se z něčeho nepřepočítává a zůstatek z výpisu neplyne. Pohyb v úscho	Funkční rozsah	C:\Users\Brann\OneDrive\Desktop\alvah Technologies\LargoVerse\src\store\useApp.ts:372-417 (exchangeAny — add()) zaokrouhluje zůstatek, rowFor zaokrouhl
Vysoká	Limity karty a zámeček karty se nikde nevynucují a strop limitu se dá bez omezení eskalovat card.limits se čtou pouze pro zobrazení a pro výpočet maxima nového limitu; žádná peněžní akce je nekontroluje. Stejně tak state: 'locked' — zamknutá karta nic neblokuje, protože kartou se stejně nedá zaplatit (jediná karetní transakce je ruční spouštěč prezentace, který si sám vybere aktivní kartu). Maximum nového limitu je des	Funkční rozsah	C:\Users\Brann\OneDrive\Desktop\alvah Technologies\LargoVerse\src\screens\Cards.ts:499 const max = card.limits[limitKey] * 10; setCardLimit v useApp.
Vysoká	Nabídka nákupu XSGD a USDT bez řešení autorizace v EU Celý příběh ukázky stojí na držbě a nákupu XSGD, v nabídce stablecoinů je i USDT. Ani jeden z těchto tokenů není v EU autorizovaný podle MiCA — z pohledu evropského klienta by je regulovaný subjekt nabízet nemohl, na rozdíl od USDC či EURC. Tým už jednou právní hranici respektoval, když ze Safe Money odstranil slib zhodnocení 2,	Funkční rozsah	C:\Users\Brann\OneDrive\Desktop\alvah Technologies\LargoVerse\src\domain\types.ts:15 STABLECOINS = ['XSGD', 'USDT']; odstraněný VAULT_RATE a odůvodněn
Vysoká	Odemykácí stránka je nepodepsaná a doručovaná stejným kanálem, který má chránit Slib schématu je „heslo se zadává v prohlížeči a nikam neodchází“. Ten slib ale plní JavaScript, který si prohlížeč stáhne ze stejného hostingu jako ciphertext, bez podpisu, bez připnutého otisku a bez CSP (GitHub Pages ani neumí nastavit hlavičky). Kdo získá zápis na hosting — kompromitovaný GitHub/Cloudflare účet, ukradený API	Doručení a ochrana	scripts/build-secure.mjs:174-233 — celá logika je inline <script>` v tomtéž souboru jako data. Jediná integritní kontrola je autentizační tag A
Vysoká	Normalizace hesla mlčky ničí entropii a povolené minimum je prolomitelné Klíč se neodvozuje z toho, co uživatel napsal, ale z `s.toUpperCase().replace(/^[A-Z0-9]/g, "")`. Abeceda tím klesá na 36 symbolů a veškerá entropie z malých písmen, symbolů i diakritiky se zahazuje — bez varování. Ověřeno spuštěním: `Přístup-2026` (12 znaků, uživateli připadá rozumné) se změní na `PSTUP2026`, tedy 9 znaků zmrza	Doručení a ochrana	scripts/build-secure.mjs:47 `const normalize = (s) => s.toUpperCase().replace(/^[A-Z0-9]/g, "")` a ř. 36 `if (!passphrase passphrase.length <
Vysoká	Ochrana nemá žádnou obranu proti hádání — je to čistě offline útok U přihlašování na server lze hádání zpomalit limitem pokusů, prodlevou nebo zamčením účtu. Tady nic z toho neexistuje a existovat nemůže: útočník si stáhne `deploy/index.html`, odpojí se a hádá lokálně libovolnou rychlostí. AES-GCM autentizační tag mu navíc dává rychlé a spolehlivé kritérium, jestli trefil. PBKDF2 se 310 000 ite	Doručení a ochrana	scripts/build-secure.mjs:25 `const PBKDF2_ITERATIONS = 310_000` a ř. 107-113 (deriveKey). V loaderu ř. 198-205 běží totéž lokálně; nikde v repozitáři

Závažnost	Nález	Oblast	Důkaz
Vysoká	Tajemství a důvěrné klientské podklady leží v OneDrive, přestože README tvrdí opak README (ř. 113–117) i komentář v <code>.gitignore</code> říkájí o složce <code>docs/</code> doslova, že jde o cizí materiál, který „nesmí opustit tenhle počítač“, a totéž vztahuje na <code>.deploy-passphrase.txt</code> . Celý projekt ale leží v <code>C:\Users\Brann\OneDrive\Desktop\...</code> , tedy v adresáři synchronizovaném do Microsoft OneDrive. Nezveršované soubory <code>.g</code>	Doručení a ochrana	Pracovní adresář: <code>/c/Users/Brann/OneDrive/Desktop/al vah Technologies/LargoVerse</code> . Na disku přítomné <code>.deploy-passphrase.txt</code> (obsah <code>LARGO-HETN-BD7M-</code>
Vysoká	GitHub Pages z tohoto repozitáře nelze zapnout správně — zapnutí by zveřejnilo zdrojový kód README a hlavička build skriptu staví celé odůvodnění šifrování na tom, že „GitHub Pages umí jen veřejné adresy“. Jenže výstup <code>deploy/</code> je v <code>.gitignore</code> , neexistuje žádná větev <code>gh-pages</code> ani workflow v <code>.github/</code> , takže zašifrovaný soubor se do gitů vůbec nedostane a Pages by ho neměly odkud vzít. V kořeni je naopak commitnut	Doručení a ochrana	<code>.gitignore</code> obsahuje <code>dist</code> a <code>deploy</code> . <code>git ls-files</code> vrátí <code>index.html</code> a všech 40+ souborů <code>src/**</code> , ale žádný soubor z <code>deploy/</code> . Kořenový index.
Vysoká	Cloudflare Access nepokryje preview adresy Pages a nesmaže cizí politiky <code>scripts/cloudflare-access.mjs</code> zakládá Access aplikaci pouze pro holý hostname <code>largoerse-demo.pages.dev</code> (ř. 26). Cloudflare Pages ale každému nasazení přiděluje vlastní trvalou preview adresu <code><hash>.largoerse-demo.pages.dev</code> , která takto úzce zacílenou politikou chráněná není a zůstává dostupná i po nahrazení produkč	Doručení a ochrana	<code>scripts/cloudflare-access.mjs</code> : <code>26 const HOSTNAME = process.env.LARGOVERSE_HOST ?? 'largoerse-demo.pages.dev';</code> <code>76 apps.find((a) => a.domain ==</code>
Vysoká	Stejná konverze CZK→USD má dvě ceny; „převod na vlastní účet“ obchází celý spread <code>transferOwn</code> převádí mezi měnami čistě přes <code>convert()</code> , tedy středovým kurzem, a účtuje jen pevných 50 CZK. <code>exchangeAny</code> na stejný pár aplikuje <code>tariffFor()</code> — spread 1,5 % plus týchž 50 CZK. Obojí je dostupné z běžného rozhraní. Ověřeno na 1 000 000 CZK: přes Směnu klient dostane 44 936,13 USD, přes Převod na vlastní účet 45	Peněžní logika	<code>src/store/useApp.ts:252-254</code> <code>(const credited = convert(amount, from.currency, to.currency))</code> — bez spreadu, bez <code>tariffFor</code> proti <code>src/store/useApp.ts:36</code>
Vysoká	Safe Money obchází pevný poplatek — vklad z jiné měny je nezpoplatněná směna <code>vaultMove</code> při vkladu z jiné měny správně aplikuje spread z <code>tariffFor(source, currency)</code> , ale položku <code>feeCzk</code> z téhož sazebníku úplně ignoruje. Komentář nad tím místem přitom výslovně říká, že smyslem je zabránit obcházení sazby přes Safe Money — spread se zavřel, poplatek zůstal otevřený. Ověřeno: vložit 1 000 000 CZK do Saf	Peněžní logika	<code>src/store/useApp.ts:469-470</code> <code>(const cross = source !== currency, const spread = cross ? tariffFor(source, currency).spread : 0</code> — <code>feeCzk</code> se nikde
Vysoká	Peníze jsou vedené v plovoucí desetinné čárce a round() zaokrouhluje nesymetricky Všechny zůstatky jsou <code>number</code> , tedy IEEE-754 double. Jediná zaokrouhlovací funkce <code>round(n, d) = Math.round(n * 10**d) / 10**d</code> má dvě samostatné vady. Za prvé binární nepřesnost násobení: ověřeno <code>1.005 * 100 = 100.49999999999999</code> , takže <code>round(1.005, 2)</code> vrátí 1,00 místo 1,01; <code>round(8.165, 2)</code> vrátí 8,16. Za druhé <code>Math.roun</code>	Peněžní logika	<code>src/store/useApp.ts:691-694</code> <code>(function round(n, decimals = 2) { const f = 10**decimals; return Math.round(n * f) / f });</code> ověřeno v Node: <code>1.005*100</code>
Vysoká	Připsání a odepsání hledá účet podle měny, ne podle id — druhý účet ve stejné měně částku zduplikuje V <code>exchangeAny</code> i <code>vaultMove</code> se změna zůstatku aplikuje přes <code>accounts.map(acc => acc.currency === c ? { ...acc, balance: round(acc.balance + delta) } : acc)</code> , tedy na VŠECHNY účty s danou měnou. Kontrola dostupnosti přitom běží přes <code>balanceOf()</code> a <code>locate()</code> , které používají <code>.find()</code> a vrátí jen PRVNÍ takový účet. Ověření	Peněžní logika	<code>src/store/useApp.ts:378-381</code> <code>(accounts = accounts.map((acc) => acc.currency === c ? { ...acc, balance: round(acc.balance + delta) } : acc))</code> proti
Vysoká	Poplatek se strhne, ale nikam se nepřipíše; u převodu na vlastní účet není ani vidět <code>transferOwn</code> počítá <code>debited = amount + feeInFrom</code> a odepíše celou sumu, ale do historie zapíše jediný řádek s částkou <code>-round(debited)</code> — poplatek je v něm schovaný a nikde se neuvádí. <code>exchangeAny</code> je v tomhle lepší a poplatek zapisuje samostatným řádkem (<code>kind: 'fee'</code>), ale ani tam poplatek nikam nejde: neexistuje výnosový ú	Peněžní logika	<code>src/store/useApp.ts:252-279</code> <code>(const feeInFrom = convert(TRANSFER_FEE_CZK, 'CZK', from.currency), const debited = amount + feeInFrom, a jediný řádek</code>

Závažnost	Nález	Oblast	Důkaz
Vysoká	Zvýšení `version` bez `migrate` tiše smaže veškerý uložený stav Konfigurace `persist` má `version: 3`, ale žádnou funkci `migrate`. Ověřil jsem chování v `node_modules/zustand/middleware.js`: při neshodě verzí a chybějícím `migrate` se vypíše chyba do konzole a průchod propadne na `return [false, void 0]`, takže `merge(undefined, currentState)` vrátí čistý výchozí stav a ten se přes `set(Sta	Peněžní logika	src/store/useApp.ts:681-687 (`version: 3` bez `migrate`); n ode_modules/zustand/middl eware.js:395-424 (`if (options.migrate) {...}` / `console.error("S
Vysoká	Dvě otevřené karty prohlížeče si stav navzájem přepisují bez varování Souběž uvnitř jedné karty problém není — všechny funkce jsou synchronní (`get()`), kontrola, `set()` bez čekání), takže se dvě volání nemohou proplést. Skutečný souběh je mezi kartami: `persist` zapisuje do localStorage při každém `set`, ale neposlouchá událost `storage`, takže hydratace proběhne jednou při načtení a od té chvíle	Peněžní logika	src/store/useApp.ts:680-687 (konfigurace `persist` bez `onRehydrateStorage` reagujícího na cizí zápis a bez posluchače události `storage`); v celém `s
Vysoká	Identifikátory transakcí jsou z Math.random bez kontroly kolizí `uid()` skládá id z `Math.random().toString(36).slice(2, 10)`. `Math.random` není kryptograficky bezpečný generátor a je predikovatelný; navíc `.slice(2, 10)` u kratšího zápisu vrátí méně než osm znaků, takže délka není konstantní. Nikde se nekontroluje, jestli id už existuje. Stejná funkce se používá i pro id notifikací.	Peněžní logika	src/store/useApp.ts:170 (`const uid = () => 'tx-' + Mat h.random().toString(36).slice (2, 10)`), použito v :177 (`tx()`) a :602 (`id: uid()`) u notifi
Vysoká	Nulové pokrytí testy — neexistuje žádný test ani testovací nástroj V repozitáři není jediný test. Hledání `*.test.*`, `*.spec.*`, `__tests__`, `vitest.config`, `jest.config` a `playwright.config` napříč celým stromem (mimo `node_modules`) nevrátilo nic. V `devDependencies` není žádný test runner, v `package.json` chybí skript `test`. Přitom `src/domain/` a `src/store/useApp.ts` obsahují netriviální finanční logiku:	Dodavatelský řetězec	package.json:6-14 — skripty jsou pouze dev, build, build:secure, deploy:cf, access:sync, preview, typecheck; žádný `test`. package.json:22-28 — devDep
Vysoká	Neexistuje žádná CI — mezi změnou kódu a nasazením není automatická brána Složka `.github` v repozitáři neexistuje a dotaz na GitHub API potvrdil, že v repu není nasazený ani jeden workflow (total_count: 0). Nic tedy automaticky nespustí typecheck, build, npm audit ani kontrolu, že se do commitu nedostal soubor s tajemstvím. Celý řetězec od zdroje k nasazení běží ručně z jednoho vývojářského stroje: npm	Dodavatelský řetězec	Adresář .github neexistuje (ls -la .github → 'no .github dir'). gh api repos/MajkPowa /largoverse-beta/actions/wo rkflows vrací { "total_count": 0, "workfl
Vysoká	Přístupový kód se doslova zapéká do JS bundlu nešifrovaného buildu VITE_ACCESS_CODES je proměnná s prefixem VITE_, kterou Vite při buildu nahrazuje literálem přímo ve zdrojovém kódu. Ověřil jsem to na skutečném výstupu: hodnota z .env.local je v dist/assets/index-hmPcZoc.js přítomna doslova, jako čitelný řetězec. Brána v useApp.ts pak jen porovnává vstup uživatele proti tomuto literálu na stra	Dodavatelský řetězec	src/store/useApp.ts:148 — const ACCESS_CODES = (imp ort.meta.env.VITE_ACCESS_ CODES ?? 'DEMO').split(''); Ověření na buildu: grep -F s hodnotou z .env.
Vysoká	Chybějící VITE_ACCESS_CODES tiše propadne na kód 'DEMO' Pokud proměnná VITE_ACCESS_CODES není nastavena, výraz nepoužije žádnou chybu ani varování, ale operátorem ?? propadne na řetězec 'DEMO'. Build proběhne úspěšně a aplikace se tváří, že je chráněná — brána se zobrazí, kód se vyžaduje, jen ho uhodne kdokoli na první pokus. Kontrast se skriptem build-secure.mjs je názorný: ten chyb	Dodavatelský řetězec	src/store/useApp.ts:148 — (i mport.meta.env.VITE_ACCES S_CODES ?? 'DEMO'). Fallback je v kódu od commitu, který proměnnou zavedl, a přežil i pozdější re
Vysoká	Ruční kroky Cloudflare Access nejsou automatizované ani ověřované — preview URL mohou zůstat nechráněné Skript access:sync nastaví jen seznam povolených e-mailů. Dva kroky, na kterých ochrana skutečně stojí, zůstávají ruční a nikde se nekontrolují: zapnutí Access policy v dashboardu a smazání hvězdičky z pole Public hostname, aby byla chráněná i produkční adresa, ne jen náhledy. README to popisuje jako krok 3 jednorázového nastave	Dodavatelský řetězec	scripts/cloudflare-access.mjs :73-115 nastavuje výhradně Access aplikaci a politiku; nikde nečte ani nenastavuje stav 'Enable Access policy' ani pole P
Střední	Odvozený stav není modelovaný — komponenty se musí ručně přihlašovat k cizím řezům `balanceOf` je definovaný jako akce store, která čte přes `get()`. Selektor `useApp((s) => s.balanceOf)` proto vrací stabilní referenci a komponenta se při změně zůstatku nepřekreslí. Řeší se to tak, že si obrazovky navíc vytáhnou `wallet` a `accounts` jen kvůli přihlášení a pak je umlčí příkazem `void`, aby prošel `noUnusedL	Architektura	src/screens/Exchange.tsx:17 -21 (`const wallet = useApp((s) => s.wallet)` ... `void wallet; void accounts`); src/screens/Crypto.tsx:40-42 a :197; sr

Závažnost	Nález	Oblast	Důkaz
Střední	Model počítá s jedním účtem na měnu; druhý účet ve stejné měně tichý rozbije zůstatky <code>`balanceOf`</code> vrací zůstatek PRVNÍHO účtu s danou měnou, ale zápisové cesty <code>`exchangeAny`</code> i <code>`vaultMove`</code> mapují přes všechny účty a připisují KAŽDÉMU, jehož měna odpovídá. Se seedem (jeden CZK, jeden USD, jeden EUR) se to neprojeví, ale je to nekonzistence mezi čtením a zápisem zabudovaná do modelu.	Architektura	<pre>src/store/useApp.ts:332 `return s.accounts.find((a) => a.currency === currency)?.balance ?? 0` vs :379-381 `accounts.map((acc) => acc.currency =</pre>
Střední	Standardní sazba je zástupné číslo, ale UI ji prezentuje jako platný sazebník V <code>TARIFFS.standard</code> je <code>spread 0,015</code> s komentářem, že jde jen o dočasně převzatou hodnotu z hyperinflační sazby, protože klient vlastní číslo nedodal. Obrazovky Směna a Nákup crypto ale tuto hodnotu zobrazují bez jakéhokoli odlišení jako „Spread: 1,5 %“ vedle věty vysvětlující, proč zrovna tahle sazba platí. Jediný disclaimer na o	Architektura	<pre>src/domain/pricing.ts:44-45 (`// TODO: doplnit spread podle klienta — 0,015 je jen dočasně převzaté.`); src/scre ens/Exchange.tsx:94-101; src/screens/C</pre>
Střední	České řetězce mimo i18n se zobrazí i v anglické a španělské verzi Přestože jsou slovníky v dokonalé paritě (284 klíčů ve všech třech jazycích) a <code>`Dict`</code> chybějící klíče vynutí, část uživatelsky viditelného textu i18n obchází: název transakce při vkladu do Safe Money, titulek a tělo simulované notifikace, všechny čtyři seedové notifikace, zkratky dnů v kalendáři a některé aria-labely.	Architektura	<pre>src/store/useApp.ts:514 `title: cross ? ... : 'Úschova'`, :603-604 (`title: 'Příchozí platba'`, `body: 'Na běžný účet bylo připsáno 2 450,00 CZK.'`);</pre>
Střední	Tokeny nejsou jediné místo pravdy pro vzhled <code>tokens.css</code> se v hlavičce i v <code>README</code> označuje za jediné místo, kde se mění barvy. Ve skutečnosti je v <code>TSX 56</code> literálových barevných hodnot (<code>hex + rgba</code>) proti 97 použitím <code>`var(-----)`</code> , a jsou to i nosné plochy: tmavé pozadí skeneru a selfie, celý <code>AccessGate</code> , pozadí pilulek nad tmavou kartou, dělicí linky.	Architektura	<pre>src/components/ui.tsx:11 `style={dark ? { background: '#1b2427' } : undefined}`; src /screens/Payments.tsx:532 a src/screens/Kyc.tsx:183 (`background:</pre>
Střední	Bez testů, lintu a CI; typecheck nepokrývá build skripty V <code>package.json</code> nejsou žádné testovací ani lintovací skripty a v <code>devDependencies</code> není <code>vitest</code> , jest ani <code>eslint</code> . Doménová vrstva (<code>pricing</code> , <code>inflation</code> , <code>convert</code> , <code>purchasingPowerGap</code>) je přitom čistá a triviálně testovatelná, a <code>store</code> obsahuje peněžní logiku s nezřejmými hranami (<code>spread</code> při výběru ze Safe Money přes <code>`/(1-spread)`</code>), kontrola	Architektura	<pre>package.json:6-28 (skripty d ev/build/build:secure/deplo y:cf/access:sync/preview/ty pecheck, devDependencies bez test a lint nástrojů); tsconfig.json:20</pre>
Střední	Žádná ochrana rout ani error boundary Tabulka <code>rout</code> v <code>App.tsx</code> nemá u žádné cesty pod <code>/app</code> kontrolu, jestli je uživatel přihlášený a ověřený; rozhoduje o tom jen komponenta <code>Entry</code> na cestě „/“. Dokud aplikace běží na <code>MemoryRouteru</code> bez adresního řádku, je to bezpečné, ale ochrana je vlastnost routeru, ne aplikace. Zároveň nikde není <code>error boundary</code> — jakákoli výjimka v o	Architektura	<pre>src/App.tsx:61-74 (routy /app/* bez wrapperu), :84-98 (Entry jako jediný guard), :100-120 (App bez ErrorBoundary)</pre>
Střední	Změna PINu bez ověření a odkrytí čísla karty s ozdobným odpočtem Nový PIN se nastaví libovolnými čtyřmi číslicemi — nezadává se současný PIN, nepotvrzuje se druhým zadáním, nekontrolují se triviální kombinace. Odpočet u zobrazení PINu i u odkrytí čísla karty s CVV je jen text: <code>useCountdown</code> dojde k 00:00 a nic se nestane, odkryté údaje zůstanou na obrazovce, dokud uživatel sám neklepne na „Skr	Funkční rozsah	<pre>C:\Users\Brann\OneDrive\D esktop\alvah Technologies\L argoVerse\src\screens\Cards .tsx:296-307 (useCountdown — hodnota se jen odpočítává), 376-382 (nasta</pre>
Střední	Generovaná karta může kolidovat s jinou a její číslo není zaručeně nevalidní <code>generateCard</code> skládá id jako <code>`card-\${last4}`</code> , kde <code>last4</code> jsou čtyři náhodné číslice — dvě vygenerované karty se stejnou koncovkou dostanou totožné id, sdílejí pak jeden záznam (změna PINu nebo limitu se propíše do obou) a <code>React</code> dostane duplicitní klíč. Číslo karty se skládá náhodně, takže zhruba v desetině případů projde <code>Luhn</code> ovou	Funkční rozsah	<pre>C:\Users\Brann\OneDrive\D esktop\alvah Technologies\L argoVerse\src\store\useApp .ts:545 (last4), 548 (id: `card-\${last4}`), 553 (number), 556 (holder na</pre>
Střední	Platba nemá potvrzení ani druhý faktor a Face ID se nikdy nepoužije <code>pay()</code> se provede rovnou po klepnutí na „Odeslat“ — žádná rekapitulační obrazovka, žádný PIN, žádné biometrické potvrzení, žádný denní limit, žádná kontrola příjemce. Příznak <code>facelid</code> se v <code>KYC</code> nastaví a v celé aplikaci se už nikdy nečte, takže volba „Používat Face ID“ nemá žádný účinek.	Funkční rozsah	<pre>C:\Users\Brann\OneDrive\D esktop\alvah Technologies\L argoVerse\src\store\useApp .ts:216 setFaceId (jediný výskyt kromě inicializace a resetu); odeslání</pre>

Závažnost	Nález	Oblast	Důkaz
Střední	Zahraniční platba zahodí IBAN i SWIFT a neprovede žádnou konverzi Po přepnutí na zahraniční platbu se od uživatele chce IBAN a BIC, ale odeslání použije jen jméno příjemce a částku — hodnoty polí iban a swift se do storu nikdy nedostanou. Částka se odepíše v měně zdrojového účtu bez ohledu na to, do jaké měny by platba mířila, bez poplatku a bez kurzu. Symboly VS/KS/SS skončí slepené jako text	Funkční rozsah	C:\Users\Brann\OneDrive\Desktop\alvah Technologies\LargoVerse\src\screens\Payments.tsx:178-189 (submit používá jen name/target/value/note; proměnné ib
Střední	Žádná validace čísla účtu, IBANu ani duplicitní platby Číslo účtu příjemce je libovolný neprázdný řetězec — neprobíhá kontrola mod-11 podle ČNB ani mod-97 u IBANu, nekontroluje se existence protistrany, formát ani měna cílového účtu. Odeslání stejné platby dvakrát za sebou projde bez varování; není tu žádná idempotence ani detekce duplicity.	Funkční rozsah	C:\Users\Brann\OneDrive\Desktop\alvah Technologies\LargoVerse\src\screens\Payments.tsx:172-173 (recipientFilled = pouhé target.trim() !== "") a store
Střední	Náhled u výběru z úschovy v cizí měně počítá opačně, než co se provede Obrazovka počítá náhled vždy jako $\text{convert}(\text{value}) \times (1 - \text{spread})$ a popisuje ho větou „Do trezoru přijde ...“. Při klepnutí na „Vybrat z úschovy“ ale store použije opačný vzorec $\text{convert}(\text{value}) \div (1 - \text{spread})$, protože klient má na účet dostat přesně zadanou částku. Náhled tedy u výběru ukazuje jiné číslo než skutečný pohyb a k tomu t	Funkční rozsah	C:\Users\Brann\OneDrive\Desktop\alvah Technologies\LargoVerse\src\screens\Crypto.tsx:206 (converted) a 321-328 (text vaultConverts) proti useApp.ts:47
Střední	Standardní spread je zástupná hodnota, ale v UI vypadá jako sazebník pricing.ts má u standardní sazby výslovné TODO: spread 0,015 je jen dočasně převzatý z hyperinflační sazby, protože klient vlastní číslo nedodal. Obě sazby jsou tedy dnes shodné a liší se jen pevným poplatkem. Obrazovky směny a nákupu přesto zobrazují „Spread 1,5 %“ jako konkrétní údaj a rozdíl mezi tarify vysvětlují textem o st	Funkční rozsah	C:\Users\Brann\OneDrive\Desktop\alvah Technologies\LargoVerse\src\domain\pricing.ts:43-45 — hyper a standard mají oba spread 0.015, řádek 44 nese kome
Střední	Přístupová brána je klientská a bez nastaveného env se otevře na kód „DEMO“ Kód se porovnává v prohlížeči proti hodnotě zapečené do balíčku, takže kdokoli si ho z buildu přečte — v kódu i v README je to poctivě napsané a skutečnou ochranou má být šifrovaný build plus Cloudflare Access. Zůstává ale tichý výchozí stav: když se build spustí bez VITE_ACCESS_CODES, brána mlčky přijme kód „DEMO“ místo toho, a	Funkční rozsah	C:\Users\Brann\OneDrive\Desktop\alvah Technologies\LargoVerse\src\store\useApp.ts:148 — (import.meta.env.VITE_ACCESS_CODES ?? 'DEMO')
Střední	Zamčená stránka bez hesla prozrazuje klienta, projekt i jeho logo README slibuje, že „kdo nemá heslo, stáhne si jen náhodná data“. U kódu aplikace to platí, u kontextu ne. Loader v cleartextu nese název LargoVerse, titulék „LargoVerse — uzavřená beta“, větu o pozvaném investorském okruhu, firemní barvy, favicon a hlavně logo se stromem jako base64 PNG — a to hned dvakrát (kvůli `mask` i `-webk	Doručení a ochrana	scripts/build-secure.mjs:140-141 vkládá `__TREE__` do dvou CSS pravidel, ř. 246 `replaceAll('__TREE__', treeB64)`. V deploy/index.html jsou dva base6
Střední	Po odemčení stránka volá Google Fonts, což popírá tvrzení o izolovanosti Loader po úspěšném dešifrování připojí ` <link rel="stylesheet"/> ` na fonts.googleapis.com. Tím vzniká jediný odchozí požadavek celé aplikace — a nastává právě v okamžiku úspěšného odemčení. README přitom hned v úvodu tvrdí, že „aplikace nikam neposílá data“, a build skript se chlubí, že obrázky vkládá inline, „ať nezůstane ni	Doručení a ochrana	scripts/build-secure.mjs:212-215 `fonts.href = 'https://fonts.googleapis.com/css2?family=Outfit...'` uvnitř `then()` po `crypto.subtle.decrypt`. V de
Střední	Šifrovaný build zřejmě nikdy nikam nasazen nebyl Na otázku „jak je LargoVerse doručován dnes“ je poctivá odpověď: podle všech dostupných stop nijak. GitHub Pages u repozitáře nakonfigurované nejsou. Cloudflare cesta také nevypadá použité — wrangler není v závislostech ani v `node_modules/.bin`, neexistuje `wrangler.toml` ani lokální stav `~/wrangler`, který `wrangler login` z	Doručení a ochrana	`gh api repos/MajkPowa/largoverse-beta/pages` → 404 Not Found (přitom `gh repo view` téhož repozitáře funguje, takže nejde o chybějící oprávnění). `~/
Střední	Kdo jednou odemkne, může balíček natrvalo osvobodit od hesla Po dešifrování se aplikace vloží do DOM jako ` <script >`="" `<style="" `textcontent`="" a="" css="" kódem="" plným="" s="" type="module" v="" zdrojovým="">`. Kdokoli s heslem si tedy může v devtools vytáhnout kompletní odemčenou aplikaci a rozdat ji dál bez hesla. To není chyba implementace — je to nevyhnutelný důsledek toho, že dešifrování prob</td><td>Doručení a ochrana</td><td>scripts/build-secure.mjs:217-224: `style.textContent = app.css` a `script.textContent = app.js`, obojí připojeno do dokumentu. Payload je prostý JSON</td></tr></table> Důvěrné — pouze pro uzavřený investorský okruh 42 </script>		

Závažnost	Název	Oblast	Důkaz
Střední	Datum se bere v UTC, zobrazuje se v místním čase — v Caracasu se večerní platby účtují na další den `today()` vrací `new Date().toISOString().slice(0, 10)`, tedy datum v UTC. `shortDate()` naopak parsuje `new Date(ISO + 'T00:00:00')`, což se vyhodnotí v místním pásmu. Venezuela, tedy cílový trh celé ukázky (VES, hyperinflace), je UTC-4: transakce provedená ve 20:00 místního času 16. srpna se uloží s datem 17. srpna. Zároveň se	Peněžní logika	src/store/useApp.ts:169 (`const today = () => new Date().toISOString().slice(0, 10)`) proti src/lib/format.ts:47-49 (`const d = new Date(ISO + 'T00
Střední	Limity karet a stav KYC nebrání žádné peněžní operaci `Card.limits` (merchant, cash, internet) se ukládají a jdou měnit přes `setCardLimit`, ale nikde v kódu se nečtou při žádné operaci, která hýbe penězi — ani `simulateCardCharge` je nekontroluje. Stejně tak `kyc.status` neomezuje `pay`, `transferOwn`, `exchangeAny` ani `vaultMove`: klient se statusem `none` může provést cokoli.	Peněžní logika	src/store/useApp.ts:531-536 (`setCardLimit` zapisuje) — v celém `src` se `limits.` nikde nečte při odespání; src/store/useApp.ts:613-636 (`simulateCar
Střední	Zobrazení zaokrouhuje jinak než úložiště, takže rozdíly nejsou vidět `money()` a `amountOnly()` formátují přes `Intl.NumberFormat` s počtem míst podle měny (VES 0, XSGD a USDT 0-4, ostatní 2), ale uložená hodnota se tím neomezuje. Zůstatek 0,004 USD se zobrazí jako „0,00 USD“, přestože je použitelný — právě tím zůstává skrytá platba pod jeden halíř z předchozího nálezu. Nekonzistence je i uvnitř	Peněžní logika	src/lib/format.ts:5-11 (`DECIMALS`) a :19-27 (`money`); src/store/useApp.ts:259-260 (`round(a.balance + credited)` — výchozích 2 míst) proti :269 (`am
Střední	Mrtvé peněžní funkce s vlastní, odlišnou cenovou logikou a zápisem jen jedné strany `exchangeVesXsgd` a `buyCrypto` nejsou odnikud z UI volané (obrazovka nákupu crypta používá `exchangeAny`). Obě přitom počítají kurz jinou cestou (`exchangeRate()` místo `convert() * (1 - tariff.spread)`), sazebník `tariffFor` vůbec nekonzultují, takže neúčtují žádný pevný poplatek. Navíc obě zapisují do historie jen odepisovano	Peněžní logika	src/store/useApp.ts:286-326 (`exchangeVesXsgd`) a :421-444 (`buyCrypto`) — obě zapisují jediný `tx{... amount: -round(amount, 0), currency: 'VES'}`
Střední	PIN a CVV karet jsou v otevřené podobě v localStorage Karty se ukládají celé, včetně `pin`, `cvv` a plného čísla karty. `partialize` je nevyřazuje, takže sedí v localStorage v čitelné podobě. `setCardPin` zapisuje PIN přímo bez jakéhokoli zpracování. Čísla karet v seedu jsou záměrně nevalidní podle Luhnovy kontroly (což je doložené a správné rozhodnutí), ale `generateCard` vytváří	Peněžní logika	src/domain/seed.ts:60-107 (`cvv: '123'`, `pin: '1234'`); src/store/useApp.ts:529-530 (`setCardPin`); src/store/useApp.ts:686 (`partialize` vyřazuje je
Střední	Simulační akce vytvářejí peníze z ničeho a jsou dostupné z rozhraní `simulateIncoming` připiše 2 450 CZK, `simulateCryptoIn` připiše 250 XSGD — obojí bez protistrany a bez jakéhokoli krytí. Nejsou schované za vývojářský přepínač: jsou vystavené jako tlačítka na obrazovce Profil v běžném sestavení aplikace. Komentář u nich poctivě vysvětluje, že se nikdy nespustí samy, aby prezentující nikdy netv	Peněžní logika	src/store/useApp.ts:581-611 (`simulateIncoming`) a :638-655 (`simulateCryptoIn`); src/screens/Profile.tsx:102-130 (tlačítka `simIncoming`, `simCardCha
Střední	Standardní spread je zástupná hodnota vydávaná za sazebník `TARIFFS.standard.spread` je 0,015, tedy hodnota převzatá z hyperinflační sazby, protože klient pro standardní pásmo vlastní číslo nedodal. Komentář to poctivě přiznává a je u toho TODO — což je správné chování a je dobře, že to není zamlčené. Prakticky to ale znamená, že rozdíl mezi hyperinflační a standardní sazbou je dnes jen	Peněžní logika	src/domain/pricing.ts:42-46 (`hyper: { spread: 0.015, feeCzk: 0 }`, `// TODO: doplnit spread podle klienta — 0,015 je jen dočasně převzaté.`), `standar
Střední	Kurzy jsou zamrzlé konstanty bez data platnosti a bez pojmu kotace `RATES_TO_CZK` je modulová konstanta bez časového razítka, zdroje a expirace. Neexistuje objekt kotace — obrazovka si spočítá zobrazený kurz z konstanty a store si při provedení spočítá kurz znovu z téže konstanty. Dokud je konstanta neměnná, obojí vyjde stejně, takže dnes rozpor nevzniká. Jakmile se kurzy začnou načítat, není k	Peněžní logika	src/domain/types.ts:143-158 (`export const RATES_TO_CZK: Record<Currency, number> = { ... }`); src/screens/Exchange.tsx:30 (`const rate = conver
Střední	Šifrovaná stránka není soběstačná — po dešifrování tahá fonty z Google CDN Skript build-secure.mjs se explicitně snaží, aby venku nežůstalo nic: obrázky převádí na data URI s komentářem 'ať nežůstane nic venku' a výsledek deklaruje jako jediný soubor, ve kterém je celá aplikace zašifrovaná. Jenže zaváděcí stránka po úspěšném dešifrování sama vytvoří <link> na fonts.googleapis.com a vloží ho do hl	Dodavatelský řetězec	scripts/build-secure.mjs:212-215 — `fonts.href = 'https:// fonts.googleapis.com/css2?family=Outfit:...'` a `document.head.appendChild(fonts)`, provedené uv

Závažnost	Nález	Oblast	Důkaz
Střední	Build není reprodukovatelný — npm install místo npm ci, nepřipnutá verze Node, nasazení z 'dirty' stromu Tři nezávislé nedostatky se sčítají do jednoho výsledku: z daného commitu nelze spolehlivě znovu vyrobit tentýž artefakt a k nasazenému artefaktu nelze zpětně dohledat commit. Za prvé, README instruuje npm install, které smí lockfile aktualizovat; všech deset přímých závislostí je zapsáno s caretem, takže na čerstvém stroji spad	Dodavatelský řetězec	README.md:14-16 doporučuje 'npm install'. package.json:15-28 — všech deset závislostí používá rozsah s ^. package.json:10 — 'wrangler pages deploy dep
Střední	Tajemství leží v cleartextu ve složce synchronizované do OneDrive Repozitář je umístěn v C:\Users\Brann\OneDrive\Desktop\alvah Technologies\LargoVerse, tedy uvnitř adresáře, který OneDrive průběžně nahrává do cloudu Microsoftu. Všechny soubory, které .gitignore úspěšně drží mimo git, jsou tímto kanálem synchronizovány: .deploy-passphrase.txt s heslem k šifrovanému investorskému buildu, .env.lo	Dodavatelský řetězec	Absolutní cesta repozitáře obsahuje segment OneDrive. Na disku existují C:\Users\Brann\OneDrive\Desktop\alvah Technologies\LargoVerse\.deploy-passphra
Střední	Ochrana šifrovaného buildu stojí na jediném sdíleném hesle s minimem 8 znaků a možností offline lámání Model hrozby je tady neobvyklý a skript ho sám popisuje: útočník má šifrovaný soubor u sebe, může tedy hesla zkoušet offline, bez jakéhokoli omezení rychlosti a bez toho, aby to kdokoli viděl. Proti tomu stojí PBKDF2-SHA256 s 310 000 iteracemi, což je rozumně zvolený parametr. Vynucené minimum je ale jen 8 alfanumerických znaků,	Dodavatelský řetězec	scripts/build-secure.mjs:36-39 a 49-52 — jediná kontrola je passphrase.length < 8, respektive secret.length < 8 po normalizaci. Normalizace na ř
Nízká	Persist bez migrate funkce; verzování se řeší přejmenováním klíče Store je persistovaný s `version: 3`, ale bez `migrate`. Zůstane v takovém případě jen zalogue chybu a uložený stav zahodí (ověřeno v node_modules/zustand/middleware.js). Autor to obchází tím, že při změně tvaru dat mění i název klíče — komentář na ř. 681-682 to popisuje. Následkem toho v localStorage zůstávají osiřelé klíče př	Architektura	src/store/useApp.ts:680-687 (`name: 'largoverse-beta-3', `version: 3`, žádný `migrate`)
Nízká	Napevno zadrátovaná seedová ID prosakují napříč vrstvami Identifikátory z demo dat nejsou uzavřené v domain/seed.ts. Řetězec 'acc-czk' se objevuje ve store i ve dvou obrazovkách, magická hodnota accountid 'wallet' rozhoduje o tom, kam se transakce zařadí, a výchozí pořadí aktiv (včetně 'vault-VES' a 'vault-CZK') je zapsané doslova dvakrát ve stejném souboru.	Architektura	src/store/useApp.ts:202 a :677 (dvakrát tentýž seznam assetOrder); :587 a :592 ('acc-czk' v simulateIncoming); src/screens/Dashboard.tsx:146 `navigate
Nízká	Datum transakce se bere z hodin prohlížeče a v UTC Každá nová transakce dostane datum z new Date().toISOString().slice(0,10), tedy podle UTC a podle hodin zařízení. V českém letním čase to znamená, že platba zadaná mezi půlnocí a druhou hodinou ranní dostane včerejší datum. Filtry hledání navíc míchají lokálně sestavené datum s převodem do UTC, takže se rozsah může posunout o de	Funkční rozsah	C:\Users\Brann\OneDrive\Desktop\alvah Technologies\LargoVerse\src\store\useApp.ts:169 const today = () => new Date().toISOString().slice(0,10); Tr
Nízká	Peněžní operace hledají účet podle měny, ne podle identifikátoru exchangeAny i vaultMove sice nejdřív najdou účet podle id, ale samotný zápis pak mapuje přes accounts a porovnává acc.currency === c. Kdyby klient měl dva účty ve stejné měně, připsalo by se i odepsalo na obou najednou — tedy dvojnásobek. Dnes to nevybuchne jen proto, že seed má od každé měny právě jeden účet a účty se v aplikac	Funkční rozsah	C:\Users\Brann\OneDrive\Desktop\alvah Technologies\LargoVerse\src\store\useApp.ts:378-381 a 494-497 (accounts.map s podmínkou na currency); balanceOf
Nízká	Dvě mrtvé peněžní akce s vlastní, odlišnou sazbou exchangeVesXsgd a buyCrypto zůstaly ve storu, ale žádná obrazovka je nevolá — nákup XSGD i směna jdou přes exchangeAny. Obě používají druhou cestu k výpočtu kurzu (exchangeRate z types.ts přes VES_XSGD_MID) a neúčtují ani poplatek, ani se neptají tariffFor. Existují tak dvě mírně odlišné definice téhož kurzu, které se dnes shodou	Funkční rozsah	C:\Users\Brann\OneDrive\Desktop\alvah Technologies\LargoVerse\src\store\useApp.ts:286-326 (exchangeVesXsgd) a 421-444 (buyCrypto), bez jediného volají
Nízká	Notifikace a některé názvy pohybů jsou natvrdo česky, částka v textu je napsaná ručně Simulovaná příchozí platba vytvoří notifikaci s pevným českým titulkem a tělem včetně ručně napsané částky '2 450,00 CZK'; při anglické nebo španělské prezentaci se objeví česky. Stejně tak vaultMove ukládá titulek 'Úschova'. Seedované notifikace jsou také jen v češtině. Zbytek aplikace přitom má úplný slovník pro tři jazyky.	Funkční rozsah	C:\Users\Brann\OneDrive\Desktop\alvah Technologies\LargoVerse\src\store\useApp.ts:600-608 (title 'Příchozí platba', body s natvrdo napsanou částkou) a

Závažnost	Nález	Oblast	Důkaz
Nízká	robots.txt a noindex nejsou řízení přístupu Build zapisuje `robots.txt` s `Disallow: /` a loader má meta `noindex, nofollow, noarchive, nosnippet, noimageindex` plus `referrer: no-referrer`. Je správně to mít, ale je to prosba adresovaná slušným vyhledávačům, nikoli bariéra — nezastaví to žádný scanner, archiv ani nikoho, kdo adresu zná. README to naštěstí nikde nevydává	Doručení a ochrana	scripts/build-secure.mjs:256-259 (robots.txt) a ř. 127-128 (meta robots, meta referrer).
Nízká	initialData() kopíruje peněženku mělce, takže seed je z živého stavu dosažitelný `initialData()` používá `structuredClone` na účty, karty, transakce, notifikace, kontakty a příjemce, ale u peněženky jen mělký spread `{ ...seedWallet }`. Vnořený objekt `vaults` tak zůstává sdílený s modulovou konstantou `seedWallet`. Současný kód ho nikdy nemění na místě (`vaultMove` ho vždy nahrazuje novým objektem přes spre	Peněžní logika	src/store/useApp.ts:159-167 (`wallet: { ...seedWallet }` vedle `structuredClone(seedAccounts)` atd.); src/domain/seed.ts:275-280 (`vaults: { VES: 1200
Nízká	Dvě známé zranitelnosti v react-router-dom, žádná automatická kontrola závislostí npm audit hlásí dvě zranitelnosti střední závažnosti v react-router, které se do projektu dostávají přes přímou závislost react-router-dom ^6.28.0: otevřené přespřehování přes zpětné lomítko v <Link> a useNavigate (obejití CVE-2025-68470) a injekce libovolného konstrukturu přes deserializeErrors() při SSR hydrataci. Oprava	Dodavatelský řetězec	npm audit: 'react-router 6.0.0 - 7.17.0, Severity: moderate', GHSA-wrjc-x8rr-h8h6 a GHSA-337j-9hxr-rhxg, závislost node_modules/react-router-dom dekla
Informativní	Brána v prohlížeči je jen dekorace — což kód přiznává, ale hodí se to pojmenovat Vnitřní AccessGate porovnává zadaný kód proti hodnotám z VITE_ACCESS_CODES, které se při buildu vloží do bundlu. Kdokoli si stáhne nešifrovaný build, kód si v něm přečte. Kód sám na to upozorňuje v komentáři a README to opakuje; skutečná ochrana stojí na šifrovaném buildu (AES-GCM 256, PBKDF2-SHA256 310 000 iterací) a nad ním na	Architektura	src/store/useApp.ts:132-151 (`ACCESS_CODES` z import.meta.env + komentář „tahle brána je jen v prohlížeči“); normalizace duplicitně v src/store/useApp
Informativní	Inflační snímek je zmrazený a nikde se nekontroluje jeho stáří INFLATION a XSGD_ANCHOR jsou ručně zapsané hodnoty s obdobím a zdrojem. UI období poctivě zobrazuje, ale nic nehlídá, jestli údaj nezastaral — za dva roky se stejná obrazovka pochlubí rozdilem kupní síly spočítaným z čísel označených 7/2026, aniž by uživatele varovala. Zdrojová čísla jsou přitom jádrem celého sdělení o úschově.	Funkční rozsah	C:\Users\Brann\OneDrive\Desktop\alvah Technologies\LargoVerse\src\domain\inflation.ts:37-52 (INFLATION jako konstanta) a Crypto.tsx:283-295 (zobrazení
Informativní	Chybí celý životní cyklus bankovní transakce Každý pohyb je okamžitě konečný. Není tu blokace a následné zúčtování u karetní platby, není stav „čeká na zpracování“, nejde platbu odvolat, stornovat ani reklamovat, neexistuje trvalý příkaz ani inkaso (šablony jen předvyplní formulář), není debet ani kontokorent, nevznikají žádné poplatky za vedení a neexistuje protistrana —	Funkční rozsah	C:\Users\Brann\OneDrive\Desktop\alvah Technologies\LargoVerse\src\domain\types.ts:95-109 (Tx nemá stav ani protistranu, jen částku, měnu a datum)
Informativní	Kryptografická část je provedena správně Aby byl obrázek úplný: samotné šifrování nemá vadu. Sůl je 16 náhodných bajtů a IV 12 náhodných bajtů z CSPRNG, generují se čerstvě při každém buildu (žádné opakování IV mezi nasazeními), šifra je AES-GCM-256 s autentizací, klíč se odvozuje PBKDF2-SHA256 se 310 000 iteracemi, je označen jako neexportovatelný (`extractable: false	Doručení a ochrana	scripts/build-secure.mjs:103-116 (getRandomValues pro sůl i IV, deriveKey s extractable=false, encrypt AES-GCM). Kontrola nasazeného souboru: `grep -o
Informativní	Git historie je čistá a repozitář je privátní Ověřeno, že heslo nikdy neproniklo do verzování a že zdrojový kód není veřejný. Do gitu se za celou historii nikdy nedostal `.env.local`, `.deploy-passphrase.txt`, `access-emails.txt` ani `docs/` — přidány byly jen jejich `.example` protějšky. Repozitář `MajkPowa/largoverse-beta` je označen jako PRIVATE, což je dnes fakticky jed	Doručení a ochrana	`git log --all -S "LARGO-HETN" --oneline` → prázdné; procházení všech commitů přes `git grep -l "HETN"` → žádný zásah; `git log --all --diff-filter=A
Informativní	Žádné testy peněžní logiky V repozitáři není žádný testovací běh ani jediný testovací soubor — `package.json` nemá skript `test` ani testovací závislost. Veškerá peněžní matematika (zaokrouhlování, sazebník, směna, trezor, převody) je neověřená a všechny výše uvedené číselné nálezy jsem musel dopočítat ručně mimo projekt.	Peněžní logika	package.json — skripty jsou pouze dev, build, build:secure, deploy:cf, access:sync, preview, typecheck; hledání `*.test.*` mimo node_modules nevrátilo

Závažnost	Nález	Oblast	Důkaz
Informativní	Nic citlivého se do gitu nikdy nedostalo — potvrzeno skenem celé historie Tohle je pozitivní zjištění, které explicitně uvádím, protože bylo součástí zadání. Prošel jsem obsah všech commitů napříč všemi referencemi a seznam všech souborů, které kdy byly do repozitáře přidány. Žádná hodnota hesla, přístupového kódu, API tokenu, privátního klíče ani JWT se v historii nevyskytuje; jediné shody na vzory j	Dodavatelský řetězec	<pre>git log --all --diff-filter=A --name-only</pre> vrací 51 souborů, mezi nimiž žádný z citlivých není (jen .env.example a access-emails.example.txt). git grep
Informativní	Rozdělení veřejný/privátní je v pořádku — zdroj je celý v privátním repu Zadání se ptalo na rozdělení repozitářů. Skutečný stav: žádné rozdělení neexistuje, protože existuje jediný repozitář MajkPowa/largoverse-beta a ten je privátní. Veřejně dostupný je pouze nasazený artefakt — jeden šifrovaný soubor na Cloudflare Pages, ideálně za Cloudflare Access. Zdrojový kód, skripty ani konfigurace nejsou nik	Dodavatelský řetězec	<pre>gh repo view MajkPowa/largoverse-beta</pre> vrací isPrivate: true, visibility: PRIVATE, defaultBranchRef: main. git branch -a ukazuje pouze main a remotes/o

Příloha B — úplný seznam požadavků cílového stavu

Všech 130 požadavků. Sloupec „Zdroj“ uvádí normu nebo nařízení včetně článku; úplné odkazy jsou v datové příloze auditu.

Závaznost	Požadavek	Vrstva	Zdroj
Právní povinnost	Silné ověření klienta: dva prvky ze tří nezávislých kategorií Přihlášení k účtu i iniciace platby musí vyžadovat dva prvky z různých kategorií — znalost (PIN/heslo), vlastnictví (vázaná instance aplikace, SIM, hardwarový klíč) a inherence (biometrie). Implementačně: klient nikdy nesmí sám rozhodovat o úspěchu SCA. Klientská část jen shromáždí důkazy a nechá au	Klientská vrstva	Commission Delegated Regulation (EU) 2018/389, čl. 4(1) a čl. 9(1) (nezávislost prvků); PSD2 (EU) 2015/2366 čl. 97
Právní povinnost	Dynamic linking — autentizační kód vázaný na částku a příjemce Autentizační kód musí být kryptograficky specifický pro konkrétní částku a konkrétního příjemce; jakákoli změna kteréhokoli z nich kód zneplatní. Implementačně: potvrzovací obrazovka musí zobrazit částku a příjemce (nebo jejich zkrácený tvar) tak, jak je do podpisu vstupují — tedy z dat přijatých ze	Klientská vrstva	Commission Delegated Regulation (EU) 2018/389, čl. 5(1) a 5(2)
Právní povinnost	Ochrana při běhu na víceúčelovém zařízení: oddělené prostředí, kontrola integrity, mitigace Právně nejdůležitější a nejčastěji přehlížené ustanovení pro klienta. Pokud se prvky SCA používají na víceúčelovém zařízení (běžný mobil), poskytovatel MUSÍ přijmout: (a) oddělená bezpečná prováděcí prostředí — v praxi TEE/StrongBox na Androidu, Secure Enclave a Keychain s ACL na iOS; (b) mechanismy	Klientská vrstva	Commission Delegated Regulation (EU) 2018/389, čl. 9(3)(a)–(c)
Právní povinnost	Timeout relace: max. 5 minut nečinnosti pro přístup k účtu Maximální doba bez aktivity plátce po autentizaci pro online přístup k platebnímu účtu nesmí překročit 5 minut. Implementačně: timeout musí být vynucen SERVEREM (invalidace session tokenu), klientský odpočet je pouze UX doplněk. Klient posílá keep-alive jen na skutečnou uživatelskou interakci, ne na	Klientská vrstva	Commission Delegated Regulation (EU) 2018/389, čl. 4(3)(d)
Právní povinnost	Limit neúspěšných pokusů o autentizaci: max. 5 Nejvýše pět po sobě jdoucích neúspěšných pokusů, pak dočasné nebo trvalé zablokování. Implementačně: čítač je autoritativně na serveru a je vázaný na uživatele/zařízení, ne na instanci aplikace (jinak stačí reinstalace nebo smazání app dat). Pokud aplikace umožňuje offline ověření lokálního PINu pro	Klientská vrstva	Commission Delegated Regulation (EU) 2018/389, čl. 4(3)(b) a čl. 4(3)(c); PSD2 čl. 97(1)
Právní povinnost	Device binding — vázání instance aplikace na zařízení jako důkaz vlastnictví Mobilní aplikace je platným prvkem 'vlastnictví' pouze tehdy, je-li chráněna mechanismem device bindingu, který jednoznačně váže instanci aplikace na konkrétní zařízení. Implementačně: při onboarding vygenerovat asymetrický klíčový pár uvnitř hardwarového úložiště, non-exportable (Android: KeyGenPa	Klientská vrstva	EBA Opinion on the elements of strong customer authentication under PSD2 (EBA-Op-2019-06, 21. 6. 2019), odst. 26 a příloha; RTS čl
Právní povinnost	Ochrana prvku vlastnictví proti replikaci Prvky kategorie vlastnictví musí být chráněny opatřeními proti replikaci. Implementačně: privátní klíče musí být negenerovatelné a nevyexportovatelné mimo TEE/StrongBox/Secure Enclave (nikdy ne klíč v SharedPreferences, souboru, ani v Keychainu jako holá data). Detekce spuštění v emulátoru, na klonu	Klientská vrstva	Commission Delegated Regulation (EU) 2018/389, čl. 7(1) a 7(2)
Právní povinnost	Prvek znalosti (PIN/heslo): maskování, žádné ukládání v otevřeném podobě Opatření proti vyzrazení znalostního prvku. Implementačně: PIN/heslo se v UI maskuje, nikdy se neloguje, nekopíruje do clipboardu, nezachycuje se do crash reportů ani analytiky. Vypnout keyboard cache u polí (Android: inputType textNoSuggestions textPassword; iOS: isSecureTextEntry = true, textCon	Klientská vrstva	Commission Delegated Regulation (EU) 2018/389, čl. 6 a čl. 22(2)–(4)

Závaznost	Požadavek	Vrstva	Zdroj
Právní povinnost	Biometrie jako prvek inherence: kryptografická vazba, ne UI brána Biometrická zařízení a software musí mít velmi nízkou pravděpodobnost autentizace neoprávněné osoby a musí odolávat neoprávněnému použití. Implementačně: NIKDY nespolehat na výsledek callbacku ('onAuthenticationSucceeded'), ten je jen UI a dá se přeskočit hookováním (Frida). Android: BiometricPrompt	Klientská vrstva	Commission Delegated Regulation (EU) 2018/389, čl. 8(1) a 8(2)
Právní povinnost	Ochrana autentizačních údajů: nikdy v otevřeném textu, maskování při zobrazení Personalizované bezpečnostní údaje se maskují při zobrazení, neukládají se v otevřeném textu a tajný kryptografický materiál je chráněn před vyzrazením. Implementačně na klientovi: žádné tokeny, PINy ani klíče v SharedPreferences/NSUserDefaults/plist/SQLite bez šifrování, žádné hardcoded klíče ve zd	Klientská vrstva	Commission Delegated Regulation (EU) 2018/389, čl. 22
Právní povinnost	Detekce rootu a jailbreaku s vrstvenou reakcí Aplikace musí ověřovat integritu platformy. Implementačně vrstvit několik nezávislých signálů, protože jednotlivé jsou obcházitelné: Android — přítomnost su/busybox/Magisk cest, kontrola ro.debuggable a ro.secure, test zápisu do /system, detekce Magisk Hide/Zygisk artefaktů, SELinux enforcing, a hla	Klientská vrstva	Commission Delegated Regulation (EU) 2018/389, čl. 9(3)
Právní povinnost	Ochrana proti manipulaci s aplikací (anti-tampering) a vzdálená atestace Ověřování, že binárka nebyla pozměněna a že běží pravá instance. Implementačně: (a) runtime kontrola podpisového certifikátu APK (PackageManager GET_SIGNING_CERTIFICATES) / provisioning profilu a embedded.mobileprovision na iOS, ideálně z nativního kódu, ne z Javy/Kotlinu; (b) kontrola instalačního	Klientská vrstva	Commission Delegated Regulation (EU) 2018/389, čl. 9(3)(b)
Právní povinnost	TLS konfigurace: TLS 1.3/1.2, silné šifry, žádný cleartext Veškerá komunikace přes TLS 1.2+ (preferovat 1.3), pouze AEAD šifry s forward secrecy, žádné fallbacky na starší verze. Implementačně: zakázat HTTP úplně (Android manifest usesCleartextTraffic="false" + Network Security Config; iOS ATS bez výjimek). Ověřovat hostname a řetěz — nikdy nepřepisovat Tru	Klientská vrstva	OWASP MASVS-NETWORK-1
Právní povinnost	Správa relací na webu: bezpečné cookies, rotace, centrální revokace Podle ASVS 5.0 kap. 7. Implementačně: session token generovaný CSPRNG s min. 128 bity entropie, uložený v cookie s HttpOnly, Secure, SameSite=Strict (nebo Lax + anti-CSRF token), Path a __Host- prefixem. Regenerace ID při každé změně úrovně oprávnění (po přihlášení, po SCA step-up). Absolutní i idle	Klientská vrstva	OWASP ASVS 5.0.0 kap. 7 (Session Management)
Právní povinnost	Inventarizace, autorizace a monitoring skriptů na platebních stránkách (PCI DSS) Pokud web zpracovává data platebních karet: požadavek 6.4.3 vyžaduje udržovat inventář VŠECH skriptů načítaných na platební stránce, každý mít písemně odůvodněný a autorizovaný, a zajistit kontrolu integrity (SRI, CSP s hashi, nebo dedikovaný client-side monitoring). Požadavek 11.6.1 vyžaduje mechan	Klientská vrstva	PCI DSS v4.0.1, požadavky 6.4.3 a 11.6.1
Právní povinnost	Řízení zranitelností komponent třetích stran a SBOM Aplikace smí používat pouze komponenty bez známých zranitelností. Implementačně: SCA sken (OWASP Dependency-Check, Snyk, Trivy) v CI na každý build, blokující policy pro kritické CVE, generování SBOM (CycloneDX / SPDX) pro každé vydání a jeho uchování. Zvláštní pozor na mobilní SDK třetích stran (an	Klientská vrstva	OWASP MASVS-CODE-3
Právní povinnost	Logování bezpečnostních událostí z klienta a napojení na fraud engine Klient musí hlásit serveru bezpečnostně relevantní události: detekce rootu/jailbreaku, selhání atestace, detekce hookovacího frameworku, aktivní screen recording, neznámá accessibility služba, změna biometrického zápisu, reinstalace, změna zařízení. Server tyto signály vyhodnocuje spolu s transakční	Klientská vrstva	Commission Delegated Regulation (EU) 2018/389, čl. 2 (monitorovací mechanismy) a čl. 18

Závaznost	Požadavek	Vrstva	Zdroj
Právní povinnost	Vztah k uživateli: komunikace o bezpečnosti, blokace a incidentech Zúžené EBA Guidelines (EBA/GL/2025/02, účinné od 20. 5. 2025) po aplikaci DORA nechávají PSP povinnosti právě v oblasti vztahu s uživateli platebních služeb. Implementačně na klientovi: bezpečný kanál pro upozornění na rizikové události (nové zařízení, změna limitu, neúspěšné pokusy), možnost okamži	Klientská vrstva	EBA/GL/2025/02 — Guidelines amending EBA/GL/2019/04 on ICT and security risk management (účinné od 20. 5. 2025)
Právní povinnost	Dokumentovaný rámec řízení ICT rizik s ročním přezkumem Backend nesmí existovat bez písemného rámce: strategie, politiky, procedury, protokoly a nástroje pro ICT riziko. Implementačně to znamená verzovaný soubor politik v repozitáři (security policy, crypto policy, logging policy, BCP/DR plán, incident response playbooks), roční revize (a mimořádná po ka	Backend a platforma	Nařízení (EU) 2022/2554 (DORA), čl. 6 odst. 1–5 a 8
Právní povinnost	Odpovědnost statutárního orgánu za ICT riziko Vedení nese konečnou odpovědnost — nelze ji delegovat na CTO. Implementačně: schválené a datované rozhodnutí orgánu o ICT strategii a rizikovém apetitu, jmenná odpovědnost za role, pravidelné školení členů vedení k ICT riziku, a reporting ICT rizik na úroveň představenstva s doložitelnou frekvencí.	Backend a platforma	Nařízení (EU) 2022/2554 (DORA), čl. 5
Právní povinnost	Šifrování dat v klidu, při přenosu a v použití + kryptografická politika Povinná dokumentovaná kryptografická politika s klasifikací dat, seznamem schválených algoritmů a délek klíčů a s procesem jejich revize (včetně sledování post-quantového vývoje). Implementačně: TLS 1.3 na všech externích i interních hranicích, šifrování databází a záloh, šifrování zůstatků a osobní	Backend a platforma	Delegované nařízení (EU) 2024/1774, čl. 6 (Encryption and cryptographic controls)
Právní povinnost	Správa kryptografických klíčů v HSM nebo cloud KMS s certifikací FIPS 140-3 Klíče musí mít definovaný celý životní cyklus — generování, distribuce, uložení, obnova, zálohování, archivace, revokace, zničení — a nesmí být uloženy vedle šifrovaných dat. Implementačně: root a KEK klíče v HSM nebo managed KMS (AWS KMS/CloudHSM, Azure Managed HSM, GCP Cloud KMS) s validací FIPS 1	Backend a platforma	Delegované nařízení (EU) 2024/1774, čl. 7 (Cryptographic key management)
Právní povinnost	Rotace klíčů a tajemství s definovanou kryptoperiodou Každý typ klíče a tajemství musí mít písemně stanovenou kryptoperiodu a automatizovanou rotaci. Praktické hodnoty podle NIST SP 800-57 Part 1 Rev. 5: symetrické datové klíče ≤ 2 roky, KEK ≤ 2 roky originator-usage, TLS certifikáty krátkodobé (ideálně automatizované ACME), aplikační tajemství (DB hes	Backend a platforma	Delegované nařízení (EU) 2024/1774, čl. 7 odst. 2 a 4
Právní povinnost	Zero trust: silná autentizace, least privilege a per-request autorizace Žádný request není důvěryhodný jen proto, že přišel z vnitřní sítě. Implementačně: mTLS mezi službami, krátkodobé tokeny s úzkým scope, autorizace na úrovni každého volání (ne jen na gateway), MFA povinně pro všechny administrativní a vzdálené přístupy, privileged access management s just-in-time es	Backend a platforma	Delegované nařízení (EU) 2024/1774, čl. 20 (Identity management) a čl. 21 (Access control)
Právní povinnost	Segmentace sítě a izolace kritických komponent Síť musí být rozdělena podle kritičnosti a klasifikace dat s explicitními pravidly toku. Implementačně: oddělené VPC/subnety pro edge, aplikační vrstvu, ledger/databázi a management, default-deny egress, service mesh s mTLS a autorizačními politikami, ledger databáze bez přímé konektivity z internet	Backend a platforma	Delegované nařízení (EU) 2024/1774, čl. 13 (Network security management) a čl. 14 (Securing information in transit)
Právní povinnost	Nezměnitelný audit trail s ochranou proti manipulaci Logy musí zachytit kdo, kdy, co, odkud a s jakým výsledkem — u peněžních operací včetně předchozího a nového stavu. Implementačně: append-only ukládání s WORM/object-lock retencí, oddělený účet nebo tenant pro logy (kompromitace aplikace nesmí umožnit smazání logů), hash chain nebo podepisování dáve	Backend a platforma	Delegované nařízení (EU) 2024/1774, čl. 12 (Logging)

Závaznost	Požadavek	Vrstva	Zdroj
Právní povinnost	Retence záznamů o transakcích minimálně 5 let Transakční a KYC záznamy se uchovávají 5 let od ukončení obchodního vztahu nebo od jednorázové transakce. Implementačně: retenční politika na úrovni ledgeru i logů, oddělený archivní storage s neměnností, a zároveň mechanismus mazání po uplynutí lhůty (GDPR minimalizace — retence není licence na věč	Backend a platforma	Směrnice (EU) 2015/849 (AMLD), čl. 40
Právní povinnost	Detekce anomálií, alerting a SIEM s vícevrstvou kontrolou DORA požaduje mechanismy umožňující 'multiple layers of control', definované prahové hodnoty pro alerty a automatické notifikace týmu incident response. Implementačně: centrální SIEM sbírající logy z aplikace, databáze, KMS, cloud audit logu, WAF a identity provideru; detekční pravidla na neúspěšné	Backend a platforma	Nařízení (EU) 2022/2554 (DORA), čl. 10 odst. 1–3
Právní povinnost	Klasifikace a hlášení závažných ICT incidentů (4h / 72h / 1 měsíc) Nutný je zdokumentovaný proces správy incidentů s klasifikačními kritérii (počet zasažených klientů, doba výpadku, geografický rozsah, ztráta dat, dopad na kritické funkce, ekonomický dopad). Implementačně: incident tracker s časovými razítky, předpřipravené reportovací šablony pro ČNB, jasně určená	Backend a platforma	Nařízení (EU) 2022/2554 (DORA), čl. 17–19
Právní povinnost	Program testování digitální provozní odolnosti (min. ročně) Všechny ICT systémy podporující kritické nebo důležité funkce se testují nejméně jednou ročně. Implementačně: SAST/DAST a SCA v CI pipeline, pravidelný vulnerability scanning s SLA na patchování podle závažnosti, penetrační testy, scénářové testy (výpadek zóny, ztráta databáze, kompromitace klíče),	Backend a platforma	Nařízení (EU) 2022/2554 (DORA), čl. 24–25
Právní povinnost	Threat-Led Penetration Testing (TLPT) jednou za 3 roky Týká se pouze entit, které dohledový orgán označí jako významné (typicky systémově významné banky, platební instituce, CSD, CCP — menší instituce a startupy zpravidla ne). Implementačně: red team test na produkčním prostředí, threat intelligence od nezávislého poskytovatele, oddělení red/blue/white	Backend a platforma	Nařízení (EU) 2022/2554 (DORA), čl. 26–27
Právní povinnost	Politika záloh, testované obnovení a definované RTO/RPO Rozsah a minimální frekvence záloh se určuje podle kritičnosti a důvěrnosti dat; pro každou kritickou funkci se stanoví RTO a RPO na základě business impact analýzy. Implementačně: PITR pro ledger databázi (RPO řádově minuty, u peněžního systému ideálně nula ztracených potvrzených transakcí), zálohy	Backend a platforma	Nařízení (EU) 2022/2554 (DORA), čl. 11 (ICT business continuity) a čl. 12 (Backup, restoration and recovery)
Právní povinnost	Oddělení prostředí dev / test / produkce Vývojové, testovací a produkční prostředí musí být oddělené sítí, identitami i daty. Implementačně: samostatné cloud účty nebo projekty, žádné sdílené credentials napříč prostředím, žádná produkční data v testu (jen syntetická nebo ireverzibilně anonymizovaná — u plateb typicky generované IBANy a f	Backend a platforma	Delegované nařízení (EU) 2024/1774, čl. 16 (ICT systems acquisition, development and maintenance)
Právní povinnost	Řízení change management s možností rollbacku Každá změna produkce musí mít schválení, testování, plán návratu a záznam. Implementačně: povinný code review a minimálně čtyřroční princip u změn dotýkajících se peněžní logiky, immutable build artefakty, podepsané image a SBOM, IaC místo ručních zásahů, oddělený emergency change proces s dodatečným	Backend a platforma	Delegované nařízení (EU) 2024/1774, čl. 17 (ICT change management)
Právní povinnost	Řízení rizik ICT třetích stran, registr informací a exit strategie Každý dodavatel ICT služeb (cloud, KYC provider, platební brána, on/off-ramp, custody, monitoring) musí být v registru informací ve formátu předepsaném prováděcím nařízením a hlášen dohledu. Smlouvy musí obsahovat povinná ustanovení podle čl. 30 — přístup a audit, lokace dat, součinnost při incident	Backend a platforma	Nařízení (EU) 2022/2554 (DORA), čl. 28–30
Právní povinnost	Vztah k NIS2 a doplňkové povinnosti Pro finanční entity uvedené v čl. 2 odst. 1 DORA má DORA přednost jako lex specialis v oblastech řízení ICT rizik, hlášení incidentů a testování odolnosti — tyto povinnosti se neplní podle NIS2 duplicitně. NIS2 (a její česká transpozice, zákon o kybernetické bezpečnosti) však může dopadat na oblasti	Backend a platforma	Nařízení (EU) 2022/2554 (DORA), čl. 1 odst. 2

Závaznost	Požadavek	Vrstva	Zdroj
Právní povinnost	Bezpečnost zpracování osobních údajů podle GDPR Běží paralelně s DORA a nelze ji nahradit. Implementačně: šifrování a pseudonymizace, schopnost obnovit dostupnost dat (překrývá se s DORA čl. 12), pravidelné testování účinnosti opatření, záznamy o činnostech zpracování, DPIA u rizikového zpracování (skóring, profilování klientů), a ohlašovací povi	Backend a platforma	Nařízení (EU) 2016/679 (GDPR), čl. 32 (bezpečnost zpracování) a čl. 33 (ohlašování)
Právní povinnost	On-chain screening protistran a sankční kontrola (Chainalysis / Elliptic / TRM) Integrace blockchain analytics do transakčního toku, nikoli jen do reportingu: (1) pre-transaction screening každé cílové adresy před odesláním a každé zdrojové adresy před připsáním (real-time API), s automatickým zablokováním při sankčním zásahu a s eskalací při vysokém risk skóre; (2) průběžný re	Blockchainová vrstva	Chainalysis, What Is the Travel Rule / compliance glossary
Právní povinnost	Travel rule podle TFR (EU) 2023/1113 a ověřování self-hosted adres Od 30. 12. 2024 musí u převodů krypto-aktiv doprovázet transakci údaje o původci a příjemci — v EU bez jakéhokoli minimálního prahu (nejpřísnější implementace na světě). Implementačně: (1) napojení na travel rule protokol (TRP, Notabene, Sygna, Openpayd apod.) pro výměnu dat mezi CASPy; (2) rozlišen	Blockchainová vrstva	Nařízení (EU) 2023/1113 (recast TFR), použitelné od 30. 12. 2024 — přehled: https://cryptoslate.com/crypto-laws/eu-transfer-of-fun
Právní povinnost	MiCA čl. 75: custody policy, segregace a odpovědnost za ztrátu Pokud aplikace drží krypto-aktiva klientů (byť jen dočasně), jde o službu úschovy a správy podle MiCA. Povinné prvky: písemná custody policy s interními pravidly a postupy zajišťujícími bezpečné uložení a kontrolu aktiv; smlouva s klientem; registr pozic vedený pro každého klienta; postup pro vrácen	Blockchainová vrstva	Nařízení (EU) 2023/1114 (MiCA), čl. 75 — Custody and administration of crypto-assets on behalf of clients
Právní povinnost	DORA: ICT risk management, testování a hlášení incidentů DORA je účinná od 17. 1. 2025 a vztahuje se i na poskytovatele služeb krypto-aktiv. Implementačně: (1) formální rámec řízení ICT rizik s odpovědností vedení; (2) klasifikace a hlášení závažných ICT incidentů příslušnému orgánu v předepsaných lhůtách (initial / intermediate / final report) — což zahr	Blockchainová vrstva	Nařízení (EU) 2022/2554 (DORA), zejména čl. 24–27 (testování) a čl. 26 (TLPT); přehled požadavků
Právní povinnost	Právní přípustnost XSGD a USDT v EU (blokátor nad technickou vrstvou) Nezávisle na kvalitě blockchainové bezpečnosti platí, že XSGD ani USDT nejsou v EU autorizované e-money tokeny podle MiCA — autorizace mají v EU zejména USDC a EURC. Podle MiCA smí být EMT v EU veřejně nabízen nebo přijat k obchodování jen tehdy, je-li jeho emitent autorizovanou úvěrovou nebo elektr	Blockchainová vrstva	Nařízení (EU) 2023/1114 (MiCA), Hlava IV (e-money tokeny), čl. 48–50 a Hlava V; přehled povinností CASP
Právní povinnost	Autorizace CASP podle MiCA a passportování Bez autorizace jako CASP nelze v EU poskytovat žádnou z regulovaných služeb (úschova a správa kryptoaktiv, směna kryptoaktiv za peněžní prostředky nebo jiná kryptoaktiva, provoz obchodní platformy, přijímání a předávání pokynů, provádění pokynů, poradenství, správa portfolia, převodní služby). Imple	Regulace a compliance	Nařízení (EU) 2023/1114 (MiCA), čl. 59, 60, 61, 62, 65
Právní povinnost	Kapitálové požadavky CASP (obezřetnostní záruky) CASP musí trvale držet obezřetnostní záruky ve výši vyšší z: (a) fixní minimální částky podle Přílohy IV — třída 1: 50 000 EUR (poradenství, správa portfolia, přijímání a předávání pokynů, převodní služby), třída 2: 125 000 EUR (úschova a správa, směna, provádění pokynů, umisťování), třída 3: 150 00	Regulace a compliance	Nařízení (EU) 2023/1114 (MiCA), čl. 67 a Příloha IV
Právní povinnost	Ochrana klientských kryptoaktiv a peněžních prostředků (obecná povinnost) CASP držící kryptoaktiva klientů musí učinit odpovídající opatření k ochraně vlastnických práv klientů, zejména pro případ vlastní insolvence. Peněžní prostředky klientů (jiné než EMT) musí být uloženy u úvěrové instituce nebo centrální banky nejpozději do konce pracovního dne následujícího po dni p	Regulace a compliance	Nařízení (EU) 2023/1114 (MiCA), čl. 70

Závaznost	Požadavek	Vrstva	Zdroj
Právní povinnost	Úschova a správa kryptoaktiv jménem klientů — provozní režim podle čl. 75 Konkrétní implementační povinnosti: (1) uzavřít s klientem smlouvu vymezující povinnosti stran, (2) zavést a udržovat custody policy s vnitřními pravidly a postupy pro bezpečné uložení či kontrolu kryptoaktiv a prostředků přístupu (klíčů); na žádost klienta ji poskytnout, (3) vést registr pozic otev	Regulace a compliance	Nařízení (EU) 2023/1114 (MiCA), čl. 75
Právní povinnost	Zákaz úročení e-money tokenů (MiCA čl. 50) Vydavatelé EMT nesmějí poskytovat úrok ve vztahu k EMT. Stejný zákaz se vztahuje na CASP při poskytování služeb souvisejících s EMT. Za úrok se považuje jakákoli odměna nebo jiná výhoda vázaná na dobu, po kterou držitel EMT drží — včetně čisté kompenzace či slev s účinkem rovnocenným úroku, ať už př	Regulace a compliance	Nařízení (EU) 2023/1114 (MiCA), čl. 50
Právní povinnost	Marketingová sdělení k e-money tokenům (MiCA čl. 53) Marketingová sdělení k nabídce EMT nebo jeho přijetí k obchodování musí: (a) být jasně identifikovatelná jako marketingové sdělení, (b) obsahovat informace, které jsou nestranné, jasné a nezavádějící, (c) být v souladu s obsahem white paperu, (d) jasně uvádět, že white paper byl zveřejněn, včetně ad	Regulace a compliance	Nařízení (EU) 2023/1114 (MiCA), čl. 53 (a čl. 66(4) pro CASP)
Právní povinnost	Vydavatel EMT musí být úvěrová instituce nebo EMI; white paper a notifikace EMT smí v EU veřejně nabízet nebo žádat o přijetí k obchodování pouze subjekt autorizovaný jako úvěrová instituce nebo jako instituce elektronických peněz podle směrnice 2009/110/ES. Vydavatel musí nejméně 40 pracovních dnů před nabídkou oznámit záměr příslušnému orgánu, vypracovat white paper podle	Regulace a compliance	Nařízení (EU) 2023/1114 (MiCA), čl. 48, 51 a Příloha III
Právní povinnost	Právo na odkup EMT v nominální hodnotě a rezervní prostředky Držitel EMT má vůči vydavateli nárok na odkup kdykoli a v nominální hodnotě (par value) měny, na kterou je token navázán. Odkup nesmí být podmíněn, poplatek smí odpovídat pouze nákladům na provedení a musí být předem transparentně uveden. Prostředky přijaté výměnou za EMT musí být chráněny podle čl.	Regulace a compliance	Nařízení (EU) 2023/1114 (MiCA), čl. 49 a čl. 54 ve spojení s čl. 7 směrnice 2009/110/ES
Právní povinnost	Ozdravný a odkupní plán vydavatele EMT Vydavatel EMT musí vypracovat ozdravný plán (recovery plan) a odkupní plán (redemption plan) zajišťující řádný odkup tokenů v případě, že příslušný orgán posoudí vydavatele jako neschopného nebo pravděpodobně neschopného plnit své povinnosti. Plány se předkládají příslušnému orgánu do šesti měsíců o	Regulace a compliance	Nařízení (EU) 2023/1114 (MiCA), čl. 55 ve spojení s Hlavou III kapitolou 6 (čl. 46, 47); EBA Final report on Guidelines on redempt
Právní povinnost	Klasifikace významného EMT a přesun dohledu na EBA EMT je klasifikován jako významný, pokud splní alespoň tři z kritérií čl. 43(1) aplikovaných podle čl. 56 — mj. více než 1 milion držitelů, hodnota emise/rezervních aktiv nad 1 mld. EUR, průměrně více než 500 000 transakcí denně nebo denní objem nad 100 mil. EUR, propojenost s finančním systémem, me	Regulace a compliance	Nařízení (EU) 2023/1114 (MiCA), čl. 56, 43, 58
Právní povinnost	Souběžná licence PSD2 pro úschovu a převody EMT (EBA No Action Letter) Podle stanoviska EBA/Op/2025/08 z 10. 6. 2025 představuje (a) úschova a správa EMT a (b) provádění převodů EMT jménem klientů platební službu podle směrnice (EU) 2015/2366 (PSD2), protože EMT jsou právně elektronickými penězi. Naopak směna EMT na vlastní účet a zprostředkování nákupu EMT platební sl	Regulace a compliance	EBA Opinion / No Action Letter EBA/Op/2025/08 k interakci PSD2 a MiCAR
Právní povinnost	Lhůty licenčního řízení CASP Příslušný orgán posoudí do 25 pracovních dnů od doručení žádosti její úplnost; při neúplnosti stanoví lhůtu k doplnění. Do 40 pracovních dnů od doručení úplné žádosti posoudí soulad s Hlavou V a rozhodne o udělení či zamítnutí autorizace. Běh lhůty lze přerušit mezi žádostí o doplnění a jejím obdrže	Regulace a compliance	Nařízení (EU) 2023/1114 (MiCA), čl. 63

Závaznost	Požadavek	Vrstva	Zdroj
Právní povinnost	Konec přechodného období (grandfathering) — v Litvě již 1. 1. 2026 Podle čl. 143(3) MiCA mohli poskytovatelé, kteří legálně působili podle národního práva před 30. 12. 2024, pokračovat do 1. 7. 2026, nebo do udělení či zamítnutí autorizace CASP, podle toho, co nastane dříve. Členské státy mohly období zkrátit. Litva jej zkrátila na 12 měsíců — pro litevské VASP ted	Regulace a compliance	Nařízení (EU) 2023/1114 (MiCA), čl. 143(3); ESMA přehled národních přechodných období
Právní povinnost	Systém správy a řízení, ICT bezpečnost, střety zájmů, outsourcing, stížnosti a wind-down Průřezové provozní povinnosti všech CASP: jednat čestně, spravedlivě a profesionálně v nejlepším zájmu klientů (čl. 66); vedení s dostatečnou dobrou pověstí, znalostmi a časovou kapacitou, posouzení kvalifikovaných účastí, vhodné organizační uspořádání, systémy a bezpečnostní protokoly splňující sta	Regulace a compliance	Nařízení (EU) 2023/1114 (MiCA), čl. 66–74
Právní povinnost	Travel Rule — informace doprovázející převody kryptoaktiv Od 30. 12. 2024 musí CASP u každého převodu kryptoaktiv, bez ohledu na částku (neexistuje de minimis práh jako u převodů peněžních prostředků), shromažďovat, ověřovat, předávat a uchovávat údaje o plátcí (originator) a příjemci (beneficiary). Minimálně: jméno, adresa distribuovaného registru / číslo	Regulace a compliance	Nařízení (EU) 2023/1113, zejména čl. 14, 15, 16, 19–21
Právní povinnost	AMLR (EU) 2024/1624 — přímo použitelná AML pravidla od 10. 7. 2027 CASP jsou výslovně povinnými osobami. Od 10. 7. 2027 platí přímo použitelný jednotný soubor pravidel: interní politiky, kontroly a postupy přiměřené velikosti a rizikům; hloubková kontrola klienta (CDD) při navádění obchodního vztahu, u příležitostných transakcí s kryptoaktivy od 1 000 EUR, při pode	Regulace a compliance	Nařízení (EU) 2024/1624 (AMLR)
Právní povinnost	Zákaz anonymních účtů a anonymity-enhancing coins (AMLR čl. 79) Od 10. 7. 2027 nesmějí povinné osoby vést anonymní účty, anonymní pasbooky, anonymní bezpečnostní schránky ani anonymní účty kryptoaktiv, ani účty umožňující anonymizaci transakcí. CASP nesmějí vést účty držící tzv. anonymity-enhancing coins — kryptoaktiva navržena tak, aby ve výchozím nastavení neb	Regulace a compliance	Nařízení (EU) 2024/1624 (AMLR), čl. 79
Právní povinnost	AMLD6 (EU) 2024/1640 — transpoziční povinnosti a rejstříky Směrnice upravuje uspořádání dohledu, pravomoci FIU, přístup k registrům skutečných majitelů, k centralizovaným registrům bankovních a platebních účtů a k registrům nemovitostí, a rovněž sankční rámec. Hlavní transpoziční lhůta je 10. 7. 2027; některá ustanovení (zejména přístup k centrálním registr	Regulace a compliance	Směrnice (EU) 2024/1640 (AMLD6)
Právní povinnost	AMLA — nový evropský dohledový orgán a přímý dohled od 2028 Nařízení (EU) 2024/1620 zřídilo Úřad pro boj proti praní peněz (AMLA) se sídlem ve Frankfurtu; většina ustanovení se použije od 1. 7. 2025. AMLA vydává technické standardy a pokyny doplňující AMLR/AMLD6 a od roku 2028 bude přímo dohlížet na vybrané povinné osoby ve finančním sektoru — očekává se cca	Regulace a compliance	Nařízení (EU) 2024/1620 (AMLAR)
Právní povinnost	Licence EMI — počáteční kapitál a průběžné vlastní zdroje Instituce elektronických peněz musí v okamžiku autorizace držet počáteční kapitál nejméně 350 000 EUR. Průběžné vlastní zdroje musí odpovídat nejméně 2 % průměrných nesplacených elektronických peněz (metoda D), a nesmějí klesnout pod počáteční kapitál; u hybridních institucí poskytujících i platební	Regulace a compliance	Směrnice 2009/110/ES (EMD2), čl. 4 a čl. 5
Právní povinnost	Safeguarding klientských prostředků u EMI EMI musí chránit prostředky přijaté výměnou za vydané elektronické peníze podle čl. 7 EMD2 ve spojení s čl. 10 PSD2. Dvě přípustné metody: (a) segregace — prostředky se nesmějí mísit s prostředky jiných osob než držitelů e-peněz, ukládají se na oddělený účet u úvěrové instituce nebo se investují do	Regulace a compliance	Směrnice 2009/110/ES (EMD2), čl. 7

Závaznost	Požadavek	Vrstva	Zdroj
Právní povinnost	PSD2 — provozní povinnosti platebního segmentu Pokud subjekt poskytuje platební služby (a podle EBA/Op/2025/08 to zahrnuje úschovu a převody EMT jménem klienta), uplatní se plný režim PSD2: silné ověření klienta (SCA) při přístupu k účtu online, iniciaci elektronické platby a jednání s rizikem podvodu, včetně dynamického propojení (čl. 97 a RTS)	Regulace a compliance	Směrnice (EU) 2015/2366 (PSD2), zejména čl. 73, 74, 96, 97, 101–103
Právní povinnost	DORA — digitální provozní odolnost Nařízení (EU) 2022/2554 je účinné od 17. 1. 2025 a vztahuje se výslovně jak na CASP autorizované podle MiCA, tak na EMI a platební instituce. Pět pilířů: (1) rámec řízení ICT rizik schválený a odpovědně vlastněný vedoucím orgánem, včetně klasifikace ICT aktiv a strategie digitální odolnosti; (2) kla	Regulace a compliance	Nařízení (EU) 2022/2554 (DORA), zejména čl. 5–16 (ICT risk), 17–23 (incidenty), 24–27 (testování), 28–44 (třetí strany)
Právní povinnost	Litva — Lietuvos bankas jako příslušný orgán a substanční požadavky Lietuvos bankas je určeným národním příslušným orgánem pro autorizaci CASP a vydavatelů EMT i pro licencování EMI a platebních institucí, a vykonává prudenciální dohled. AML/CFT dohled vykonává Finanční vyšetřovací služba (FNIT / FCIS), která provádí plánované i neplánované kontroly. V praxi Lietuvo	Regulace a compliance	MiCA čl. 93 (určení příslušných orgánů) ve spojení s litevským prováděcím zákonem; Lietuvos bankas
Právní povinnost	Ochrana spotřebitele a GDPR jako průřezová vrstva Vedle sektorové regulace se uplatní obecná pravidla: nařízení (EU) 2016/679 (GDPR) — právní základ zpracování KYC/AML údajů, retence po dobu 5 let podle AML předpisů jako zákonná povinnost, DPIA u biometrického ověřování a monitoringu transakcí, posouzení předávání do třetích zemí u cloudových a blo	Regulace a compliance	Nařízení (EU) 2016/679 (GDPR), zejména čl. 5, 6(1)(c), 17, 35, 44–49
Právní povinnost	Právní titul KYC: právní povinnost, nikoli souhlas Zpracování identifikačních údajů, dokladů totožnosti a údajů o původu prostředků při KYC/CDD se opírá o čl. 6 odst. 1 písm. c) GDPR (splnění právní povinnosti podle AML předpisů), doplňkově o čl. 6 odst. 1 písm. b) (plnění smlouvy) u údajů nutných k vedení účtu. Implementačně to znamená: žádný check	Ochrana osobních údajů	Nařízení (EU) 2016/679 (GDPR), čl. 6 odst. 1 písm. b) a c), čl. 7
Právní povinnost	Minimalizace a účelové omezení KYC dat Sbírat jen údaje, které AML předpis skutečně vyžaduje pro daný rizikový profil (jméno, datum narození, adresa, číslo a typ dokladu, státní příslušnost, účel obchodního vztahu, zdroj prostředků u vyššího rizika). Praktické dopady: neukládat celé skeny dokladu, pokud stačí ověřené atributy + doklad o	Ochrana osobních údajů	GDPR čl. 5 odst. 1 písm. b) a c)
Právní povinnost	Doby uchování: AML retence vs. omezení uložení AML vyžaduje uchovat kopie dokladů a záznamy o transakcích 5 let od skončení obchodního vztahu nebo od provedení příležitostné transakce; členské státy mohou prodloužit až na 10 let. AMLR čl. 77 (přímo použitelný od 10. 7. 2027) navíc zakazuje záznamy redigovat — musí zůstat úplné a nezměněné. V ČR	Ochrana osobních údajů	AMLR (EU) 2024/1624 čl. 77
Právní povinnost	Omezení práv subjektu údajů kvůli zákazu tipování (tipping-off) Pokud klient podal žádost o přístup nebo výmaz a zároveň je předmětem oznámení podezřelého obchodu, nesmí být z odpovědi patrné, že takové oznámení existuje. Prakticky: odpovědní workflow na DSAR musí mít krok kontroly proti AML case managementu, exporty pro klienta nesmí obsahovat interní risk skór	Ochrana osobních údajů	GDPR čl. 23 a čl. 15
Právní povinnost	Šifrování při přenosu (TLS 1.3, mTLS pro integrace) Veškerá komunikace klient–aplikace, aplikace–API, aplikace–databáze i mezi mikroslužbami musí být šifrována. Konkrétně: TLS 1.3 (minimálně 1.2 s omezenou sadou šifer), HSTS s preload, zákaz downgrade, certificate pinning u mobilní aplikace, mTLS nebo podepsané payloady u integrací s KYC providerem,	Ochrana osobních údajů	Nařízení Komise (EU) 2024/1774, RTS k rámci řízení ICT rizik, čl. 6–7 (šifrování a kryptografické kontroly)
Právní povinnost	Šifrování v klidu a správa klíčů Databáze, objektové úložiště se skeny dokladů, zálohy, logy i dočasné soubory musí být šifrovány. Doporučený standard je AES-256 (nebo ekvivalent), přičemž samotné šifrování disku (FDE) nestačí jako opatření proti aplikačnímu úniku — u nejcitlivějších polí (číslo dokladu, biometrická šablona, adresa	Ochrana osobních údajů	RTS (EU) 2024/1774 čl. 6–9 (šifrování dat v klidu, správa kryptografických klíčů)

Závaznost	Požadavek	Vrstva	Zdroj
Právní povinnost	Pseudonymizace jako povinné opatření záměrné ochrany EDPB v Guidelines 01/2025 potvrdil, že pseudonymizovaná data zůstávají osobními údaji pro toho, kdo má přístup k dodatečné informaci, ale pseudonymizace snižuje riziko a je uznávaným opatřením podle čl. 25 a 32. Implementačně: interní identifikátor klienta odpojený od jména a rodného čísla; přiřazov	Ochrana osobních údajů	EDPB Guidelines 01/2025 on Pseudonymisation (přijaty 16. 1. 2025)
Právní povinnost	Umístění dat a předávání mimo EU GDPR nevyžaduje, aby data zůstala v EU, ale vyžaduje pro každé předání do třetí země platný mechanismus. K srpnu 2026 platí: EU-US Data Privacy Framework je platný (Tribunál zamítl žalobu Latombe 3. 9. 2025), ale běží kasační opravný prostředek u SDEU (C-703/25 P), takže je nutné mít připravenou zál	Ochrana osobních údajů	GDPR kap. V, čl. 44–49
Právní povinnost	Právo na výmaz vs. neměnnost blockchainu — osobní údaje mimo řetězec EDPB přijal Guidelines 02/2025 o zpracování osobních údajů prostřednictvím blockchainu (verze 2.0 přijata 7. 7. 2026). Klíčová stanoviska: (1) zašifrovaný ani zahashovaný údaj nepřestává být osobním údajem — hash veřejného klíče, transakční identifikátor nebo hash dokumentu jsou nadále v režimu GDPR	Ochrana osobních údajů	EDPB Guidelines 02/2025 on processing of personal data through blockchain technologies, v2.0 (7. 7. 2026)
Právní povinnost	Biometrické údaje při ověření totožnosti Selfie s liveness detekcí, porovnání obličeje s fotografií v dokladu a hlasová verifikace vytvářejí biometrické údaje ve smyslu čl. 9 GDPR, pokud slouží k jedinečné identifikaci. Zpracování je zakázáno, dokud neplatí některá výjimka — v praxi výslovný souhlas (čl. 9 odst. 2 písm. a) nebo významný ve	Ochrana osobních údajů	GDPR čl. 9 odst. 1 a 2, čl. 4 bod 14
Právní povinnost	Oznamování porušení zabezpečení — dva paralelní režimy Při incidentu běží dvě nezávislé lhůty. GDPR: oznámení dozorovému úřadu (v ČR ÚOOÚ) do 72 hodin od okamžiku, kdy se správce o porušení dozvěděl, a oznámení dotčeným klientům bez zbytečného odkladu, pokud hrozí vysoké riziko (výjimka platí u silně šifrovaných dat). DORA: u závažného ICT incidentu prv	Ochrana osobních údajů	GDPR čl. 33 a 34
Právní povinnost	Posouzení vlivu na ochranu osobních údajů (DPIA) U aplikace, která kombinuje rozsáhlé zpracování finančních údajů, doklady totožnosti, biometrické ověření, automatizované AML scoring a distribuovanou technologii, je DPIA povinná — naplňuje se hned několik kritérií WP248 (hodnocení a scoring, zvláštní kategorie údajů, data velkého rozsahu, inovativ	Ochrana osobních údajů	GDPR čl. 35 a 36
Právní povinnost	Zpracovatelské smlouvy a řetězec subdodavatelů S každým dodavatelem, který se dotýká osobních údajů (KYC/AML provider, cloud, e-mailová a SMS brána, monitoring, podpora, analytika, blockchain node provider), musí být uzavřena smlouva podle čl. 28 odst. 3 GDPR s povinnými náležitostmi: předmět a doba, povaha a účel, kategorie údajů a subjektů, po	Ochrana osobních údajů	GDPR čl. 28
Právní povinnost	Hodnocení dodavatelů a řízení ICT rizik třetích stran podle DORA Nad rámec GDPR ukládá DORA finančním subjektům samostatný režim pro dodavatele ICT: před smluvní due diligence a posouzení koncentračního rizika, povinný registr informací o všech smluvních ujednáních (Article 28(3) Register of Information) s uvedením kritičnosti, lokalit zpracování a uložení dat a s	Ochrana osobních údajů	DORA (EU) 2022/2554 čl. 28–30
Právní povinnost	Řízení přístupu, auditní stopa a logování přístupů ke KYC datům Přístup ke KYC složkám a skenům dokladů musí být omezen na role, které je nezbytně potřebují, s vícefaktorovým ověřením, principem nejmenších oprávnění, oddělením rolí a časově omezeným přístupem (just-in-time) pro podporu. Každé nahlédnutí do KYC složky konkrétního klienta musí být logováno (kdo, k	Ochrana osobních údajů	GDPR čl. 32 odst. 1 písm. b) a čl. 5 odst. 2 (odpovědnost)

Závaznost	Požadavek	Vrstva	Zdroj
Právní povinnost	Informační povinnost a záznamy o činnostech zpracování Klientovi je nutné před sběrem údajů poskytnout úplné informace podle čl. 13: totožnost správce a DPO, účely a právní tituly (zvlášť KYC z právní povinnosti, zvlášť marketing ze souhlasu), příjemci včetně kategorií dodavatelů, předávání mimo EU a jeho mechanismus, doby uchování pro jednotlivé katego	Ochrana osobních údajů	GDPR čl. 12–14 a čl. 30
Právní povinnost	Údaje doprovázející převody (travel rule) a jejich ochrana U převodů kryptoaktiv i klasických převodů prostředků musí spolu s transakcí putovat identifikační údaje odesílatele i příjemce (jméno, číslo účtu/adresa peněženky, adresa nebo číslo dokladu, u kryptoaktiv bez prahové hodnoty). Tyto údaje se uchovávají 5 let. Z hlediska ochrany dat to znamená: údaje	Ochrana osobních údajů	Nařízení (EU) 2023/1113 (TFR), čl. 4, 14, 21
Právní povinnost	Jmenování pověřence pro ochranu osobních údajů (DPO) Finanční aplikace zpracovávající KYC data ve větším rozsahu naplňuje čl. 37 odst. 1 písm. b) i c) — pravidelné a systematické monitorování subjektů údajů (transakční monitoring) i rozsáhlé zpracování zvláštních kategorií (biometrie). DPO musí být nezávislý, nesmí být ve střetu zájmů (nemůže jím být	Ochrana osobních údajů	GDPR čl. 37–39
De facto standard	iOS Keychain: správné třídy dostupnosti a ochrana proti přenosu záloh Konkrétní implementace: veškerý citlivý materiál v Keychainu, nikdy v UserDefaults ani v souborech. Používat kSecAttrAccessibleWhenUnlockedThisDeviceOnly pro data potřebná jen v popředí (tokeny, klíče relace) a kSecAttrAccessibleAfterFirstUnlockThisDeviceOnly pouze tam, kde je nutný běh na pozadí. S	Klientská vrstva	OWASP MASVS-STORAGE-1 a MASTG v2.0.0 (iOS testy MASVS-STORAGE)
De facto standard	Android Keystore / StrongBox: hardwarově vázané, neexportovatelné klíče Podpisové a šifrovací klíče generovat uvnitř Android Keystore (KeyGenParameterSpec), nikdy nevytvářet v paměti a poté importovat. Pro platební operace nastavit setIsStrongBoxBacked(true) tam, kde zařízení StrongBox (dedikovaný bezpečnostní čip, např. Titan M2) má, s fallbackem na TEE a s ošetřením S	Klientská vrstva	OWASP MASVS-CRYPTO-2 a MASVS-STORAGE-1
De facto standard	Anti-static analysis: obfuskace a odstranění ladicích informací Ztížení reverzního inženýrství. Implementačně: Android — R8/ProGuard v release režimu s agresivními pravidly, přejmenování tříd a metod, odstranění debug symbolů, string encryption pro citlivé konstanty (endpointy, pinning hashe, názvy kontrol), pro klíčovou logiku (podpis transakce, detekce integri	Klientská vrstva	OWASP MASVS-RESILIENCE-3 (anti-static analysis) a MASTG v2.0.0
De facto standard	Anti-dynamic analysis: detekce debuggeru, hookovacích frameworků a emulátoru Detekce běhu pod nástroji dynamické analýzy. Implementačně: Android — kontrola Debug.isDebuggerConnected() a TracerPid v /proc/self/status, detekce Frida (otevřené porty 27042/27047, gadget knihovny v /proc/self/maps, řetězce 'frida', 'gum-js-loop'), Xposed/LSPosed a Zygisk modulů, detekce emulátoru	Klientská vrstva	OWASP MASVS-RESILIENCE-4 (anti-dynamic analysis) a MASTG v2.0.0
De facto standard	Certificate pinning na všechny endpointy pod kontrolou vývojáře Aplikace má provádět identity pinning pro všechny vzdálené endpointy pod kontrolou vývojáře. Implementačně: pinovat SPKI hash (SHA-256 veřejného klíče), ne celý certifikát — přežije obnovu certifikátu se stejným klíčem. Android: Network Security Config s <pin-set> a expiration, nebo OkHttp Cer	Klientská vrstva	OWASP MASVS-NETWORK-2
De facto standard	Ochrana proti odposlechu obrazovky: screenshoty, nahrávání, náhled v přepínači aplikací Zásadní asymetrie platform. Android: FLAG_SECURE na okna s citlivým obsahem — blokuje screenshot, nahrávání, casting i náhled v Recents. Od Androidu 15 (API 35) je navíc k dispozici detekce nahrávání obrazovky (Activity.registerScreenCaptureCallback / ScreenRecordingCallback) a systém automaticky c	Klientská vrstva	OWASP MASVS-PLATFORM-3 (secure UI) a MASWE-0038 (Insufficient Protection of Sensitive Data from Screenshots or Screen Recordings)

Závaznost	Požadavek	Vrstva	Zdroj
De facto standard	Ochrana proti overlay útokům a zneužití Accessibility služeb Aplikace nesmí být zranitelná vůči překrytí cizím oknem (tapjacking) — to je hlavní vektor bankovních trojanů. Implementačně Android: <code>setFilterTouchesWhenObscured(true)</code> na citlivá tlačítka (zejména potvrzení platby), kontrola <code>MotionEvent.FLAG_WINDOW_IS_OBSCURED</code> a <code>FLAG_WINDOW_IS_PARTIALLY_OBSCURED</code> , n	Klientská vrstva	OWASP MASVS-PLATFORM-3 a MASWE-0039 (App Vulnerable to Overlay Attacks)
De facto standard	Zamezení úniku citlivých dat mimo úložiště aplikace (logy, cache, IPC, deeplinky) Implementačně: žádné citlivé údaje v <code>logcat/os_log</code> ani v release buildu (odstranit log volání přes ProGuard pravidla), nikdy do crash reportingu a analytiky (Crashlytics, Sentry — nastavit scrubbing). Vypnout <code>WebView</code> cache a ukládání formulářů, mazat cache při logoutu. Android: exportované komponent	Klientská vrstva	OWASP MASVS-STORAGE-2 (prevence úniku) a MASVS-PLATFORM-1 (IPC)
De facto standard	Bezpečné použití WebView / vestavěného prohlížeče Pokud aplikace zobrazuje webový obsah (např. 3-D Secure, souhlasy, PSD2 redirect flow): zakázat JavaScript tam, kde není nutný; nikdy nepoužívat <code>addJavascriptInterface</code> pro citlivé nativní funkce (a pokud ano, jen s <code>@JavascriptInterface</code> a bez přístupu k relaci); zakázat <code>setAllowFileAccess</code> , <code>setAllowFi</code>	Klientská vrstva	OWASP MASVS-PLATFORM-2 (WebViews)
De facto standard	Self-contained tokeny (JWT): validace algoritmu, publika a životnosti Pokud se používají JWT/JWS jako nositelé relace nebo autorizace: na serveru vynutit whitelist algoritmů (nikdy neakceptovat 'none' ani nepřepínat mezi RS256/HS256 podle hlavičky), ověřit iss, aud, exp, nbf, jti; krátká životnost access tokenu (minuty) + refresh token s rotací a detekcí znovupoužití.	Klientská vrstva	OWASP ASVS 5.0.0 kap. 9 (Self-contained Tokens) a kap. 10 (OAuth and OIDC)
De facto standard	Bezpečnostní hlavičky a ochrana frontendu (CSP, anti-clickjacking) Podle ASVS 5.0 kap. 3. Implementačně: Content-Security-Policy s nonce nebo hashy pro skripty, bez 'unsafe-inline' a 'unsafe-eval', s frame-ancestors 'none' (nahrazuje X-Frame-Options), s explicitním connect-src a form-action. Dále Strict-Transport-Security s preload, X-Content-Type-Options: nosniff,	Klientská vrstva	OWASP ASVS 5.0.0 kap. 3 (Web Frontend Security) a kap. 1 (Encoding and Sanitization)
De facto standard	Vynucení aktualizace aplikace a minimální verze platformy Aplikace musí umět vynutit svou aktualizaci a běžet na podporované verzi OS. Implementačně: server vrací minimální podporovanou verzi klienta; při nižší verzi aplikace zablokuje platební funkce a nabídne update (Android In-App Updates API v režimu IMMEDIATE, iOS kontrola verze proti App Store API +	Klientská vrstva	OWASP MASVS-CODE-1 (aktuální platforma) a MASVS-CODE-2 (vynucení aktualizací)
De facto standard	Validace a sanitizace vstupů na klientovi (a povinné zopakování na serveru) Klient validuje formát částky, čísla účtu, IBAN, reference — ale výhradně jako UX. Veškerá validace se musí opakovat na serveru, protože klientský kód je plně pod kontrolou útočníka. Implementačně: parsování a validace veškerých vstupů z externích zdrojů (deeplinky, QR kódy platebních příkazů, NFC,	Klientská vrstva	OWASP MASVS-CODE-4
De facto standard	Silná kryptografie a správa klíčů na klientovi Používat pouze aktuální primitiva: AES-256-GCM nebo ChaCha20-Poly1305 pro symetrické šifrování, ECDSA P-256 / Ed25519 nebo RSA-3072+ pro podpisy, SHA-256+, HKDF pro odvozování, CSPRNG platformy (SecureRandom bez seedu, SecRandomCopyBytes). Zakázáno: MD5, SHA-1, DES/3DES, ECB mód, statické IV, vlastn	Klientská vrstva	OWASP MASVS-CRYPTO-1 a MASVS-CRYPTO-2
De facto standard	Ověření podle MASVS/MASTG a ASVS jako doložený proces, ne jednorázový test Pro bankovní aplikaci se jako referenční bere profil MAS-L2 (pokročilá bezpečnost pro aplikace s citlivými daty a kritickými funkcemi) PLUS MAS-R (odolnost proti reverznímu inženýrství a manipulaci); u webu ASVS úroveň L2, u nejcitlivějších funkcí L3. Implementačně: mapovat každý požadavek na konkré	Klientská vrstva	OWASP MASVS v2.1.0 (18. 1. 2024, 8 kategorií / 24 kontrol)

Závaznost	Požadavek	Vrstva	Zdroj
De facto standard	Podvojný append-only ledger jako jediný zdroj pravdy o penězích Zůstatek nesmí být sloupec, který se přepisuje UPDATE příkazem. Implementačně: tabulka postings, kde každá transakce generuje minimálně dva řádky (debet a kredit) se součtem přesně nula, kontrolované databázovým constraintem nebo trigger/deferred check; žádné UPDATE ani DELETE na záúčtovaných řádcích	Backend a platforma	De facto standard finančního inženýrství; opora v požadavcích na integritu: DORA čl. 9 odst. 2 a čl. 12 odst. 5 (kontroly a rekonc
De facto standard	Idempotence a exactly-once sémantika platebních operací Každá mutující platební operace musí být bezpečně opakovatelná. Implementačně: povinná hlavička Idempotency-Key (UUIDv4) generovaná klientem, uložení dvojice klíč → hash požadavku → odpověď v databázi s unique constraintem, návrat původní odpovědi při opakování a chyba 409 při stejném klíči s odlišn	Backend a platforma	De facto standard platebních API (Stripe, Adyen, Braintree vyžadují idempotency key na charge endpointech); Berlin Group NextGenPS
De facto standard	Certifikace ISO/IEC 27001:2022 jako důkaz řízeného ISMS Právně povinná není, ale v praxi ji vyžadují protistrany, banky, investoři i dohled jako zkratku pro důkaz zralosti. Implementačně: definovaný rozsah ISMS, analýza rizik s metodikou, Prohlášení o aplikovatelnosti (SoA) pokrývající 93 kontrol Annexu A ve čtyřech doménách (organizační, personální, fyz	Backend a platforma	ISO/IEC 27001:2022
De facto standard	PCI DSS v4.0.1 při jakémkoli kontaktu s karetními daty Aplikuje se jen tehdy, pokud platforma ukládá, zpracovává nebo přenáší data držitelů karet — u čistě SEPA/účetního backendu neplatí, u karetní vrstvy ano. Implementačně: minimalizace CDE (ideálně tokenizace a hosted fields, aby PAN vůbec nevstoupil do vašich systémů), maskování PAN, šifrování v klid	Backend a platforma	PCI DSS v4.0.1 (červen 2024), future-dated požadavky povinné od 31. 3. 2025
De facto standard	Segregace peněženek hot / warm / cold s limity expozice Tři oddělené domény klíčů s odlišnými bezpečnostními modely: hot (automatické podepisování, jen provozní minimum — typicky <1-2 % aktiv, tvrdý denní i per-transakční limit), warm (MPC/HSM s policy engine, lidské schválení, střední objemy), cold (offline, air-gapped, většina rezerv, žádná online	Blockchainová vrstva	CCSS v9.0 (CryptoCurrency Security Standard), aspekty Key Storage a Key Usage, C4 / CryptoCurrency Certification Consortium
De facto standard	Volba modelu úschovy klíčů: MPC/TSS vs. multisig vs. HSM MPC/TSS: klíč nikdy neexistuje celý na jednom místě, generuje se distribuovaně (DKG), podpis je na řetězci nerozeznatelný od běžného EOA podpisu (levnější gas, chain-agnostic), shares lze rotovat bez změny adresy. Smart-contract multisig (Safe): pravidla vynucená on-chain, auditovatelná, ale dražší	Blockchainová vrstva	Silence Laboratories, MPC vs Multisig: Key Management Architecture for Institutional Custody
De facto standard	HSM validované podle FIPS 140-3 Level 3 pro kořen důvěry Klíče (nebo MPC shares) generovat, ukládat, používat a ničit uvnitř validovaného kryptografického modulu — celý životní cyklus nesmí opustit hranici modulu. Prakticky: cloud HSM (AWS CloudHSM, Azure Managed HSM) nebo on-prem Thales/Utimaco; entropie z hardwarového TRNG uvnitř modulu, nikdy z aplikač	Blockchainová vrstva	NIST FIPS 140-3 / CMVP; přehled Thales
De facto standard	Nezávislé ověření obsahu transakce (anti blind-signing) — nejvyšší priorita Podepisující nikdy nesmí spoléhat na to, co ukazuje webové rozhraní podpisové aplikace. Implementačně: (1) clear signing — hardware wallet musí parsovat a zobrazit skutečná data volání (EIP-712 typed data + ERC-7730 metadata pro čitelnost), ne jen hash; (2) nezávislý verifikační kanál — každý signer	Blockchainová vrstva	NCC Group, In-Depth Technical Analysis of the Bybit Hack
De facto standard	Politika podepisování, čtyři oči a prahy multisigu úměrné hodnotě Formalizovaná signing policy s prahovými pásmy: pod X automaticky (hot, policy engine bez člověka), X–Y dva nezávislí schvalovatelé (iniciátor ≠ schvalovatel, tvrdě vynuceno v systému, ne procesně), nad Y tři a více plus schválení mimo IT (compliance/finance). Prahy multisigu volit vysoké — 3-z-11 j	Blockchainová vrstva	CCSS v9.0, aspekty Key Usage, Keyholder Grant/Revoke Policies a Key Compromise Protocol

Závaznost	Požadavek	Vrstva	Zdroj
De facto standard	Whitelisting výběrových adres s časovým zámekem 24–48 h Odchází transakce jen na adresy z allowlistu. Přidání nebo změna adresy vyžaduje: schválení čtyřma očima, potvrzení druhým kanálem (e-mail + 2FA/passkey) a povinnou čekací dobu 24–48 h, během níž nelze na novou adresu odeslat nic. Zámek musí být vynucen na straně policy engine (server-side, nezávisl)	Blockchainová vrstva	Crypto.com, 24h Withdrawal Lock on Newly-Added Withdrawal Address
De facto standard	Politika potvrzení a ochrana proti reorg Definovat a kódem vynutit počet potvrzení, po kterém se přichází vklad připisuje. Ethereum má hard finalitu po 2 epochách = 64 slotů ≈ 12,8 min; single-slot finality je v roce 2026 stále jen ve výzkumu bez termínu nasazení. Praxe burz: 12 potvrzení (Binance ≈ 2,4 min), 14 (Coinbase), 20 (Kraken) — t	Blockchainová vrstva	ethereum.org, Single slot finality (roadmap, stav 2026)
De facto standard	Správa nonce: centralizovaný serializer a reconciliace Každý EOA odesílá transakce ve striktní posloupnosti podle nonce; jakákoli mezera zablokuje všechny následující transakce. Implementačně: (1) jeden proces (nebo distribuovaný zámek / DB sekvence) jako jediný zdroj pravdy pro nonce dané adresy — nikdy nespolehat jen na <code>`eth_getTransactionCount`</code> z RPC	Blockchainová vrstva	Chainstack, Ethereum Nonce Management: Prevent Stuck Transactions
De facto standard	Gas management a replace-by-fee EIP-1559: nastavovat <code>`maxFeePerGas`</code> s dostatečnou rezervou nad aktuální baseFee (baseFee může růst o 12,5 % za blok — pro jistotu 2× nad odhad při okně několika bloků) a <code>`maxPriorityFeePerGas`</code> podle percentilu z <code>`eth_feeHistory`</code> . Pro nahrazení zaseknuté transakce platí, že se musí zvýšit obě pole ne	Blockchainová vrstva	go-ethereum issue #23616, EIP-1559 mempool TX replacement condition (pravidlo +10 % na obě pole)
De facto standard	Relayery a meta-transakce: omezení důvěry a rozsahu delegace Pokud aplikace platí gas za uživatele (gasless UX), platí: (1) ERC-2771 trusted forwarder — kontrakt musí ověřovat <code>`_msgSender()`</code> výhradně přes ověřený forwarder a forwarder musí být immutable nebo měnitelný jen přes timelock; nikdy nepřijímat libovolného forwardera; (2) ERC-4337 — paymaster obsahuj	Blockchainová vrstva	EIP-4337: Account Abstraction Using Alt Mempool
De facto standard	Bezpečné zacházení s ERC-20 approve / transferFrom (1) Nikdy neudělovat neomezený (type(uint256).max) allowance — vždy přesná potřebná částka, ideálně jednorázová; (2) pro tokeny vyžadující reset (USDT) použít <code>`forceApprove`</code> z OpenZeppelin SafeERC20, tj. nejprve approve(0), pak approve(N) — přímé přepsání nenulového allowance na jiné nenulové USDT k	Blockchainová vrstva	OpenZeppelin SafeERC20 (safeIncreaseAllowance / forceApprove)
De facto standard	Nestandardní chování USDT kontraktu na Ethereum USDT na Ethereum (0xdAC17F958D2ee523a2206206994597C13D831ec7) nevrací bool z <code>`transfer()`</code> a <code>`transferFrom()`</code> , což je porušení ERC-20 specifikace. Volání, které očekává návratovou hodnotu, revertne. Implementačně: veškeré token interakce vést přes OpenZeppelin SafeERC20 (<code>`safeTransfer`</code> , <code>`safeTransferF`</code>)	Blockchainová vrstva	OpenZeppelin SafeERC20 dokumentace a implementace
De facto standard	Freeze / blacklist funkce emitenta jako architektonický předpoklad Jak XSGD, tak USDT jsou centrálně kontrolované tokeny s upgradovatelným proxy a s funkcí umožňující emitentovi zmrazit adresu. XSGD (0x70e8de73ce538da2beed35d14187f6959a8eca96) je dvojice proxy + implementace, kde určený účet může freeze/unfreeze a wipe zůstatku libovolné adresy — StraitsX to uvádí	Blockchainová vrstva	StraitsX XSGD Token kontrakt na Etherscan
De facto standard	Audit vlastních smart kontraktů a bezpečný upgrade Každý kontrakt, který aplikace nasadí (i „jen“ forwarder, paymaster, vault nebo timelock), musí projít nezávislým auditem před nasazením a znovu po každé netriviální změně. Rozsah: automatizované nástroje (Slither, Semgrep, Mythril) v CI jako gate, manuální audit minimálně jedné renomované firmy, pr	Blockchainová vrstva	OWASP Smart Contract Security Verification Standard
De facto standard	Nepřetržitý on-chain monitoring s automatickým circuit breakerem Real-time sledování všech vlastních adres a kontraktů s automatizovanou reakcí, ne jen s alertem do Slacku. Implementačně: (1) detekce anomálií — neočekávaný odchází transfer, nový Approval, změna vlastnictví/implementace kontraktu, transakce mimo pracovní dobu, odchází objem nad rolling limit; (2)	Blockchainová vrstva	Hypernative, Security (circuit breakers, automatizované reakce)

Závaznost	Požadavek	Vrstva	Zdroj
De facto standard	Zabezpečení dodavatelského řetězce vývoje a front-endu Bybit i Radiant začaly kompromitací vývojářské strany, ne kryptografie. Implementačně: (1) pinning a integritní kontrola všech závislostí (lockfile + SRI pro veškeré skripty načítané v podpisovém UI), zákaz načítání JS z CDN třetích stran ve všech rozhraních dotýkajících se transakcí; (2) reprodukov	Blockchainová vrstva	NCC Group, In-Depth Technical Analysis of the Bybit Hack (kompromitace vývojářského stroje Safe a podvržení JS)
De facto standard	Redundance a nezávislost RPC / node infrastruktury Aplikace nesmí mít jediný pohled na řetězec. Implementačně: (1) minimálně dva nezávislé RPC provideři plus ideálně vlastní full node jako referenční zdroj pravdy pro kritické čtení (zůstatky, potvrzení, finalita); (2) cross-check kritických odpovědí mezi zdroji, alert při neshodě (kompromitovaný neb	Blockchainová vrstva	Chainstack, Ethereum Nonce Management (rizika nekonzistence mezi nody)
De facto standard	Zálohování, obnova klíčů a Key Compromise Protocol CCSS vyžaduje, aby klíče/seedy byly zálohovány, uloženy se silným šifrováním a rozmístěny do více geograficky oddělených lokalit tak, aby lokální výpadek neznemožnil disponovat prostředky. Implementačně: (1) zálohy v tamper-evident obalech v oddělených trezorech/depozitech s dokumentovanou chain of	Blockchainová vrstva	CCSS v9.0, aspekty Key Storage, Key Compromise Protocol, Keyholder Grant/Revoke Policies, Data Sanitization
De facto standard	Proof of reserves a průběžná rekonciliace on-chain vs. ledger Automatická, průběžná (ne měsíční) rekonciliace: součet interních klientských zůstatků v ledgeru musí odpovídat součtu skutečných on-chain zůstatků na kontrolovaných adresách, s alertem při jakékoli odchylce nad definovaný práh. Implementačně: (1) kanonický seznam kontrolovaných adres s prokázanou k	Blockchainová vrstva	CCSS v9.0, aspekt Proof of Reserve a Log Audits
De facto standard	Auditní logy podpisových a transakčních operací (WORM) Každé volání podpisové operace, každá změna policy, každá změna allowlistu, každý přístup ke klíčovému materiálu a každá odeslaná transakce musí být logovány neměnitelně: append-only/WORM úložiště mimo dosah provozních administrátorů, s časovými razítky ze spolehlivého zdroje, s identitou iniciátora	Blockchainová vrstva	CCSS v9.0, aspekt Log Audits
De facto standard	Litva — lhůty licenčního řízení EMI a provozní realita Pro plnou (neomezenou) licenci EMI je zákonná lhůta zpravidla 3 měsíce od doručení úplné dokumentace; v praxi se celý proces pohybuje mezi 3 a 6 měsíci, což je jedna z nejrychlejších lhůt v EU. Omezená (restricted) licence EMI bývá vyřízena rychleji, ale neumožňuje passporting a podléhá objemovým li	Regulace a compliance	Lietuvos bankas
De facto standard	Bezpečnost mobilní a webové aplikace podle uznávaných standardů Právní předpisy nestanoví konkrétní technické kontroly, ale dozor i dodavatelské due diligence očekávají soulad s etablovanými standardy. Prakticky: OWASP ASVS úroveň 2 pro webovou část, OWASP MASVS pro mobilní aplikaci (bezpečné úložiště, detekce rootu/jailbreaku, ochrana proti screenshotům obrazov	Ochrana osobních údajů	GDPR čl. 32 (stav techniky)
Doporučení	Riziko emitenta a depeg — monitoring a limity Stablecoin není bezriziková hotovost. USDC v březnu 2023 spadl na ~0,87 USD poté, co Circle oznámil 3,3 mld. USD (~8 % rezerv) uvízlých v Silicon Valley Bank; peg se obnovil až po zásahu FDIC. Implementačně: (1) nezávislý cenový monitoring stablecoinu proti fiat referenci (více zdrojů, ne jeden orac	Blockchainová vrstva	S&P Global, Stablecoins: A Deep Dive into Valuation and Depegging
Doporučení	Bridge riziko: nepoužívat vlastní ani nedůvěryhodné mosty Bridge hacky tvoří od roku 2022 přes 69 % všech odcizených prostředků v DeFi, kumulativně přes 2,8 mld. USD: Ronin 600 mil. USD (kompromitováno 5 z 9 klíčů), Wormhole 326 mil. USD, Nomad 190 mil. USD, Multichain přes 100 mil. USD (všechny klíče fakticky pod kontrolou jedné osoby). Nízkoprahové valid	Blockchainová vrstva	Chainlink Education Hub, 7 Cross-Chain Bridge Vulnerabilities Explained
Doporučení	PSD3 / PSR — stav příprav a dopad na plánování licence Baliček PSD3 (směrnice) + PSR (přímo použitelné nařízení) prošel politickou dohodou 27. 11. 2025, finální kompromisní texty Rada zveřejnila 23. 4. 2026, hlasování výboru ECON proběhlo 5. 5. 2026 a publikace v Úředním věstníku byla očekávána v Q2–Q3 2026 (možný skluz na září 2026). PSR vstoupí v plat	Regulace a compliance	Návrhy PSD3 COM(2023) 366 a PSR COM(2023) 367; legislativní stav

Závaznost	Požadavek	Vrstva	Zdroj
Doporučení	Anonymizace jako alternativa k výmazu — s vyšší laťkou Tam, kde nelze data fyzicky smazat (append-only ledgers, WORM zálohy, blockchain), se často sahá po anonymizaci. EDPB v návrhu Guidelines 02/2026 o anonymizaci (zveřejněn v červenci 2026, nahrazuje stanovisko WP29 z roku 2014) zpřísňuje test: anonymita se posuzuje relativně, s ohledem na prostředky	Ochrana osobních údajů	EDPB Guidelines 02/2026 on Anonymisation (návrh, veřejná konzultace 2026)

Dokument zpracován statickým auditem repozitáře largoverse-beta (revize bcfaa50) a rešerší platné evropské regulace ke dni 16. srpna 2026. Regulatorní část je podkladem pro právní posouzení, nikoli právním stanoviskem.